

Sessioni HTTP



Problema pratico importante



Documenti dinamici: (REMIND)



document è **costruito** da un **programma**:

1. Input: HTTP request
2. Esegue una qualche elaborazione
 - ☐ Caso particolare: query su database
3. Output: HTTP response

Funzionalità FONDAMENTALE

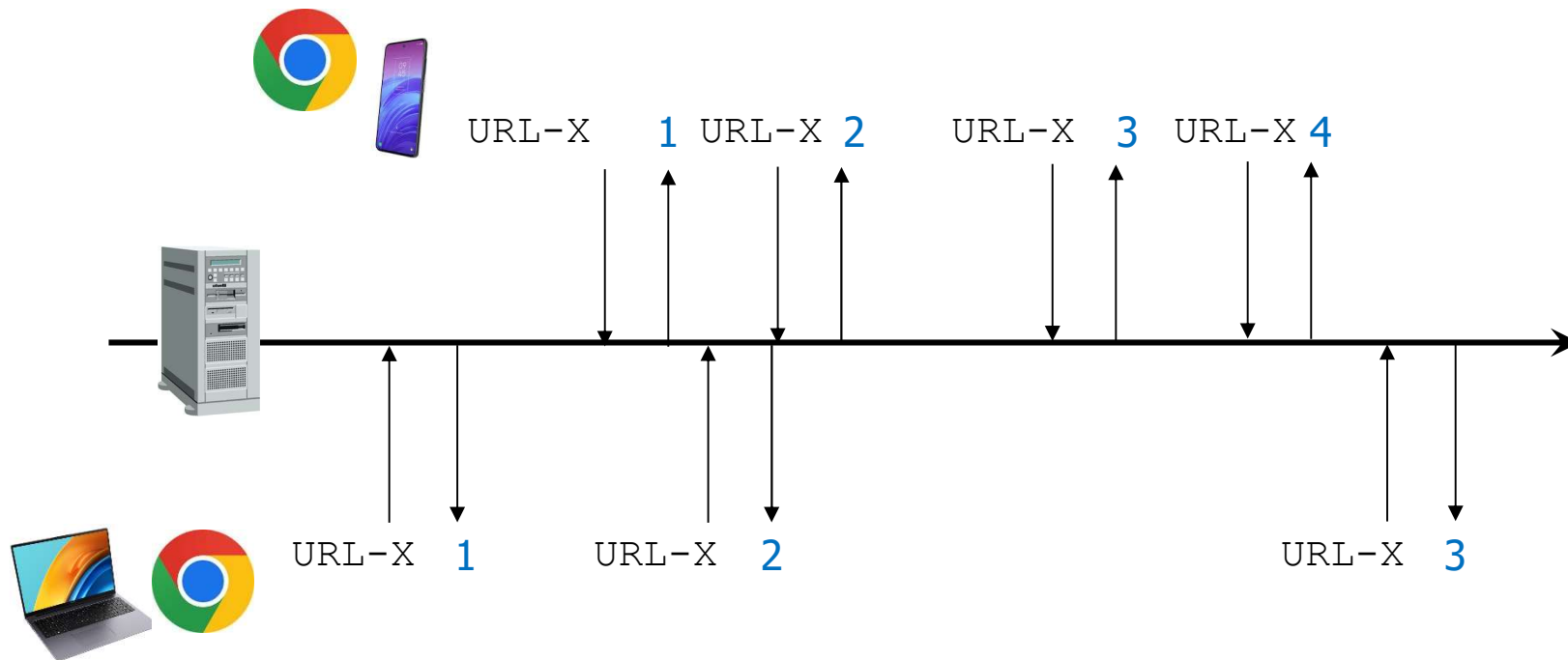


document è **costruito** da un **programma**:

1. Input: HTTP request inviate da **browser@device**
(la corrente **e le precedenti**)
 2. Esegue una qualche elaborazione
 - ☐ Caso particolare: query su database
 3. Output è HTTP response
-
- ☐ **Non** sappiamo (ancora) come realizzarla

Esempio banale (apparentemente)

- URL-X torna documento dinamico HTML con un solo paragrafo:
numero richieste ricevute da browser@device



E come fa?



- Una richiesta HTTP non contiene **nessun** riferimento alle richieste **precedenti** inviate dallo **stesso browser@device**
- HTTP is **stateless** (senza "stato")

```
GET /~bartolia/ HTTP/1.1\r\n
User-Agent: Mozilla/4.0 (compatible; MSIE 5.0; windows NT 5.0) opera 5.02 [en]\r\n
Host: uts.univ.trieste.it\r\n
Accept: text/html, image/png, image/jpeg, image/gif, image/x-xbitmap, */*\r\n
Accept-Language: en\r\n
Accept-Encoding: deflate, gzip, x-gzip, identity, *;q=0\r\n
Connection: Keep-Alive\r\n
\r\n
```

*Quale browser@device
l'ha inviata?*

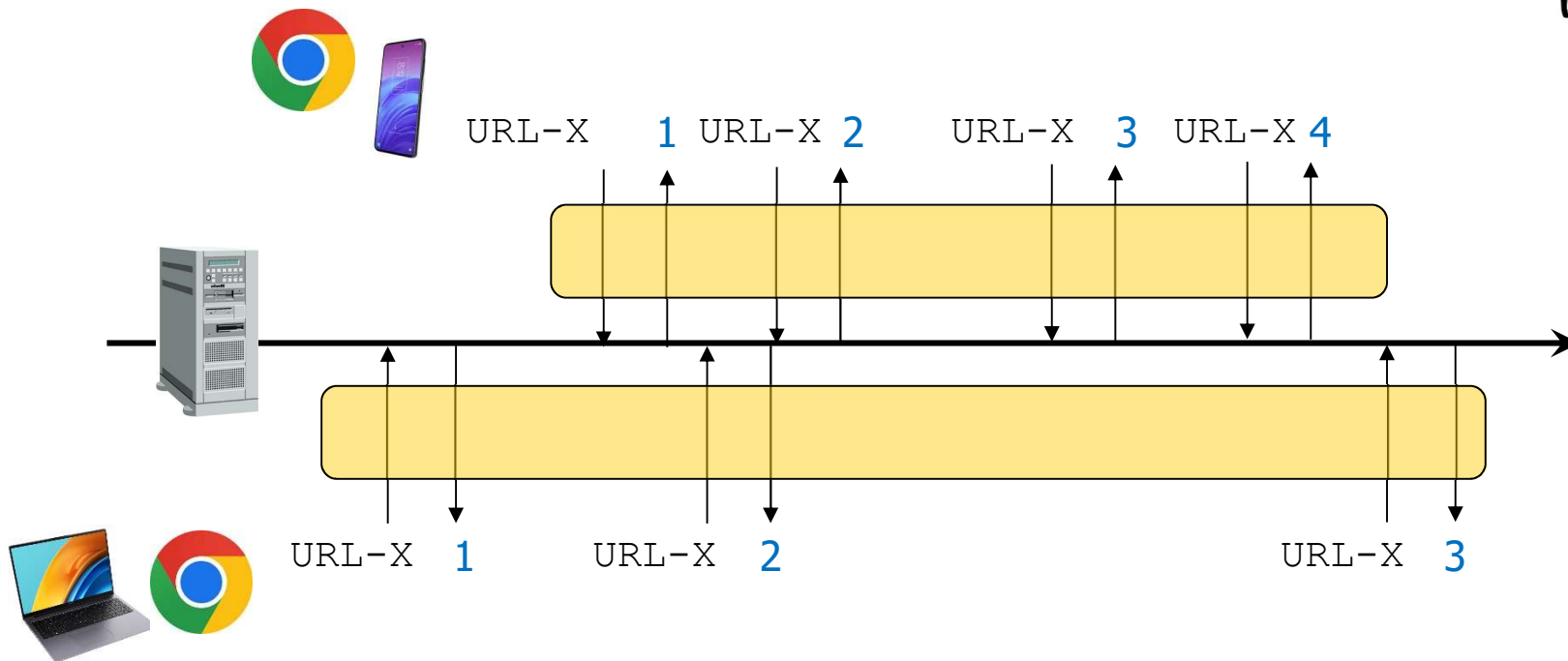


23/09/22

<https://bartoli.inginf.units.it>

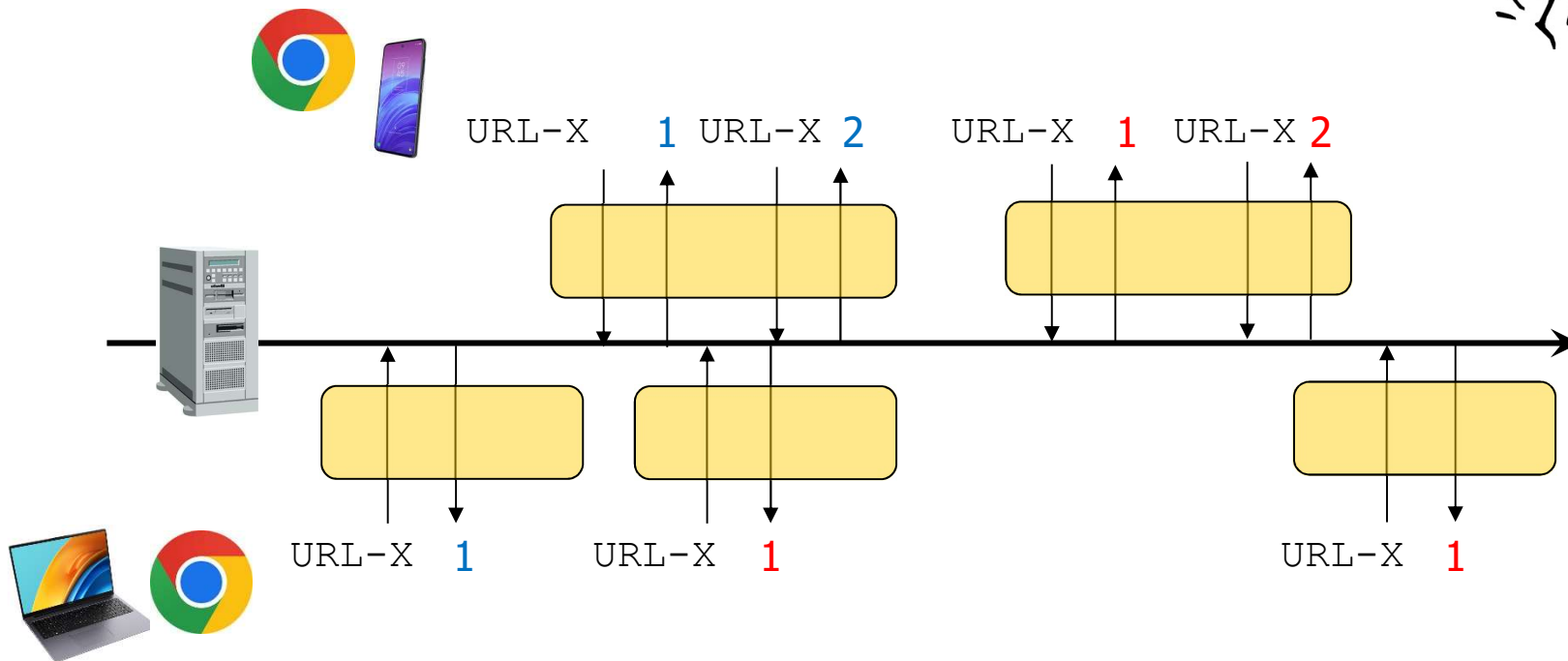
Tentativo

- Web server "aggancia" tutte le HTTP request che provengono dalla stessa connessione TCP



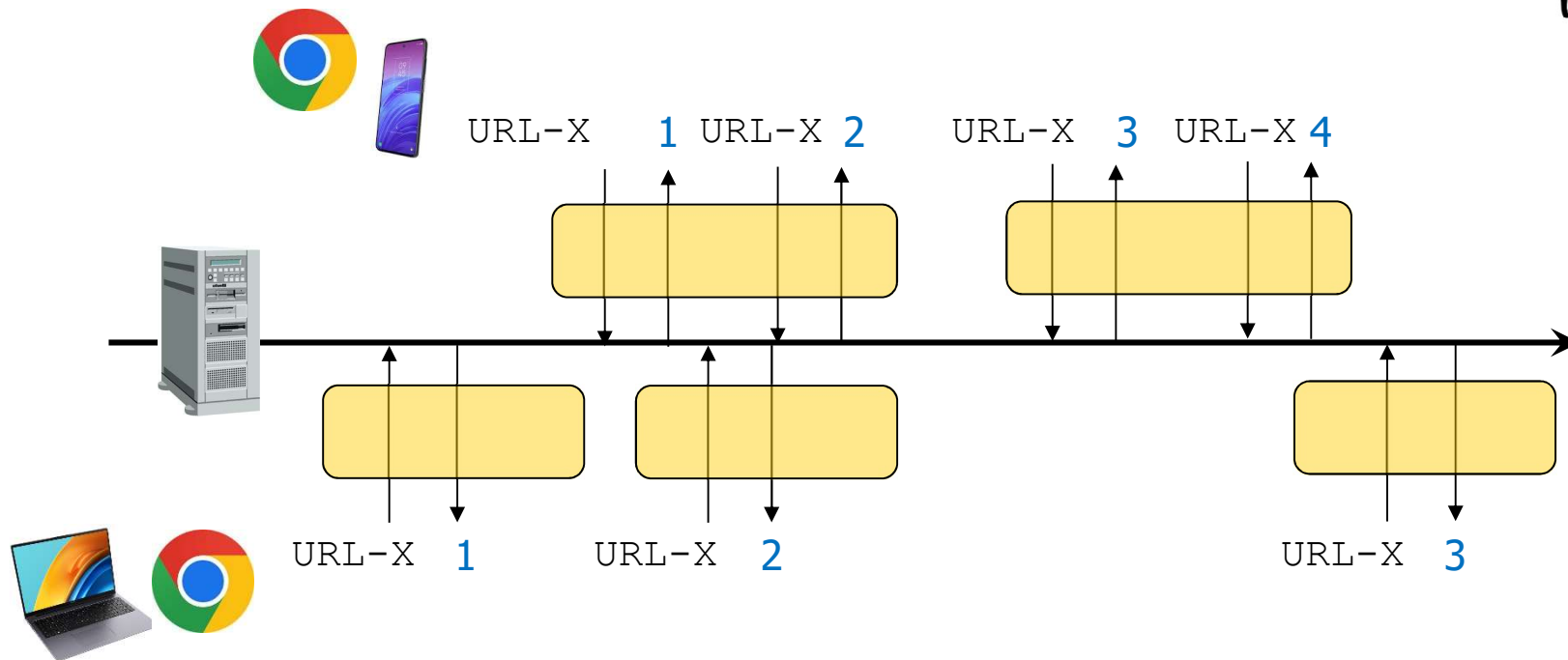
Non funziona!

- Una connessione TCP trasporta un numero **non predicibile** di coppie request-response

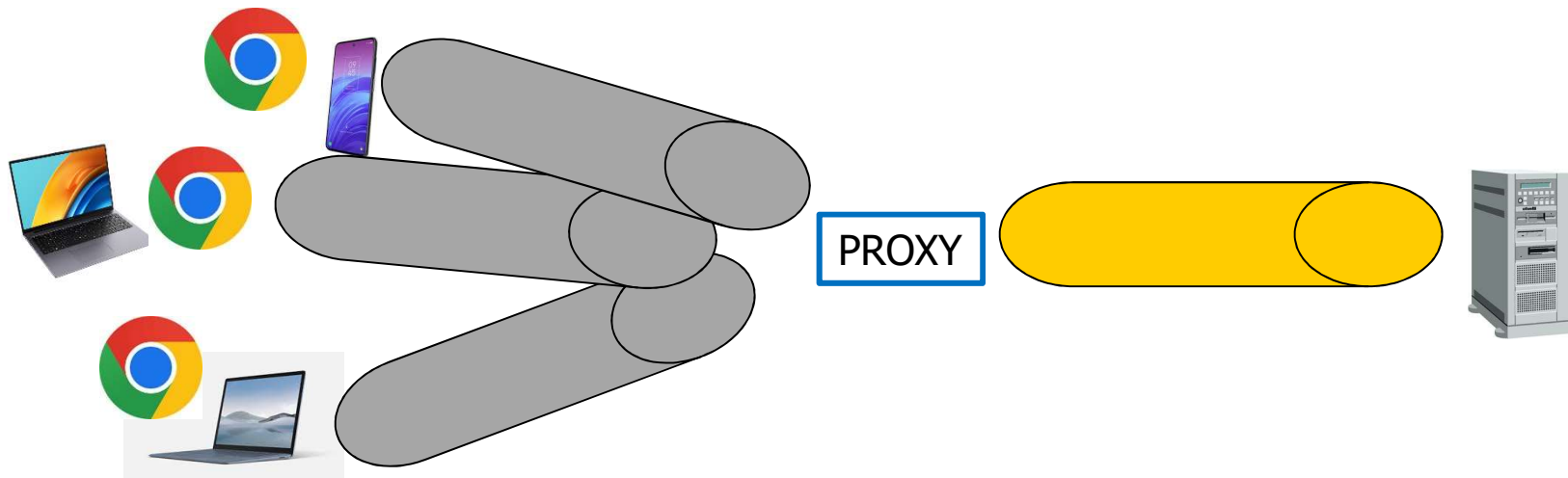


Altro Tentativo

- Web server "aggancia" tutte le HTTP request che provengono dallo stesso indirizzo IP



Non funziona



- ❑ Una connessione TCP trasporta un numero non predicibile di coppie request-response
- ❑ ...e potrebbero essere di **browser diversi**

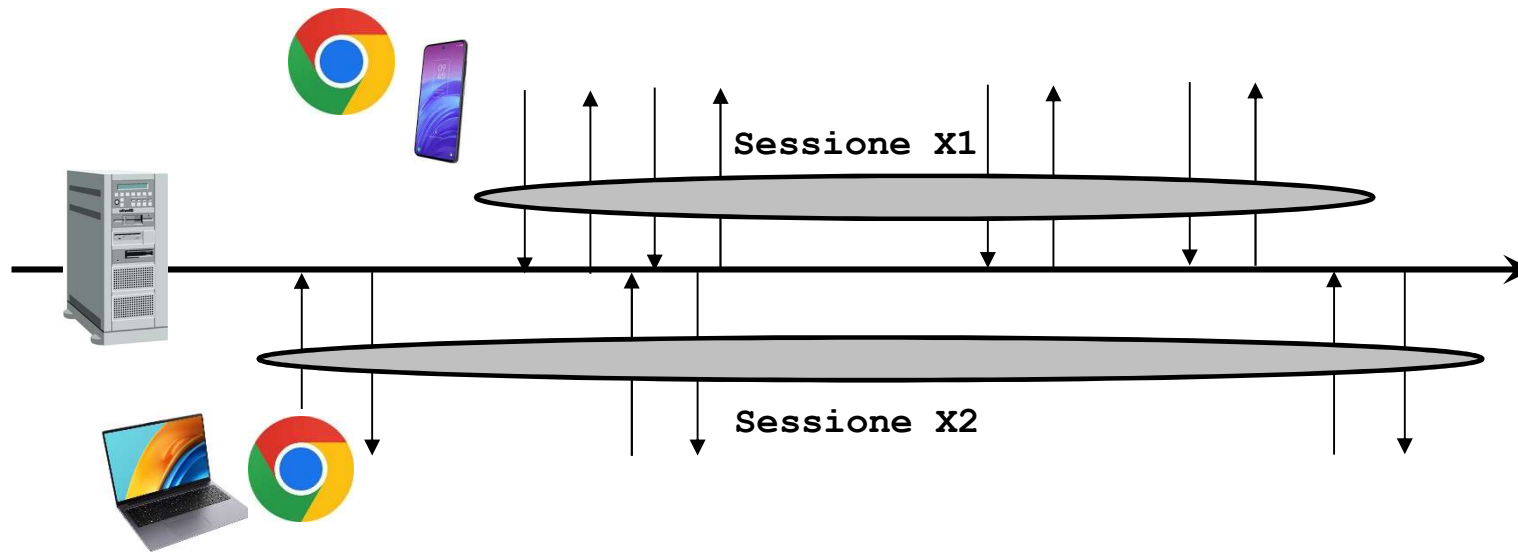


Sessione HTTP



Sessione: Definizione

- ❑ Sequenza di Request e Response scambiate da una coppia < **Browser@Device**, WebSite >
- ❑ Ogni sessione ha **identificatore** univoco sul WebSite

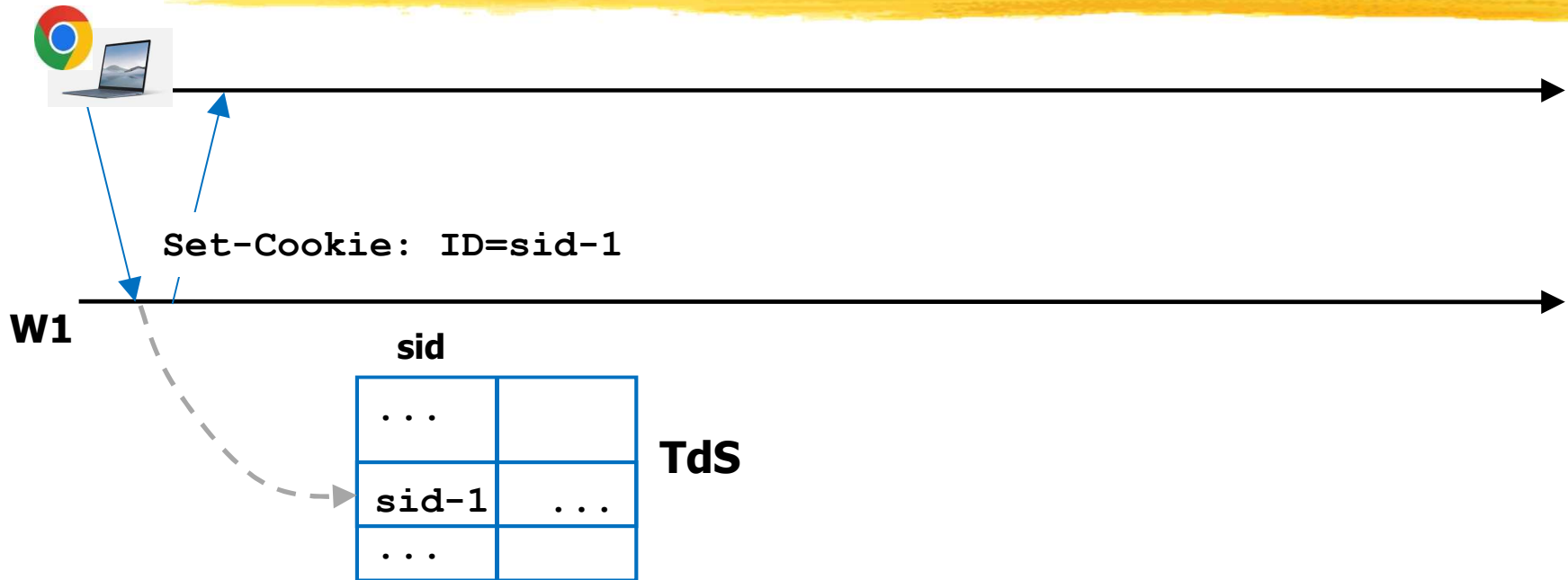


Sessione:

Implementazione (Cookie)

- ❑ HTTP Request R appartiene a sessione *sid* con web server W
⇔
- ❑ R contiene header `Cookie: name=sid`
 - ❑ *name* dipende dalla configurazione di W
 - ❑ *sid* **identificatore di sessione** scelto da W
(**univoco** su W)
- ❑ Esempio: Web server W1 usa la forma `ID=...`
 - ❑ Browser B1: `ID=5d20b8af7cb`
 - ❑ Browser B2: `ID=aba055465f2`
- ❑ Esempio: Web server W2 usa la forma `JSESSION=...`
 - ❑ Browser B1: `JSESSION=5667bccdr5kk9`
 - ❑ Browser B2: `JSESSION=9982afe33aab0`

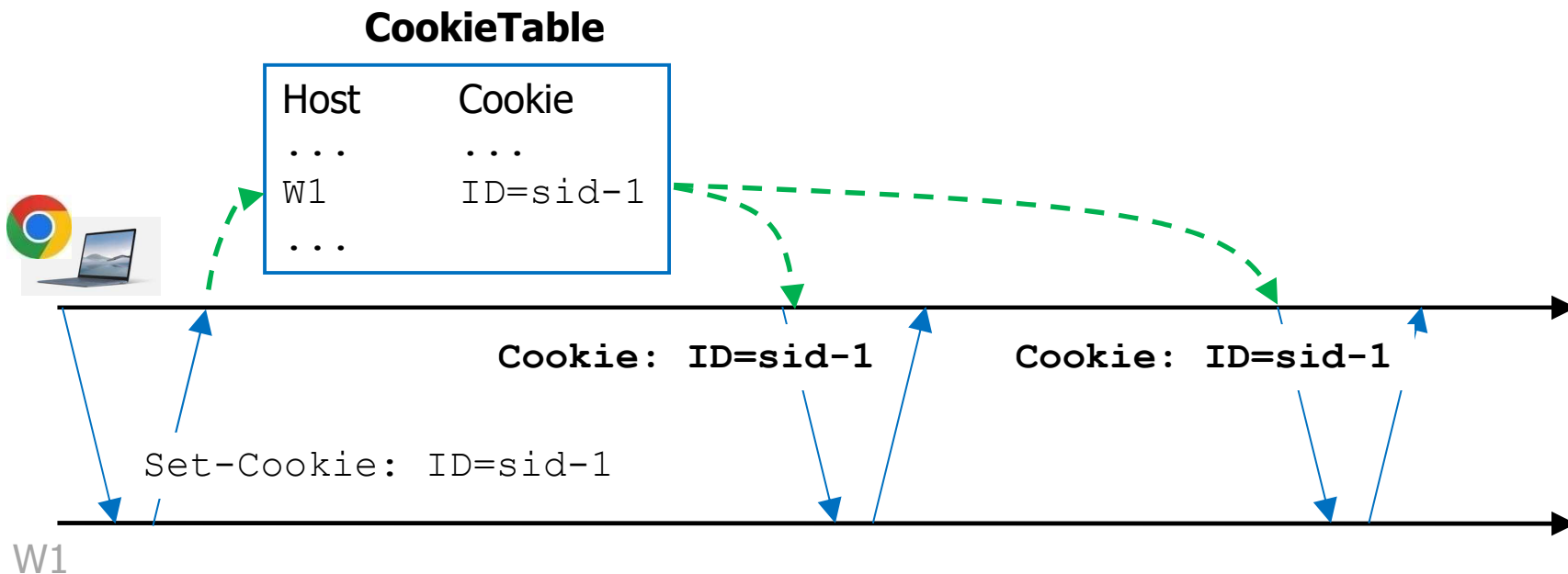
Cookie (I)



- ❑ Riceve HTTP Request che **non** contiene header `Cookie`
 - ❑ Decide di **creare** sessione identificata da `sid-1`
 1. Registra `sid-1` nella propria **Tabella delle Sessioni**
 2. Inserisce un HTTP response header `Set-Cookie`

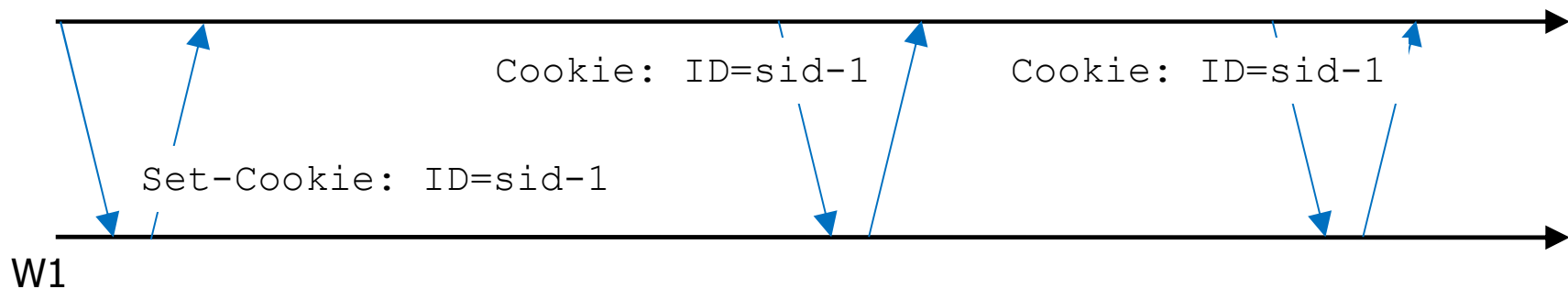
Cookie (II)

- ❑ Riceve HTTP Response con header `Set-Cookie`
 - ❑ Registra "il cookie" nella propria **Tabella dei Cookie**
 - ❑ Inserirà un HTTP Request header `Cookie` in tutte le **richieste future** verso quello stesso `Host`



In parole povere

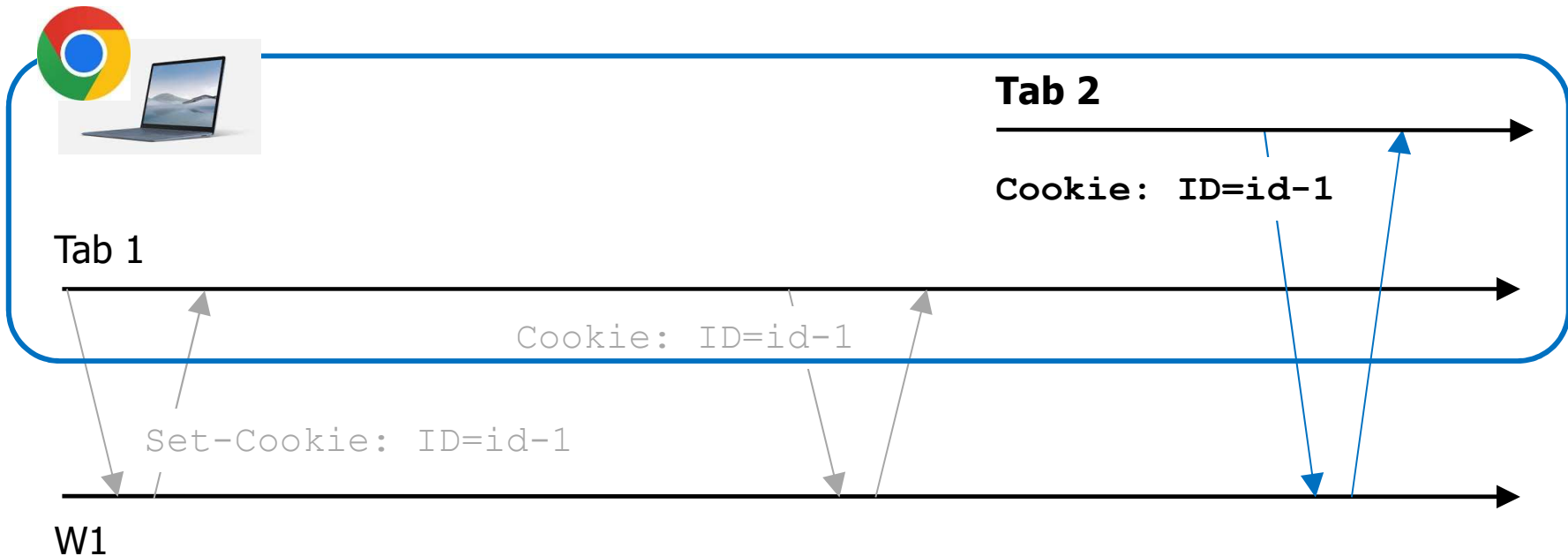
- ❑ **Web Server** sceglie un identificatore **univoco** per il Browser (e glielo comunica)
- ❑ **Browser** si impegna ad identificarsi in quel modo



Cookie Table (I)

1. Condivisa tra tutti i tab

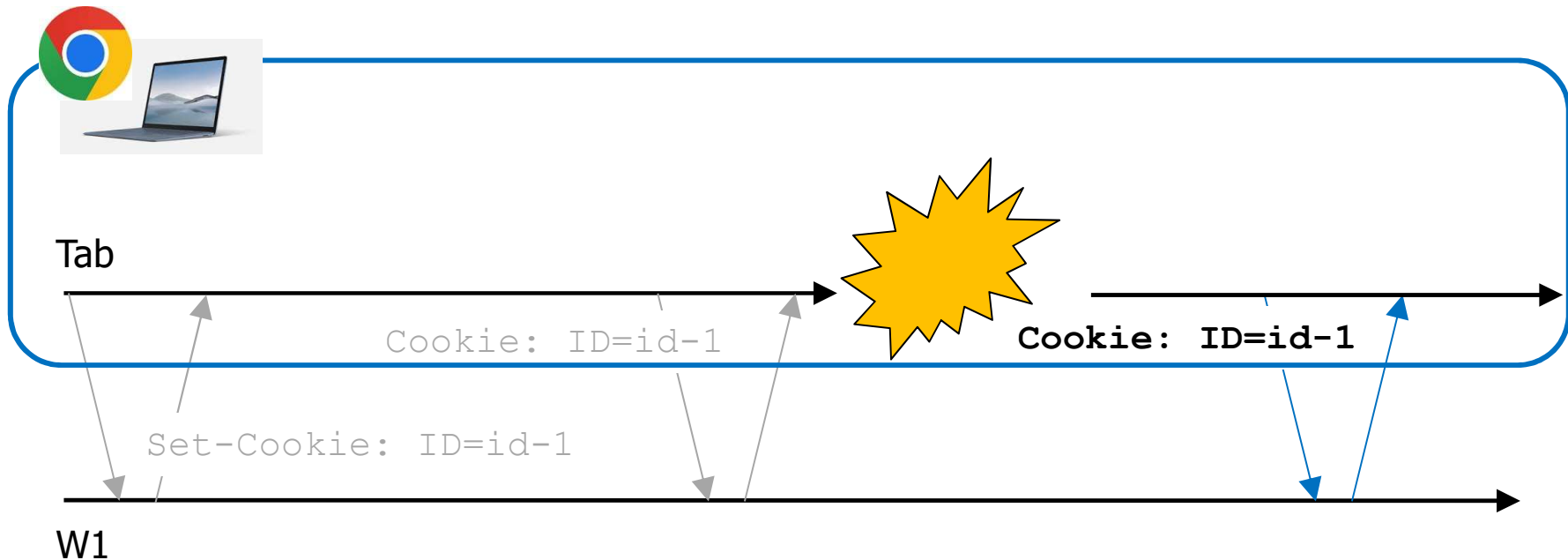
Host	Cookie
...	...
W1	ID=id-1
...	...



Cookie Table (II)

2. **Persistente** (sopravvive chiusura browser / shutdown)

Host	Cookie
...	...
W1	ID=id-1
...	...



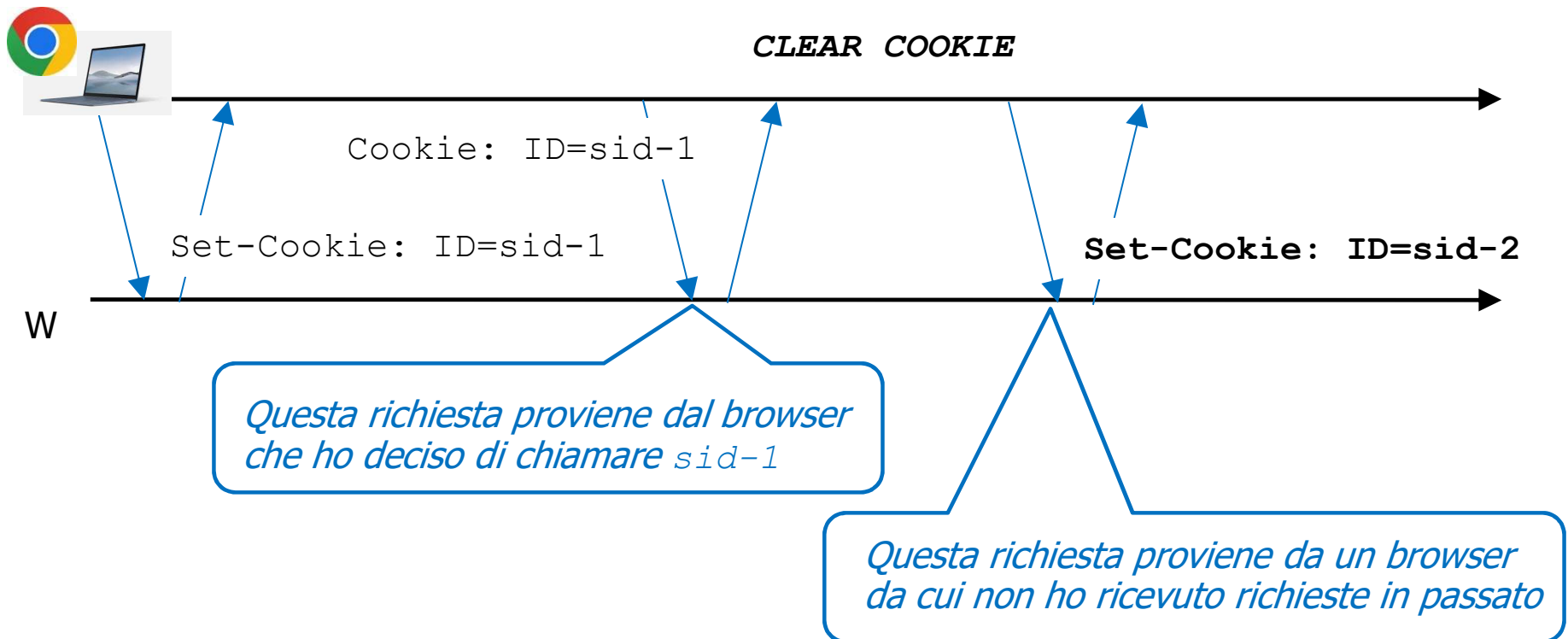
CookieTable (III)



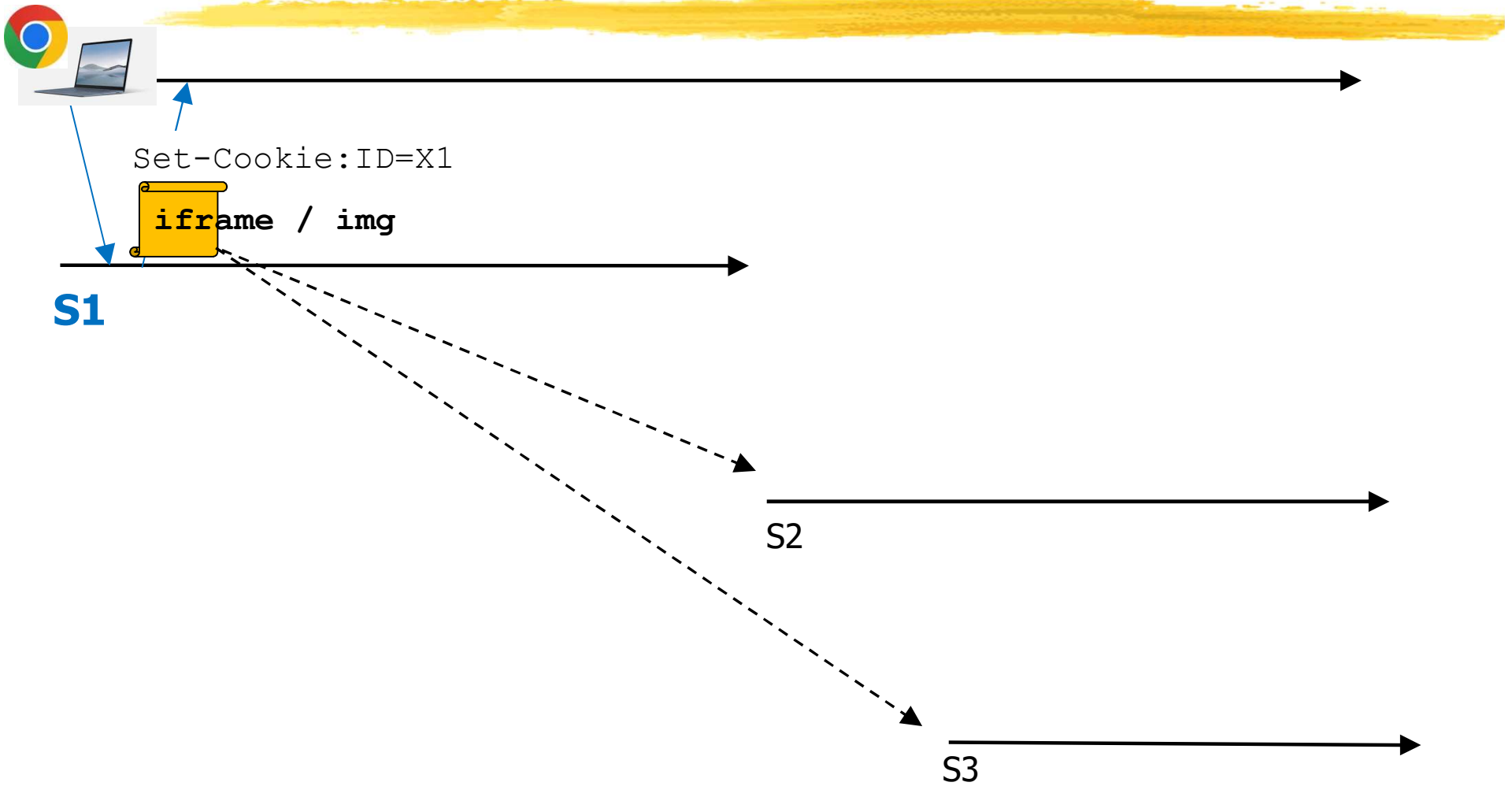
- ❑ **Sequenza** finita di Request e Response scambiate da una coppia < Browser@Device, WebSite >
- ❑ Ogni sessione ha **identificatore** univoco sul WebSite
- ❑ CookieTable **non** condivisa tra Browser **diversi**
- ❑ Esempio:
 - ❑ Safari / Chrome / Firefox / Internet Explorer su stesso device, collegati a stesso web site
 - ❑ Una sessione separata per ogni browser

CookieTable (IV)

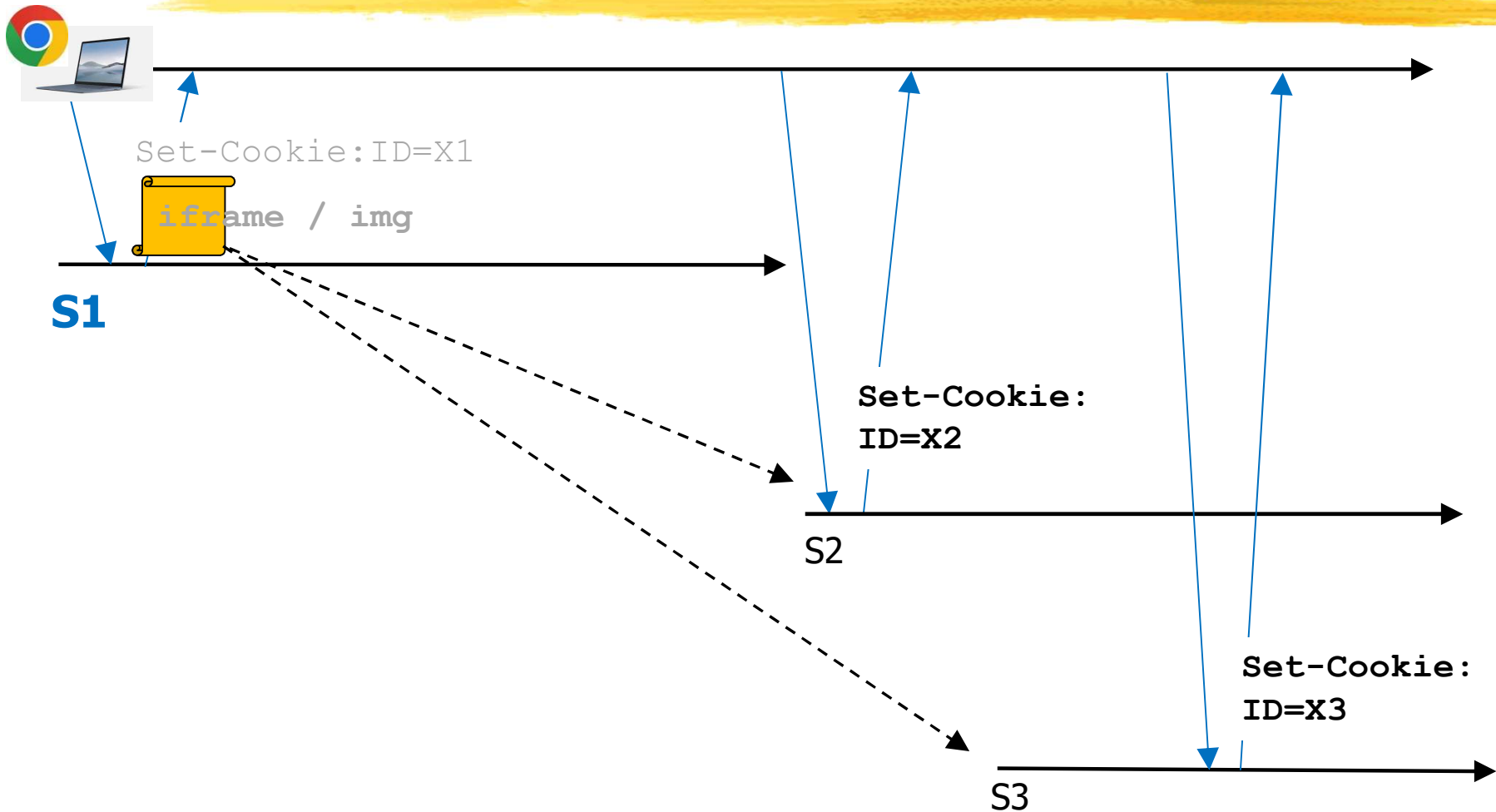
- Browser@Device **cancella** cookie per W
 - Da quel momento, W lo considera un Browser@Device **diverso**



Cookie?



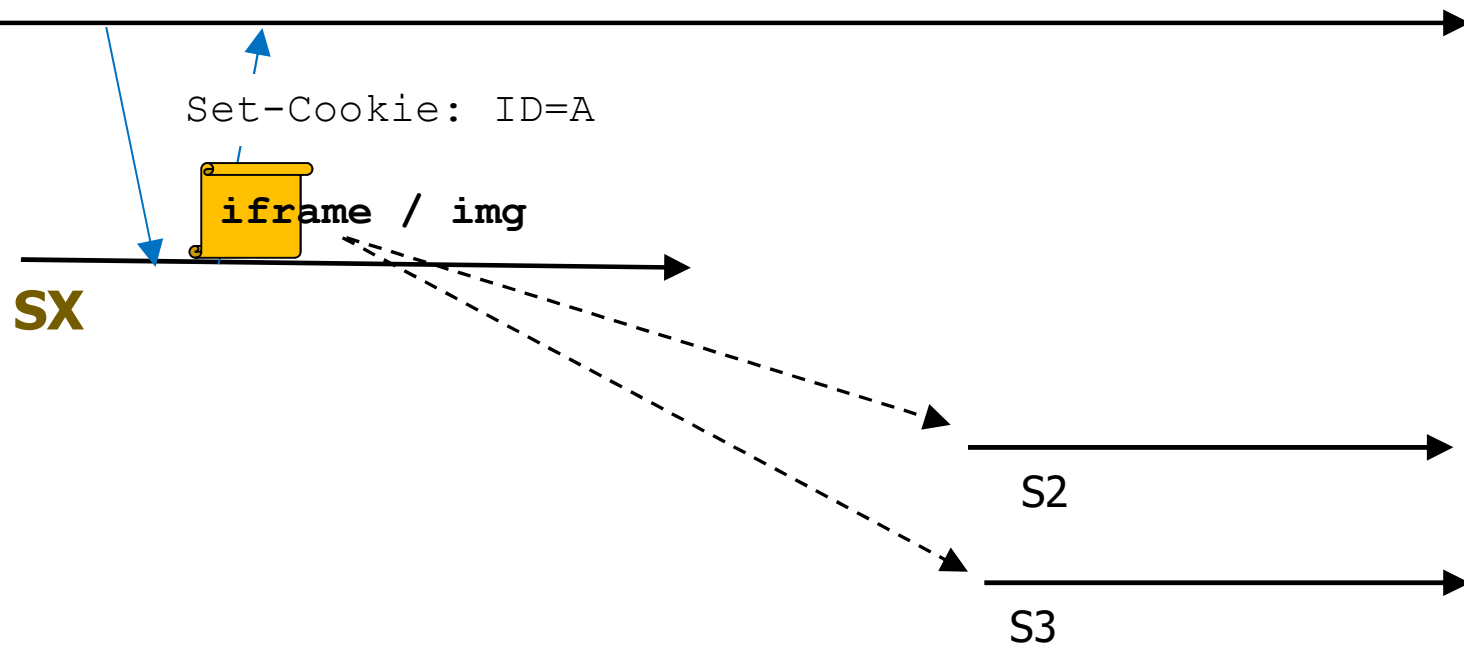
Ogni server ha i propri



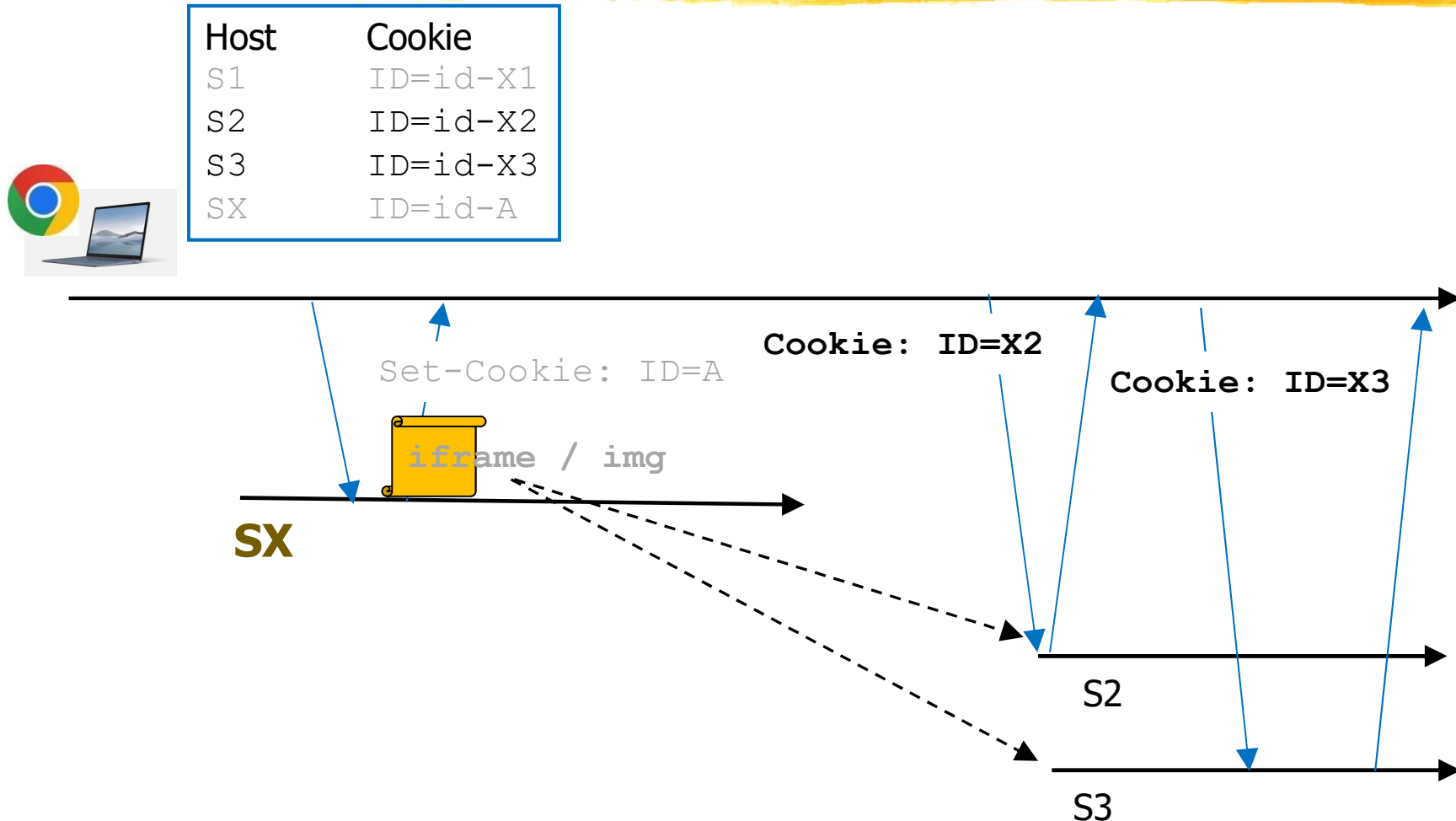
Cookie?



Host	Cookie
S1	ID=id-X1
S2	ID=id-X2
S3	ID=id-X3
SX	ID=id-A



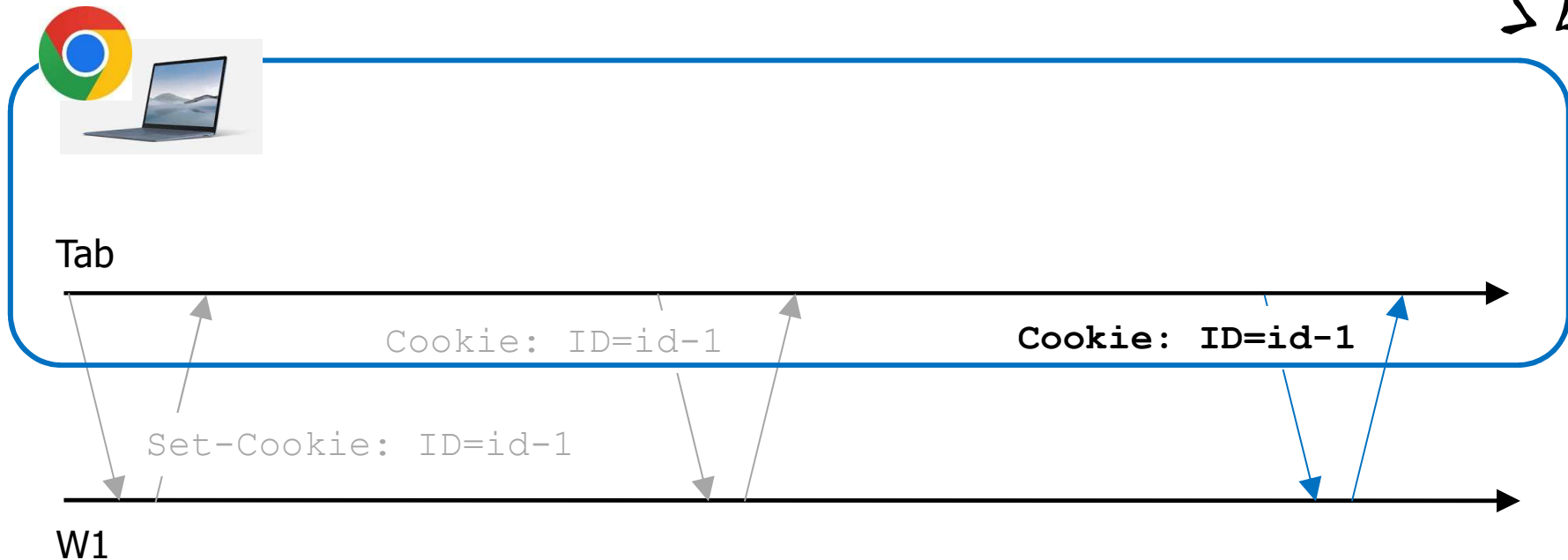
Non dipendono da dove arrivo



Durata infinita?

Host	Cookie
...	...
W1	ID=id-1
...	...

*Una volta inserito
in CookieTable ci rimane
per sempre?*



Cookie Lifetime

Set-Cookie: *name=sid*; **Expires=date**

- ❑ SE presente attributo **Expires**
- ❑ ALLORA deve esistere fino a *date* (settimane o mesi)
- ❑ ALTRIMENTI deve esistere fino a chiusura del browser

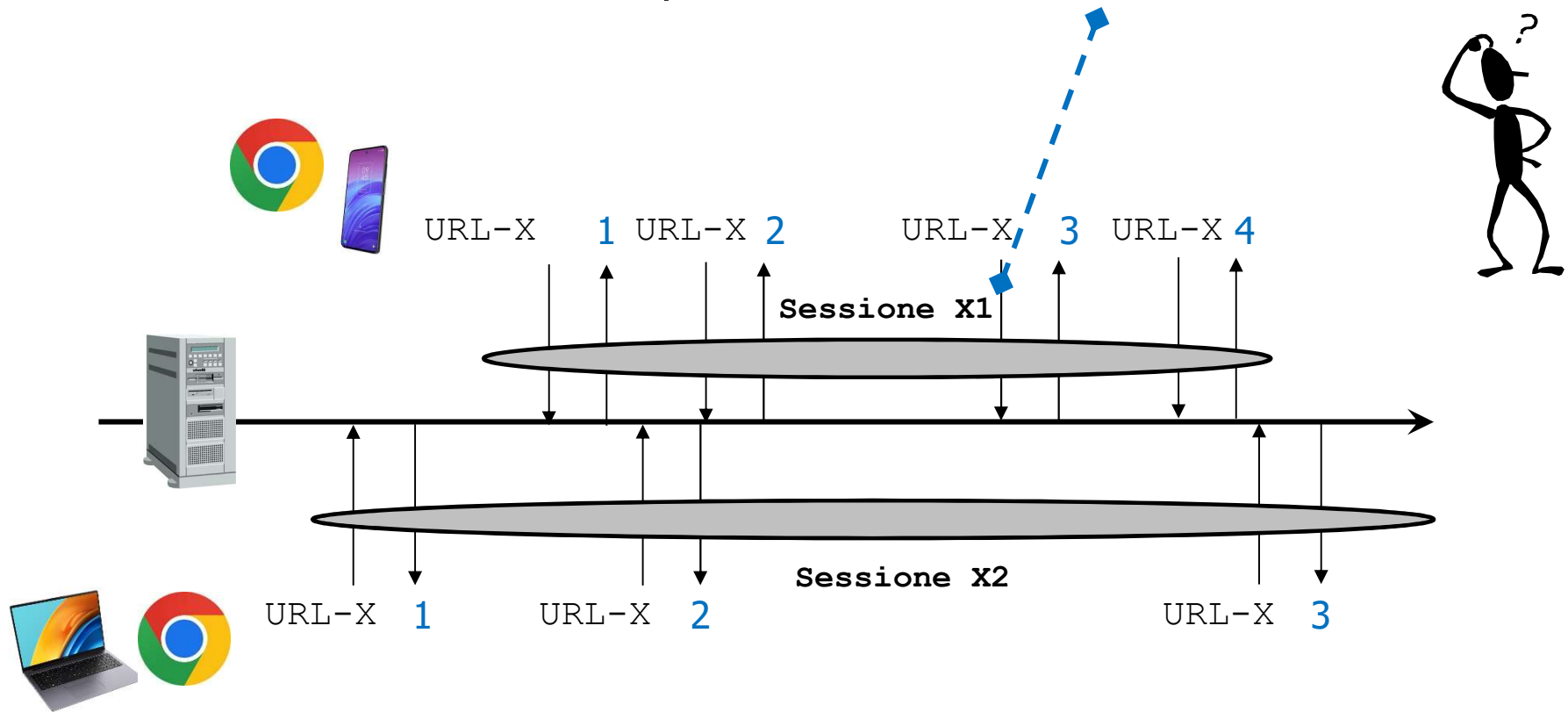
Host	Cookie	ExpirationDate
...	...	...
S1	ID=id-1	none
S2	RMID=xyz	Fri, 31-Dec-2021 23:59:59 GMT
...	...	...

Stato delle Sessioni



Ancora non risolto...

*Questa richiesta appartiene alla sessione X1
...ma quale numero devo tornare???*



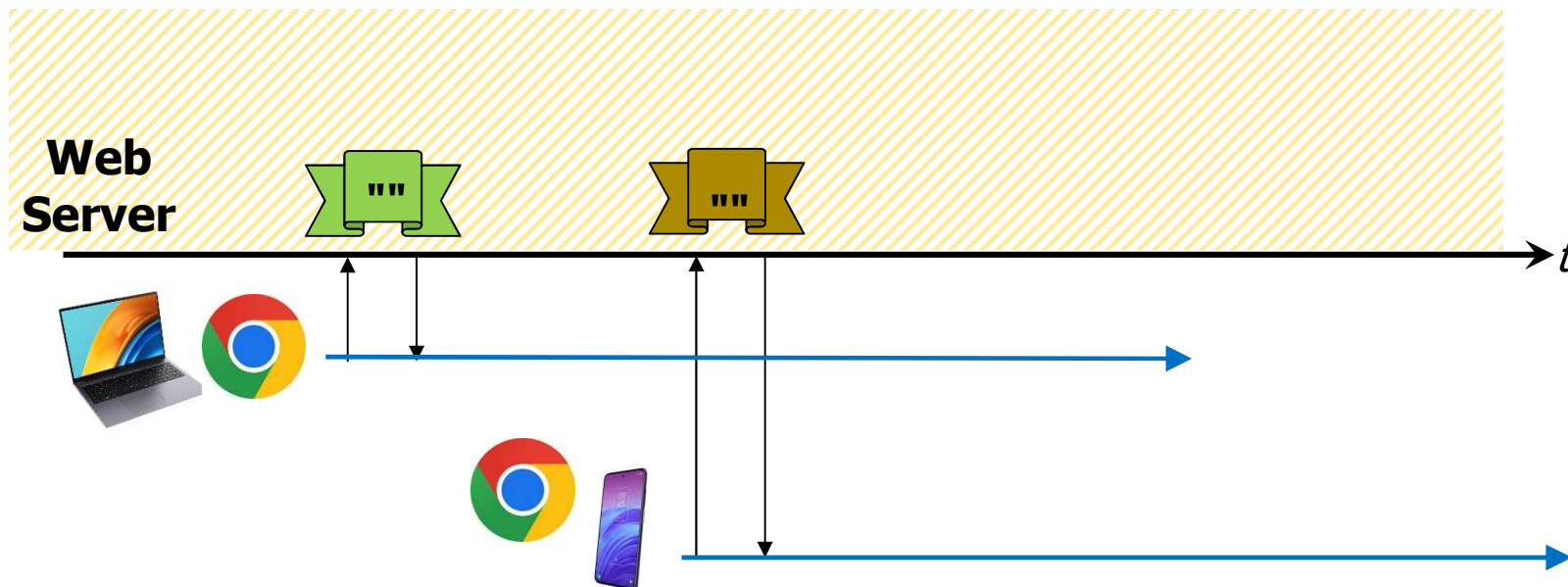
Nostro approccio



1. Descrizione **intermedia** molto semplificata e non reale
(variabile di sessione)
2. Descrizione "reale"
(stato della sessione)

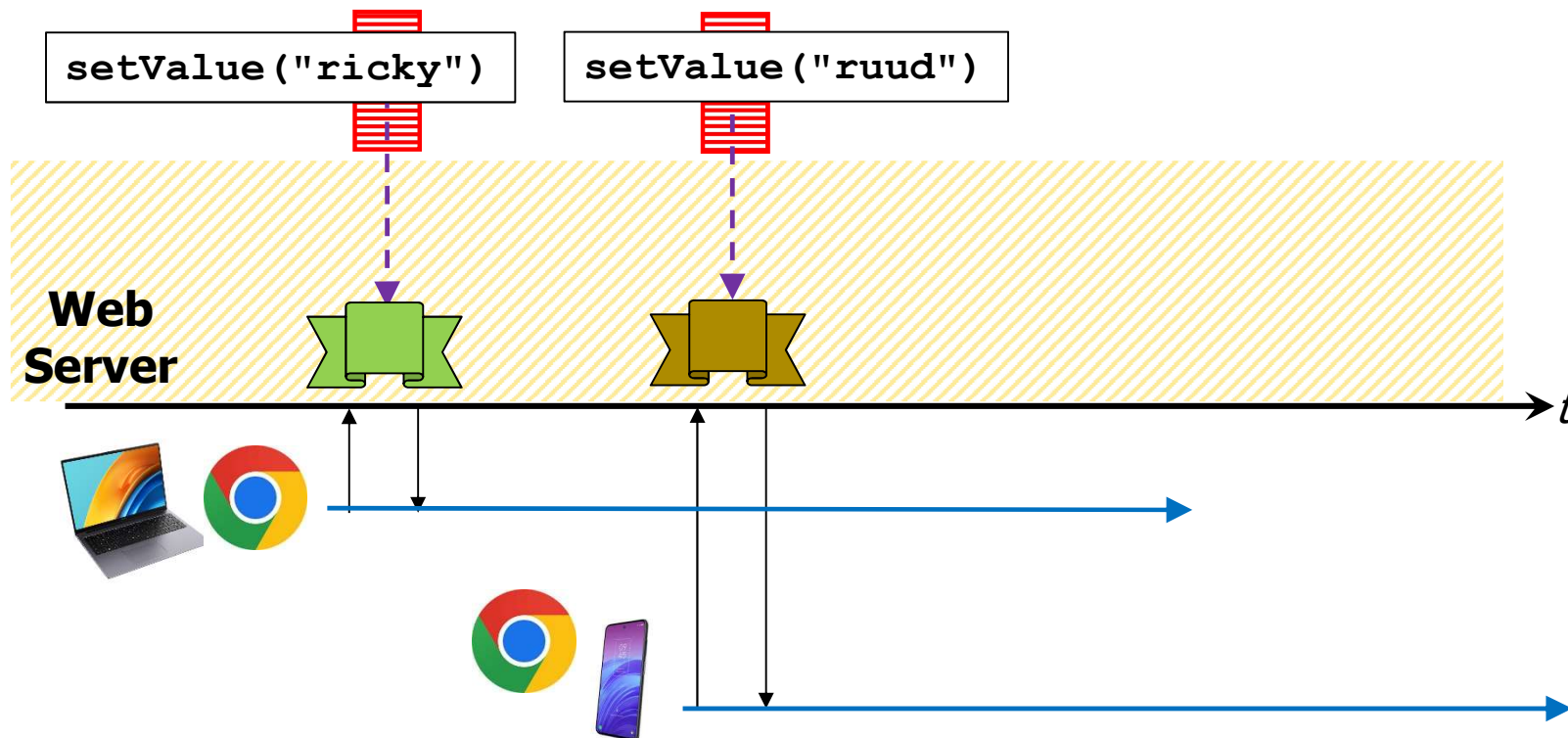
Variabile di Sessione (I)

- ❑ Web Server mantiene **una variabile** per ogni sessione
 - ❑ **Valore** di tipo **String** (inizialmente vuoto)
 - ❑ ...



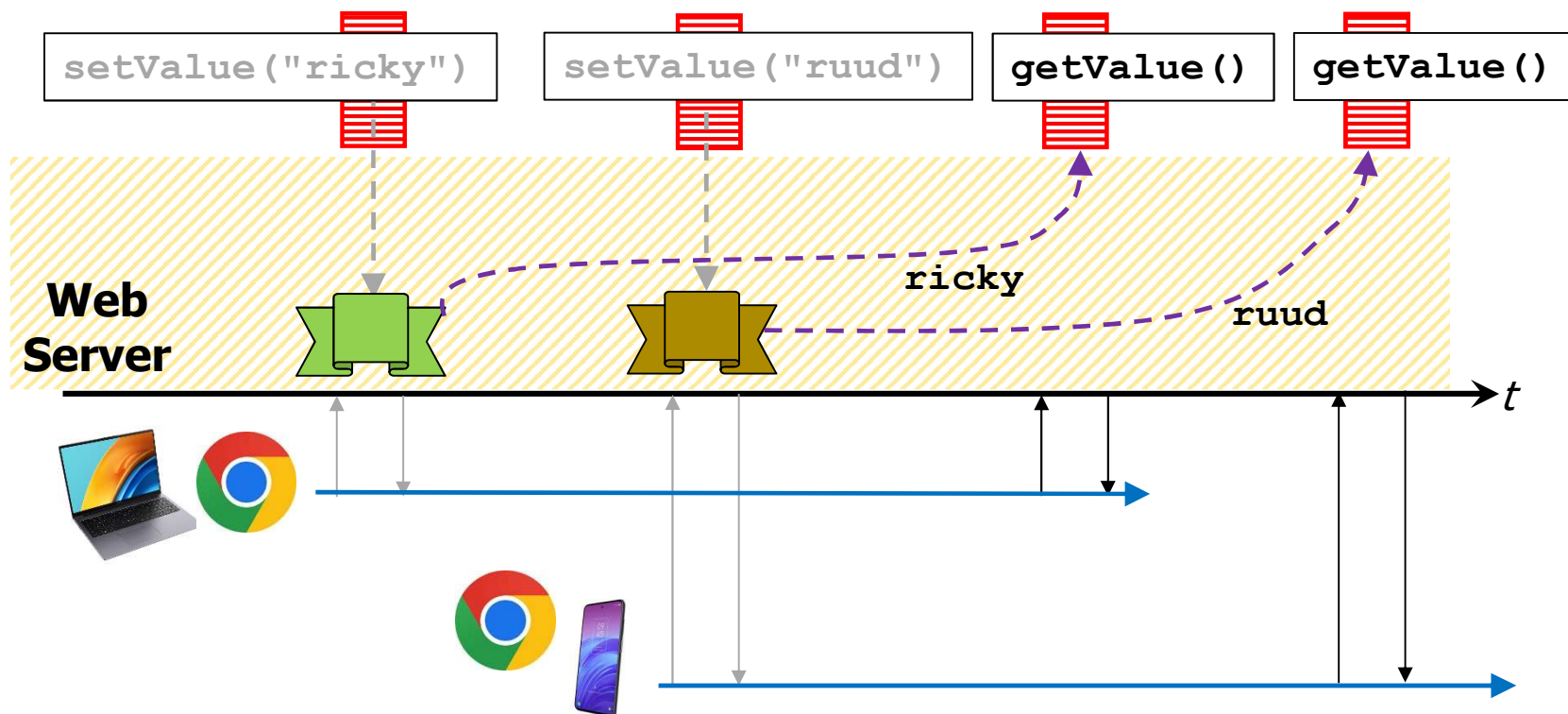
Variabile di Sessione (II)

- ❑ Web Server mantiene **una variabile** per ogni sessione
 - ❑ Accessibile al codice che genera documenti dinamici (dettagli dipendenti da linguaggio / web server)



Variabile di Sessione (III)

- Web Server mantiene **una variabile** per ogni sessione
- Esiste** per tutta la durata della sessione



Risolto! (idea di base) (I-a)



```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```

*Manca il check
"se vuota allora carattere 0"*



Risolto! (idea di base) (I-b)

```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```

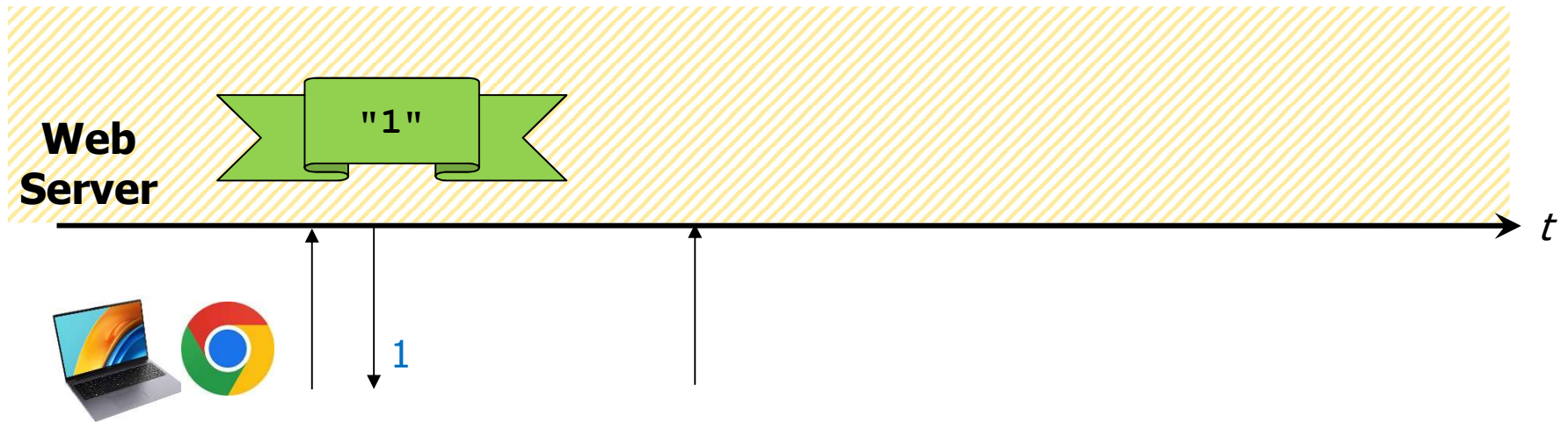
*Manca il check
"se vuota allora carattere 0"*



Risolto! (idea di base) (II-a)

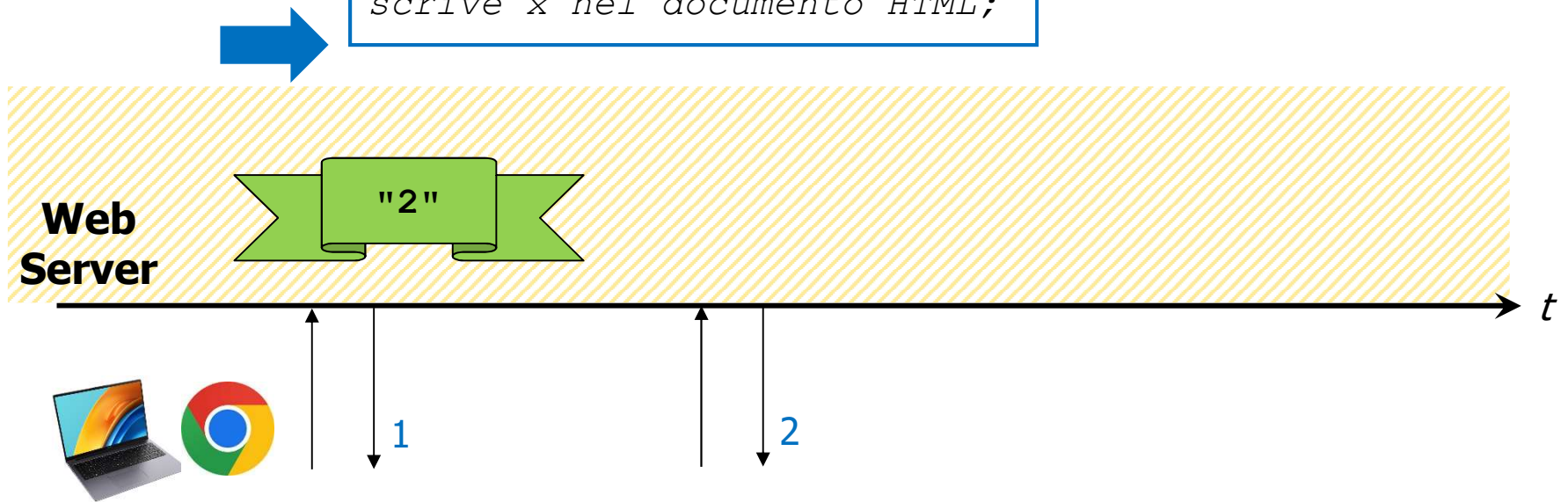


```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```



Risolto! (idea di base) (II-b)

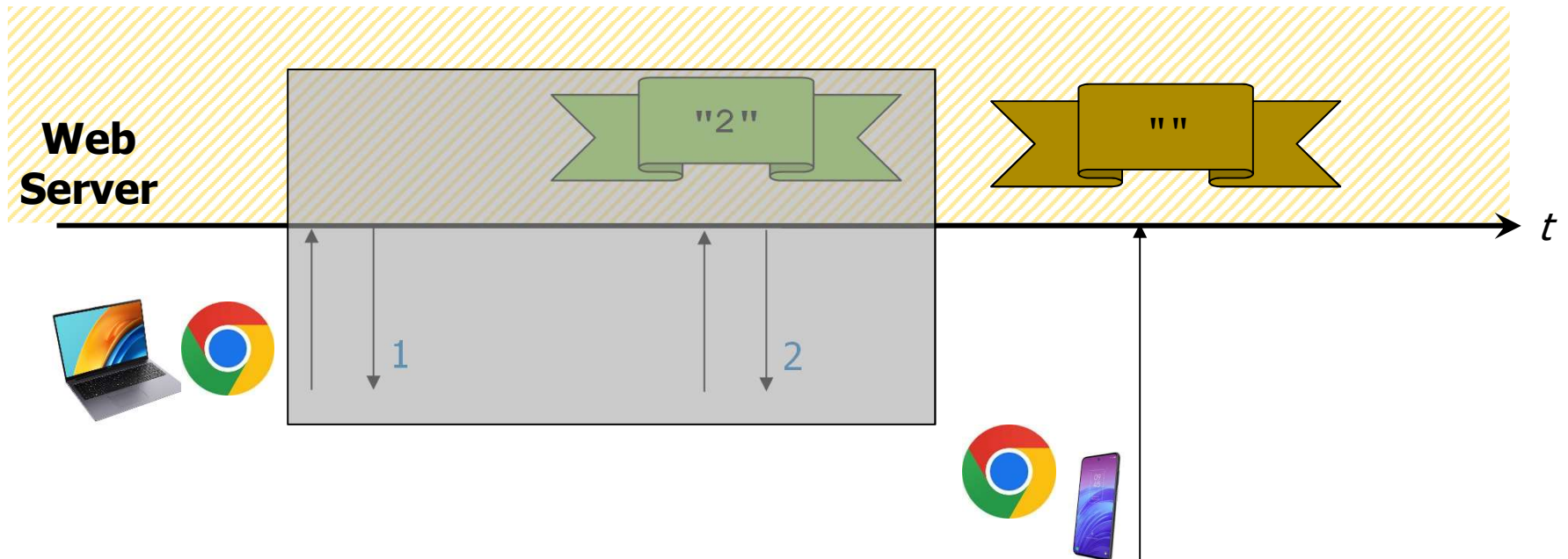
```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```



Risolto! (idea di base) (III-a)

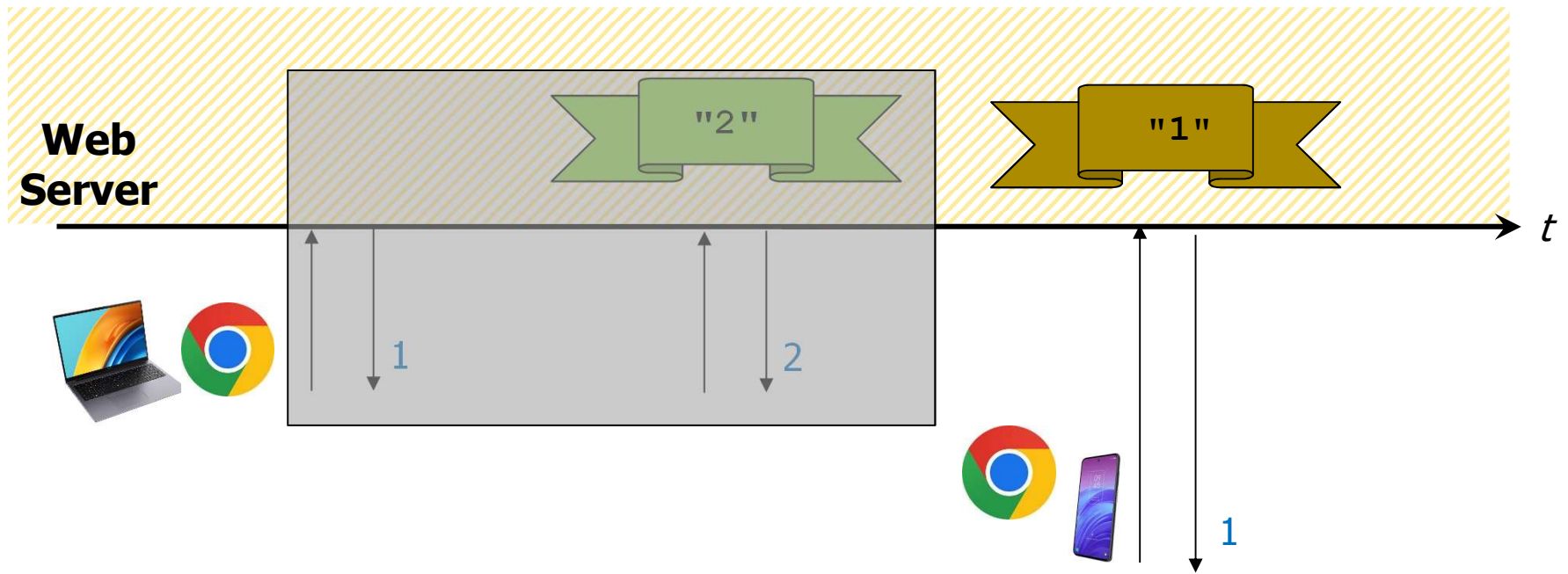


```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```



Risolto! (idea di base) (III-b)

```
x := getValue();  
y := StringToInt(x);  
y := y+1;  
setValue(IntToString(y));  
scrive x nel documento HTML;
```



Ecco come ci riesce...

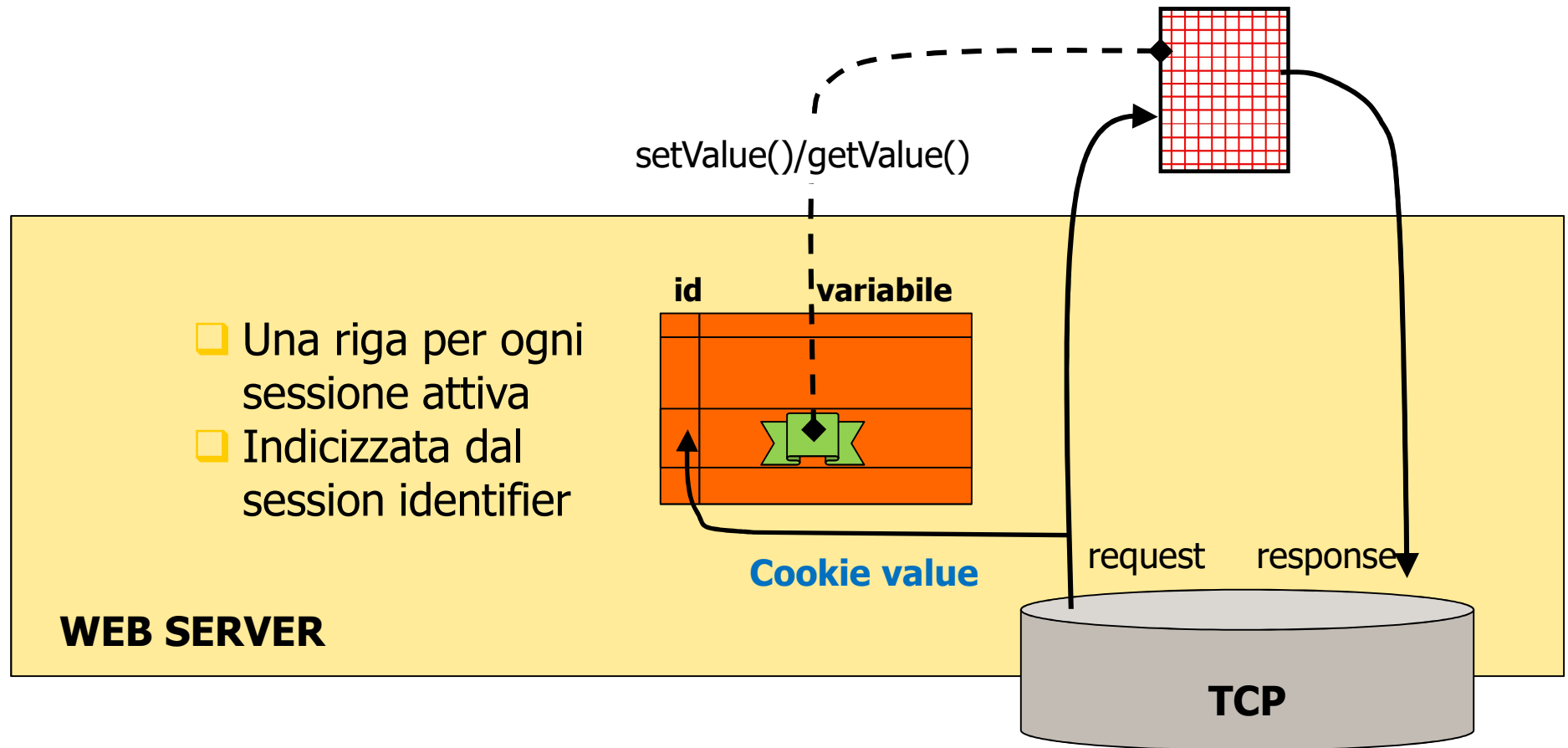
document è **costruito** da un **programma**:

1. Input è HTTP request e
HTTP request **precedente** dello **stesso** browser@device
2. Esegue una qualche elaborazione
 - ❑ Caso particolare: query su database
3. Output è HTTP response

❑ ~~Non~~ sappiamo (ancora) come realizzarla



Tabella delle Sessioni



Osservazione (I)



- ❑ **Variabile di sessione**
- ❑ Web Server
 - ❑ Fornisce lo **spazio di memoria** e **l'interfaccia di accesso**
 - ❑ Non vi associa **nessun significato**
- ❑ Webapp (codice che genera contenuto dinamico)
 - ❑ Accede con l'interfaccia del Web Server
 - ❑ Le associa il significato che vuole

Osservazione (II)

☐ Variabile di sessione

☐ Web Server

- ☐ Fornisce lo spazio di memoria e l'interfaccia di accesso
- ☐ Non vi associa nessun significato

☐ Webapp (codice che genera contenuto dinamico)

- ☐ Accede con l'interfaccia del Web Server
- ☐ Le associa il significato che vuole

☐ HTTP

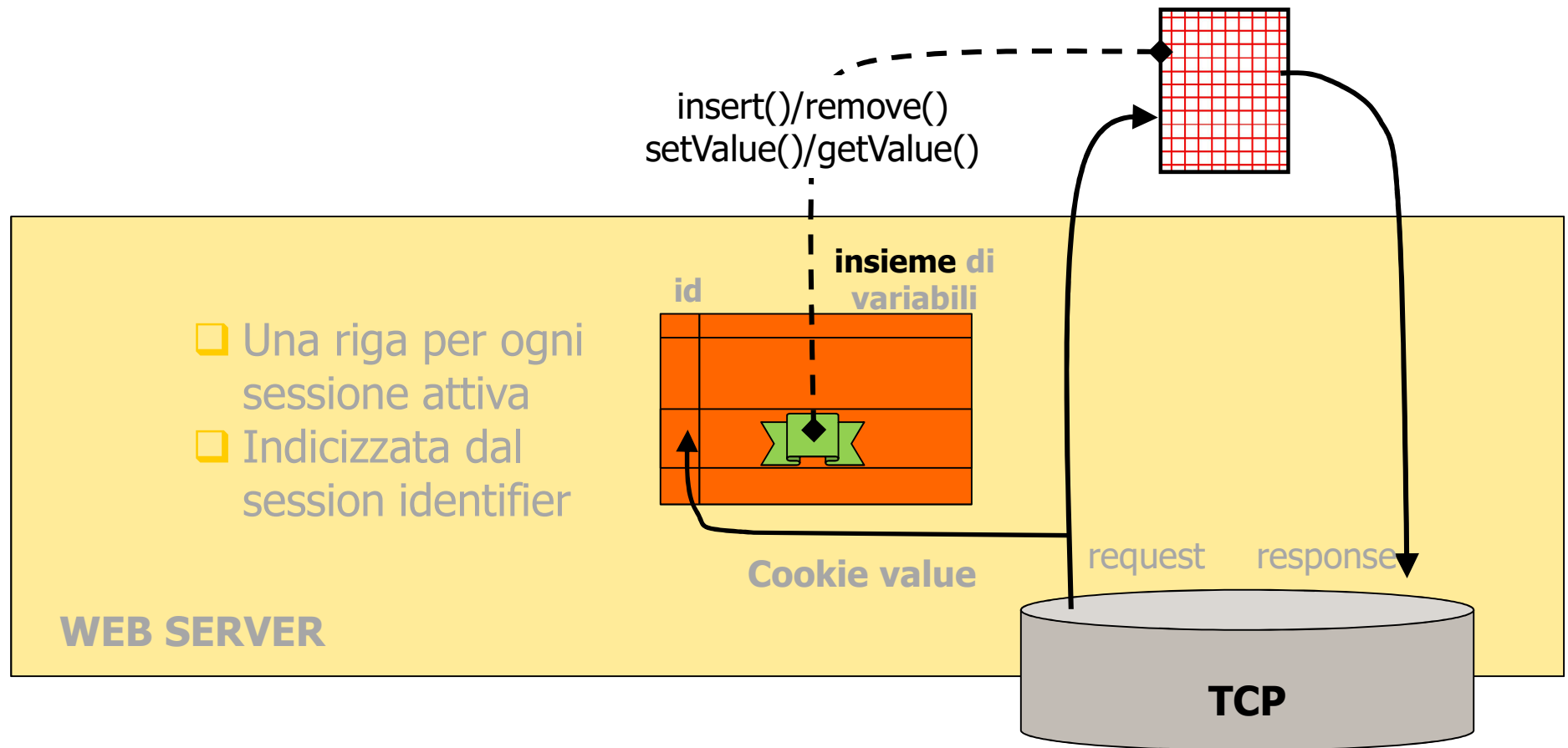
- ☐ Definisce **solo** gli header `Cookie` per Request→Session Identifier
- ☐ Variabili di sessione **irrilevanti** (sconosciute)

Realtà:

Session STATE (I)

- ❑ Session state: **INSIEME** di variabili di sessione (inizialmente vuoto)
- ❑ Ognuna ha un **nome** ed è di tipo String
- ❑ Creazione / Distruzione variabili
 - `Insert-Session("authenticated", "false")`
 - `Insert-Session("username", "")`
 - `Remove-Session("authenticated")`
- ❑ Lettura / Scrittura variabile
 - `SetValue-Session("authenticated", "true")`
 - `SetValue-Session("username", "bartoli.alberto")`
 - `GetValue-Session("username")`

Tabella delle Sessioni: In realtà



Authentication



Premessa



- ❑ **Tutti** gli esempi seguenti assumono **esistenza sessione**

- ❑ Se HTTP Request non contiene `Cookie`:
- ❑ Allora Server crea sessione
HTTP Response contiene `Set-Cookie`:

- ❑ Non li scriviamo per semplicità
- ❑ Assumiamo implicitamente che ci sono
- ❑ Negli esami **devono** essere inseriti

- ❑ Autenticazione:
 - ❑ In teoria si potrebbe fare senza sessioni
 - ❑ In pratica si fa sempre con sessioni

Definizioni (informali e semplificate) (I)

- Subject

- Utente di un sistema informatico (esterno al calcolatore)

- Username

- Stringa (interna al calcolatore)

- Identifica un utente di un sistema informatico

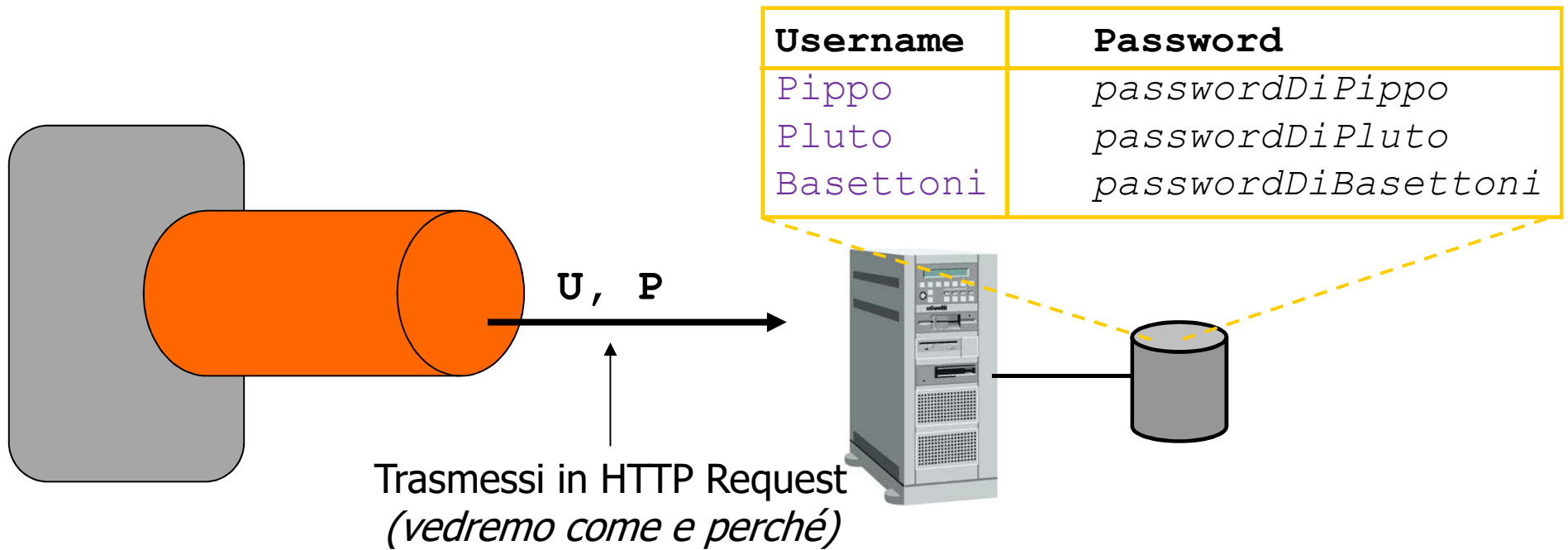
- Subject utilizza Username:

- Deve **dimostrare** al sistema essere associato a quello Username (possesso delle **credenziali**)

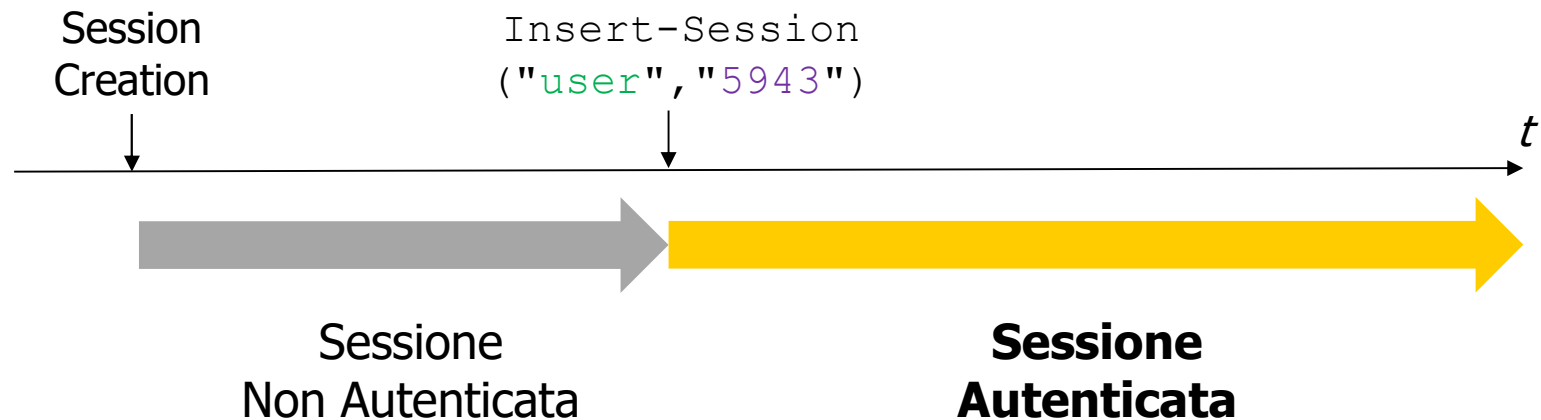
- Conoscenza password

- Conoscenza password + Possesso numero telefonico

Tabella delle Credenziali

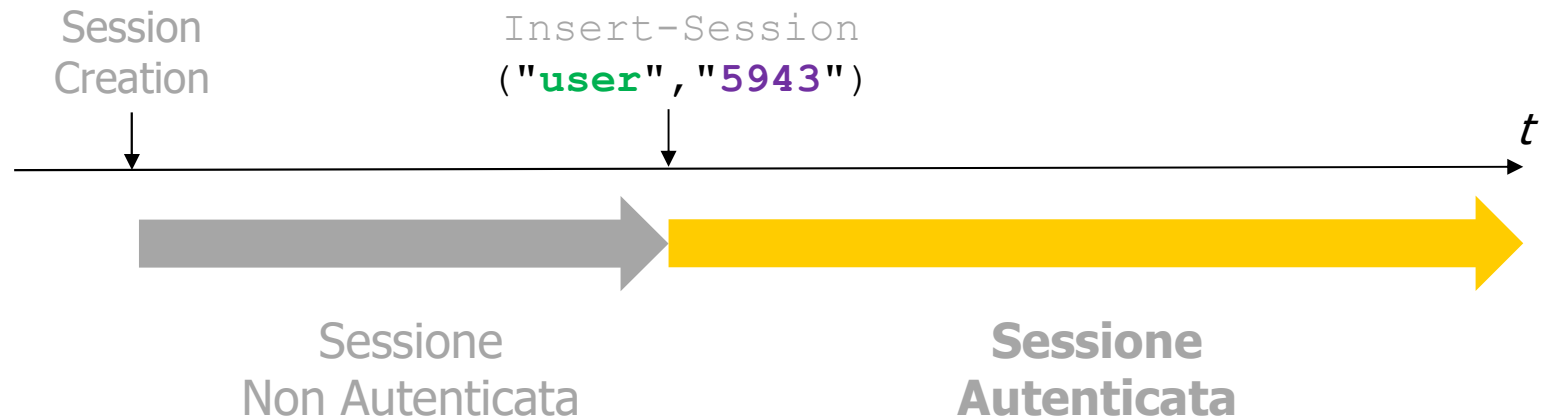


Definizioni (informali e semplificate) (II-a)



- ☐ Ogni sessione è inizialmente non autenticata
- ☐ Può diventare autenticata
- ☐ Web app richiede HTTP Request con credenziali

Definizioni (informali e semplificate) (II-b)



Il **nome della variabile di sessione** ("user")
contenente lo username ("5943")
dipende dalla configurazione del web server

Contenuti protetti (per ora)



❑ Configurazione Web Server:

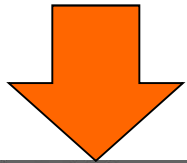
- ❑ Insieme di URL-P che **richiedono autenticazione**
- ❑ Insieme di URL-NP che **non** richiedono autenticazione

1. GET URL-P in sessione non autenticata
2. HTTP Response che "sollecita autenticazione" ("pagina login")
3. ...
4. HTTP Response con documento dinamico **personalizzato**

- ❑ **Molte** possibilità per il traffico HTTP
- ❑ Vediamo le più importanti

"Login stesso URL" (I)

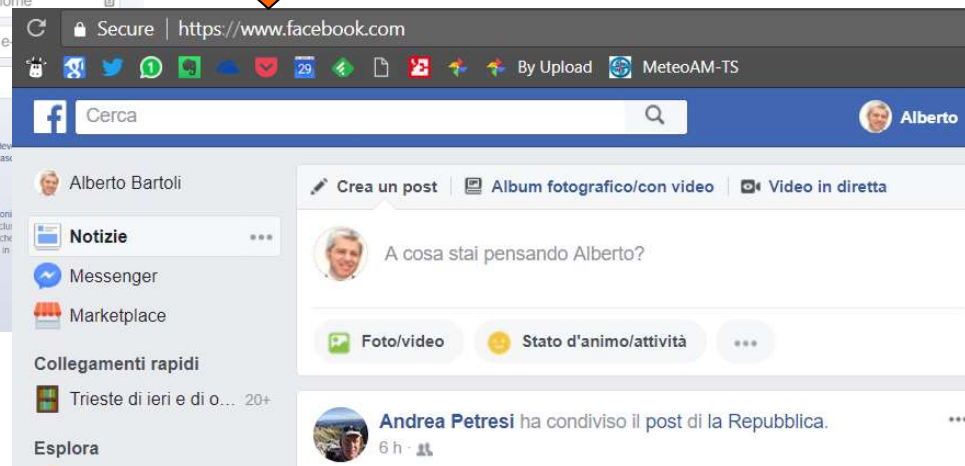
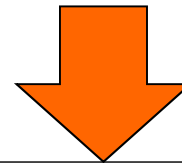
GET URL-P in sessione **non** autenticata



(response-request con credenziali)



Response con doc personalizzato



"Login stesso URL" (II)

1. GET URL-P in sessione non autenticata
2. HTTP Response che "sollecita autenticazione" ("**pagina login**")
3. **POST URL-VALIDATION con credenziali**
4. HTTP Response con documento dinamico **personalizzato**

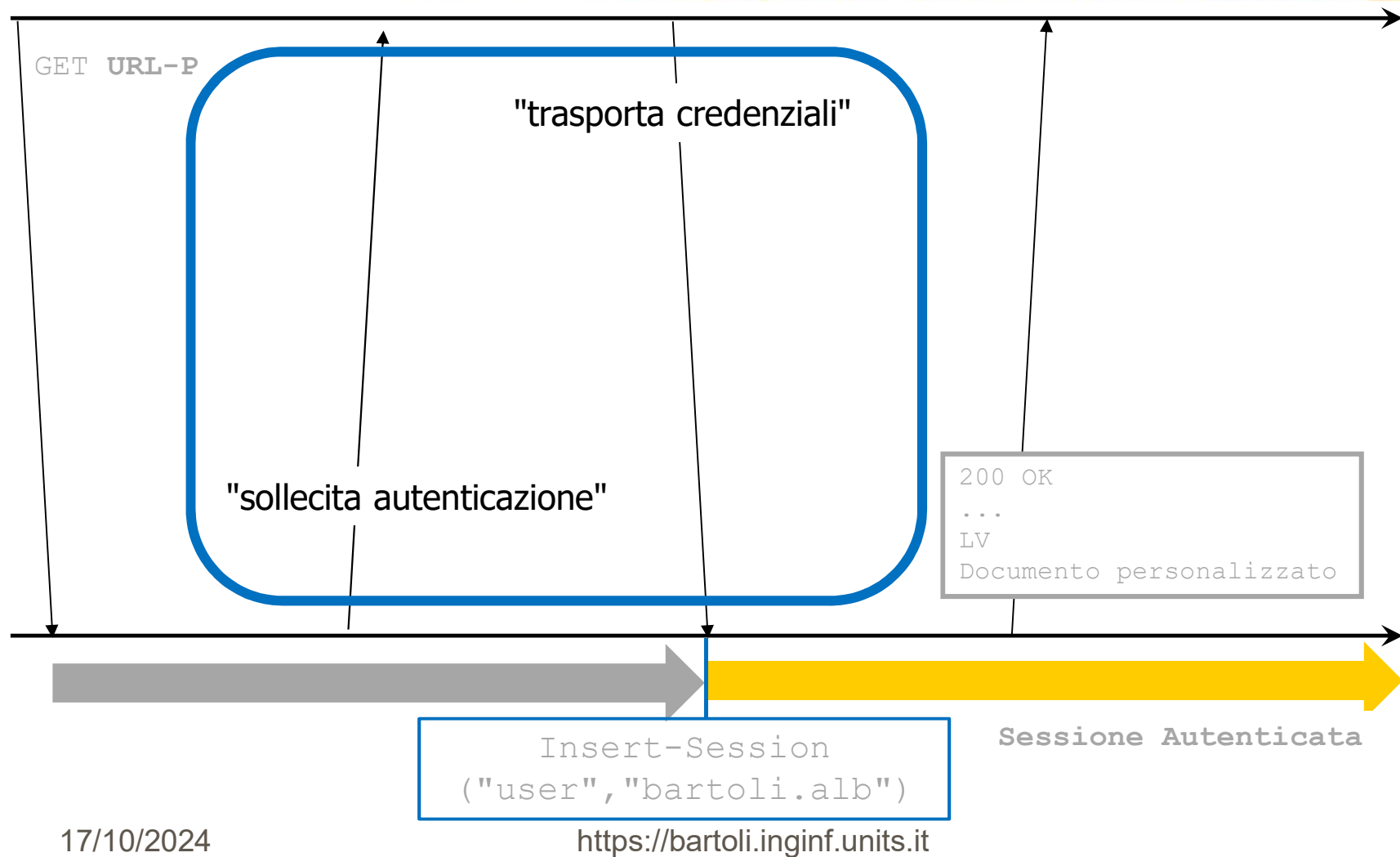
□ Browser mostra URL-P nella address bar

□ Esempi

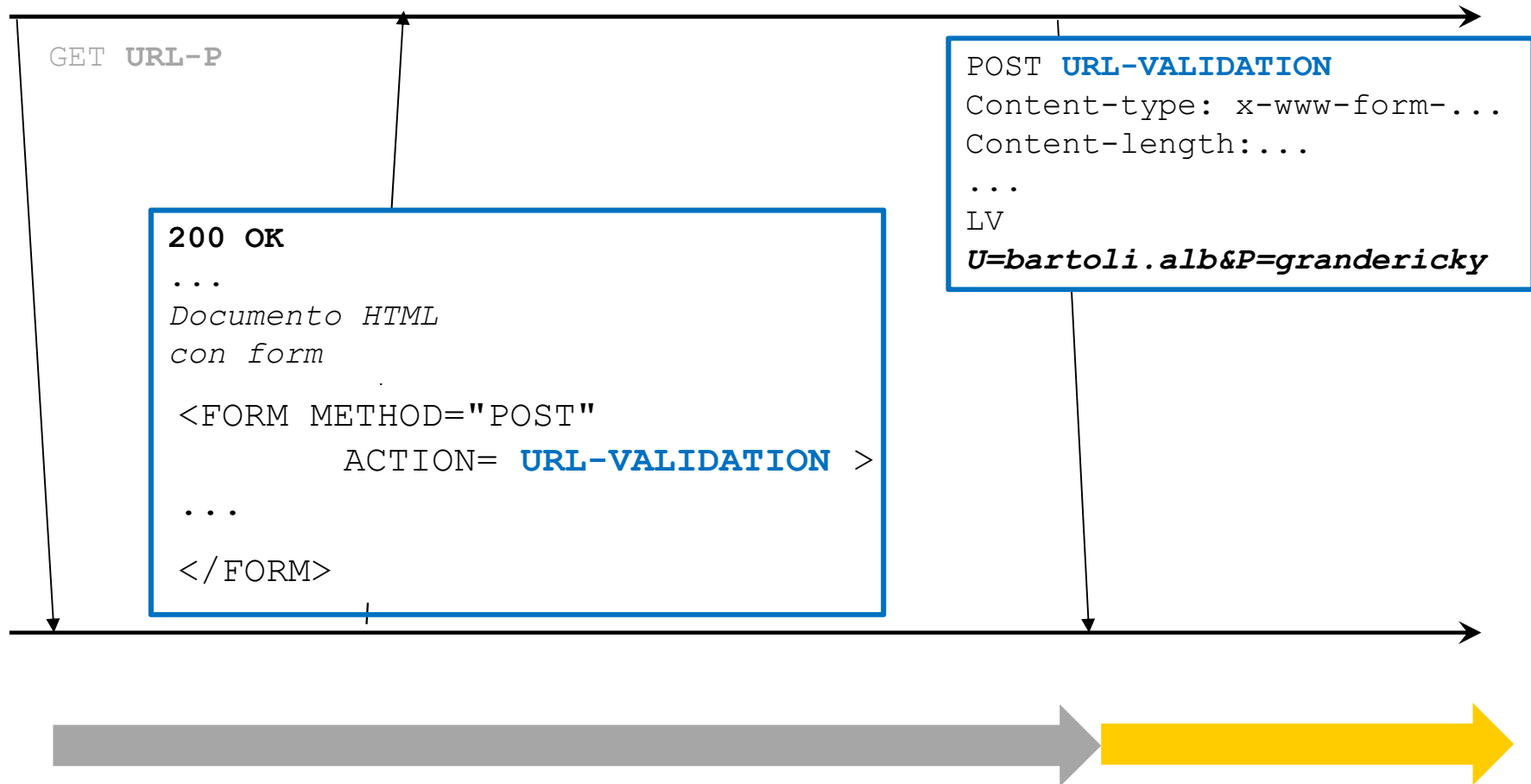
- Vado su `www.facebook.com` e ricevo contenuto generico con FORM per login
- Mi autenticò e vedo **ancora** `www.facebook.com` ma **personalizzato**

- Vado su `amazon.it` e ricevo contenuto generico con FORM per login
- Mi autenticò e vedo **ancora** `amazon.it` ma **personalizzato**

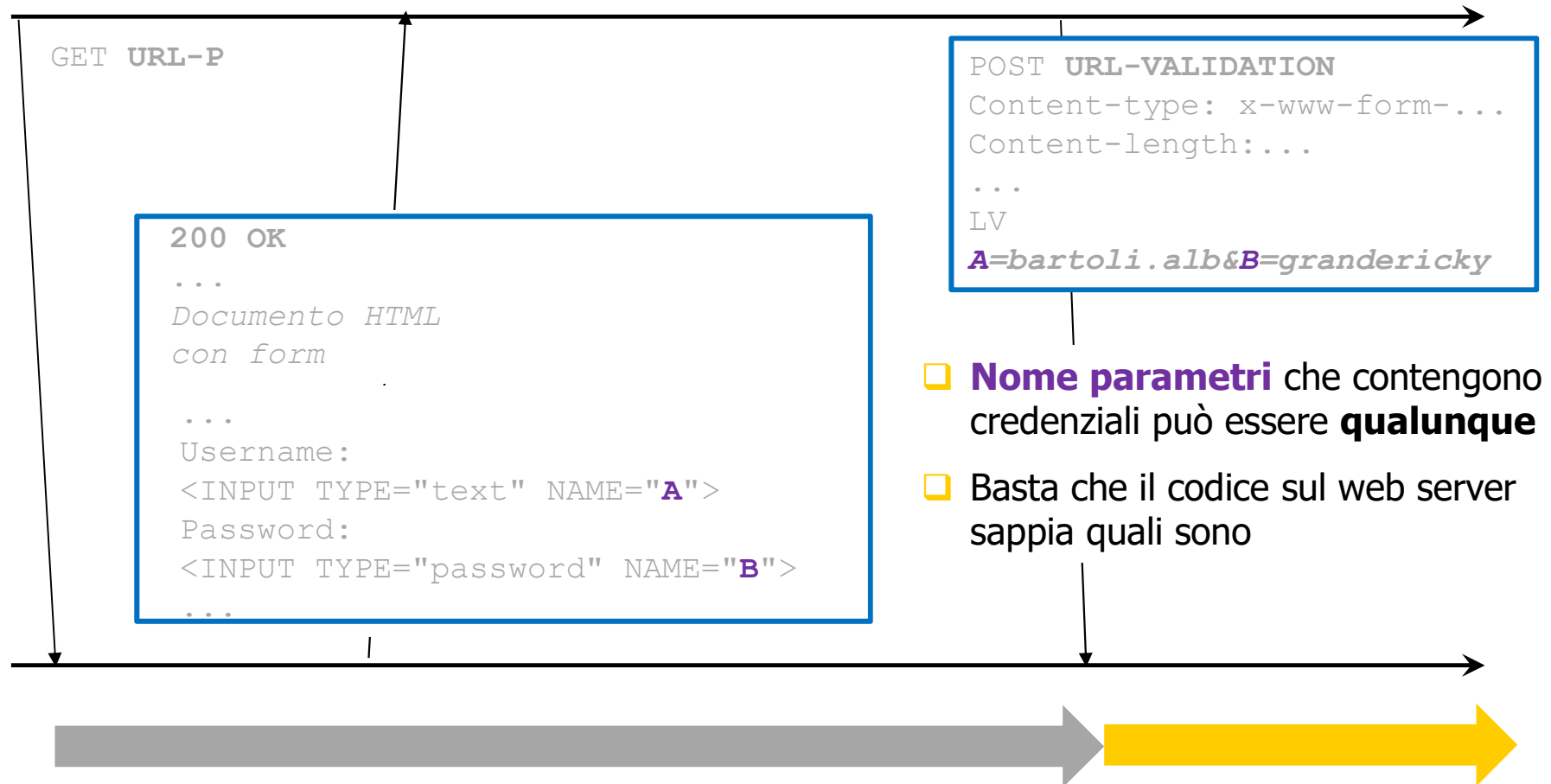
Cosa dobbiamo vedere



FORM Authentication (I)



FORM Authentication (II)

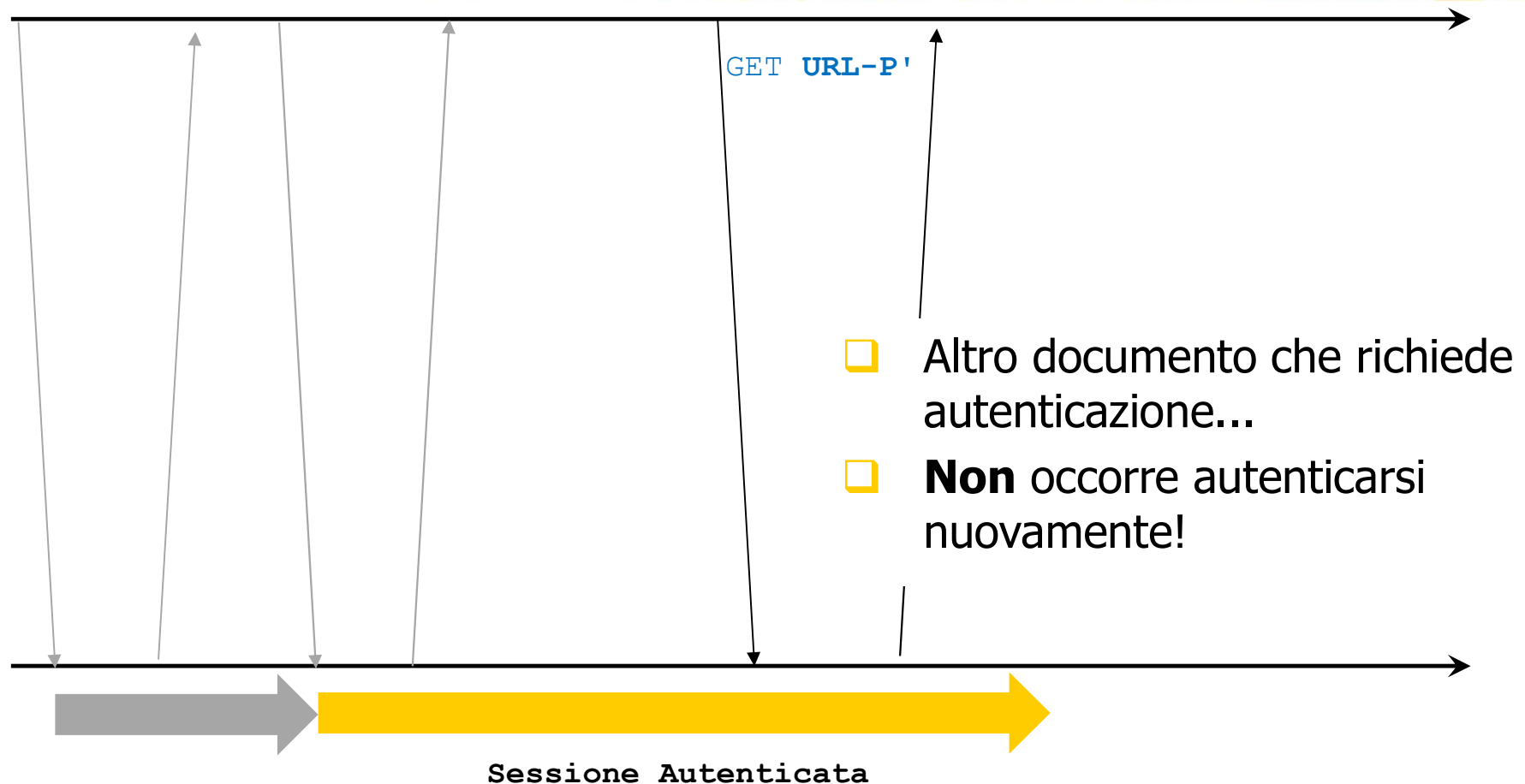


Osservazione



- ❑ Browser **non sa** che si sta autenticando
- ❑ Vede solo un comune FORM HTML e una sessione
- ❑ **Non** usa funzionalità HTTP “per l’autenticazione”

Sessione Autenticata



Autenticato per molti giorni

- ❑ Sessione basata su Cookie
- ❑ Tempo di scadenza dell'ordine di giorni / settimane / "sempre"



Bentornato

Evernote consente di ricordare tutto in tutti i computer, i telefoni e i tablet utilizzati.

Cattura qualsiasi cosa
Salva le tue idee, le attività, i progetti, i file, le ricerche e altro ancora.

Accedi da qualunque posto
Evernote ti mette a disposizione tutte le memorie ovunque tu vada.

Trova le cose velocemente
Cerca per parola chiave, tag, e trova addirittura il testo all'interno delle immagini.

Accedi o [Crea un account](#)

Indirizzo e-mail o nome utente

Password

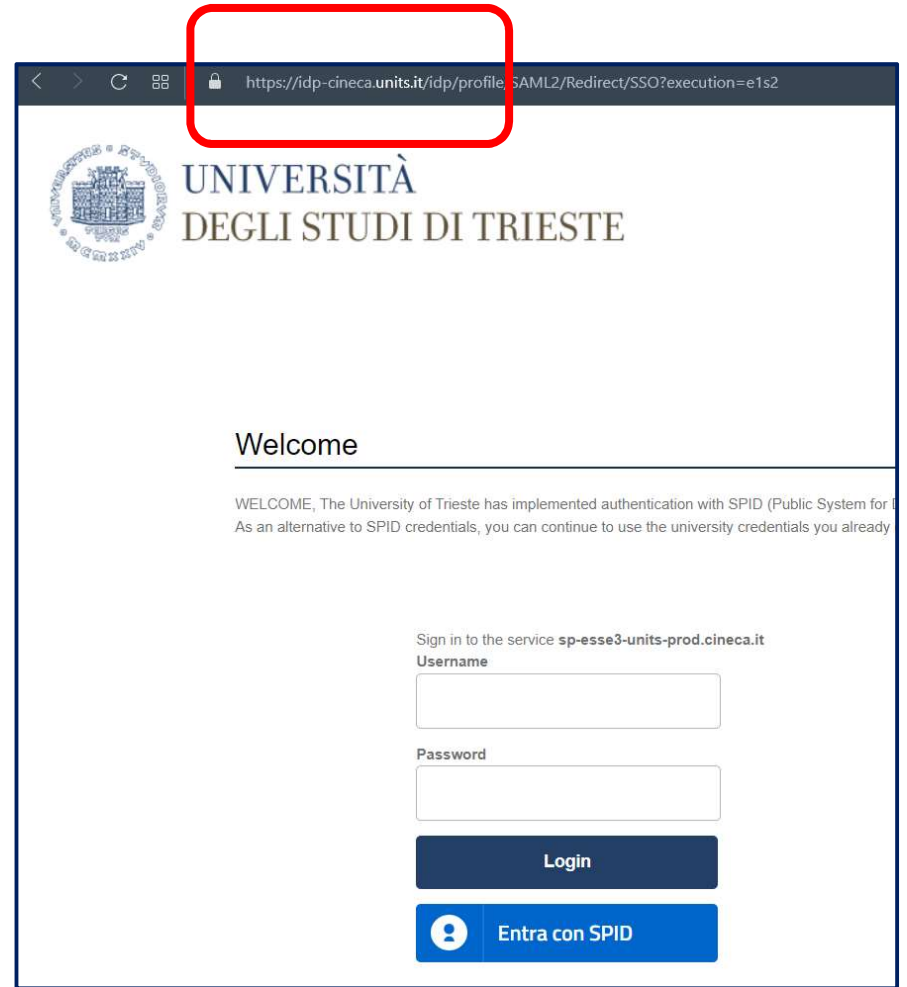
☒ Ricordami per una settimana

Accedi

[Cambia la tua password?](#)

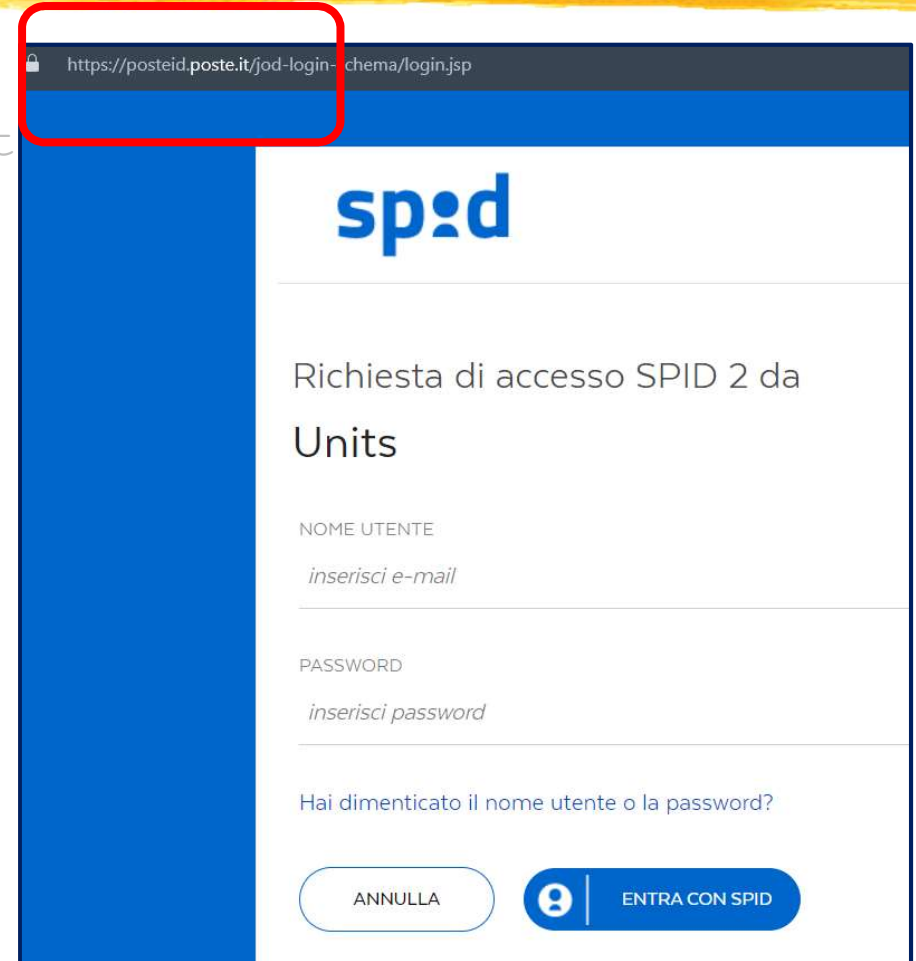
Molto rilevante (NON VEDIAMO) (I)

- ❑ Mi sto autenticando su `esse3.units.it`
- ❑ Perché FORM prelevato da
(e credenziali inviate a)
`idp-cineca.units.it`???



Molto rilevante (NON VEDIAMO) (II)

- ❑ Mi sto autenticando su `esse3.units.it`
- ❑ Perché FORM prelevato da `idp-cineca.units.it`???
- ❑ ...e perché se uso SPID **invio credenziali a** `posteid.poste.it`???



Azioni Web Server



Domanda

WEB SERVER

*Come faccio a dire se
appartiene ad una
sessione autenticata?*



Risposta



WEB SERVER

```
u := getValue-Session("user");  
IF u == ""      THEN // sessione non autenticata  
                ELSE // sessione autenticata  
...  

```

- Abbiamo assunto che alla ricezione di credenziali valide:
`Insert-Session("user", "...")`

Azioni Web Server

(Request 1 – senza cred.)

```
u := getValue-Session("user");  
IF      u == ""  
THEN    // sessione non autenticata  
    Estrai username,password da HTTP Request  
    IF      username,password ∈ TabellaCredenziali  
    THEN    Insert-Session("user",u)  
            Costruisci doc predefinito personalizzato per u  
            Send HTTP Response con doc  
            Return  
    ELSE    Send HTTP Response con doc. "devi autenticarti"  
            Return  
ELSE     // sessione autenticata  
    Costruisci doc richiesto personalizzato per u  
    Send HTTP Response con doc  
    Return
```

Request 1 non contiene credenziali
contenute in TabellaCredenziali

Azioni Web Server

(Request 2 - con cred.)

```
u := getValue-Session("user");
IF      u == ""
THEN    // sessione non autenticata
        Estrai username,password da HTTP Request
        IF      username,password ∈ TabellaCredenziali
        THEN    Insert-Session("user",u)
                Costruisci doc predefinito personalizzato per u
                Send HTTP Response con doc
                Return
        ELSE    Send HTTP Response con doc. "devi autenticarti"
                Return
ELSE    // sessione autenticata
        Costruisci doc richiesto personalizzato per u
        Send HTTP Response con doc
        Return
```

Request 2 contiene credenziali
contenute in TabellaCredenziali

Azioni Web Server

(Request in sess. auth.)

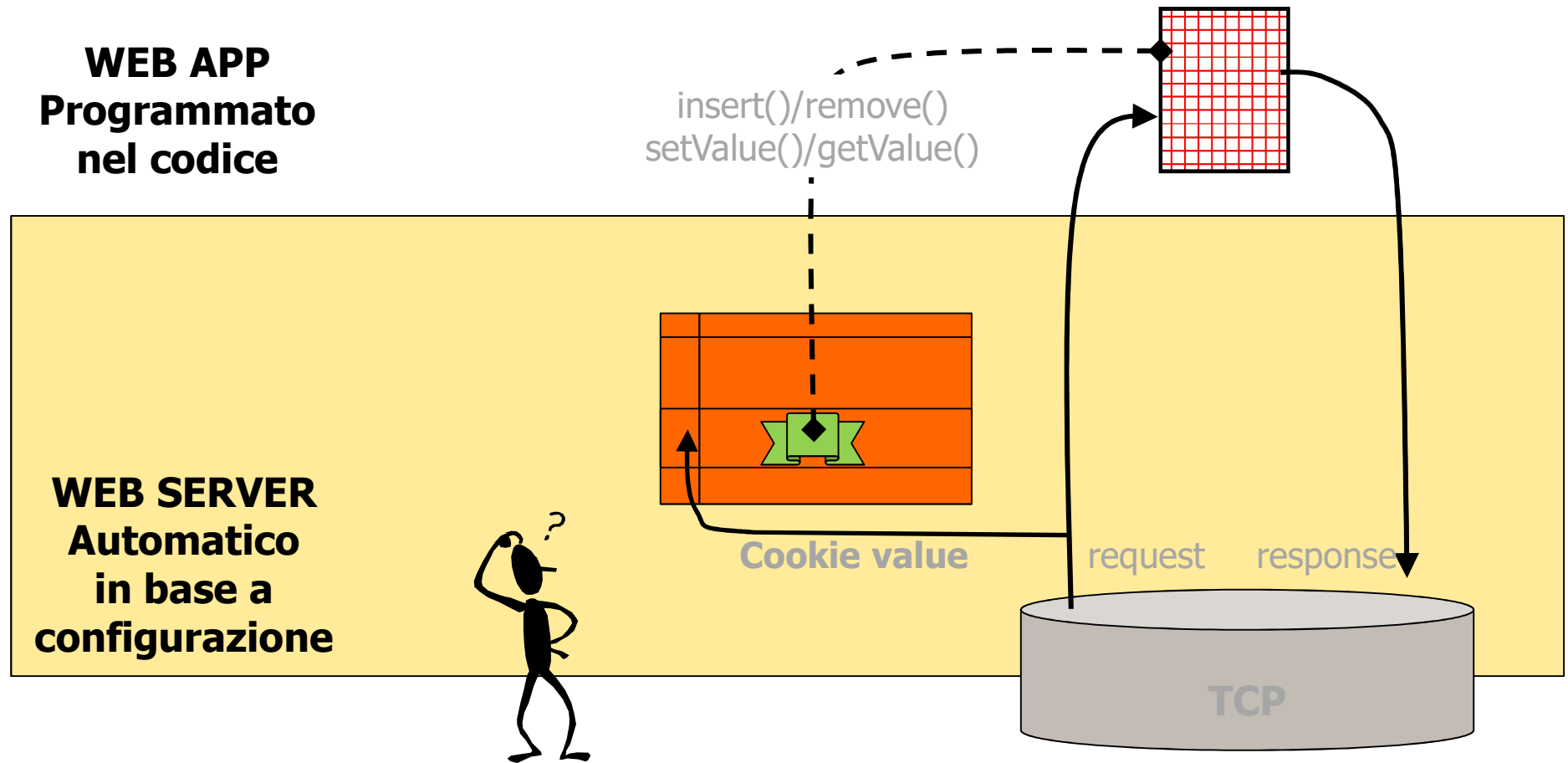
```
u := getValue-Session("user");  
IF      u == ""  
THEN    // sessione non autenticata  
          Estrai username,password da HTTP Request  
          IF      username,password ∈ TabellaCredenziali  
          THEN    Insert-Session("user",u)  
                  Costruisci doc predefinito personalizzato per u  
                  Send HTTP Response con doc  
                  Return  
          ELSE    Send HTTP Response con doc. "devi autenticarti"  
                  Return  
ELSE    // sessione autenticata  
          Costruisci doc richiesto personalizzato per u  
          Send HTTP Response con doc  
          Return
```

Personalizzazione

```
u := getValue-Session("user");
IF      u == ""
THEN    // sessione non autenticata
        Estrai username,password da HTTP Request
        IF      username,password ∈ TabellaCredenziali
        THEN    Insert-Session("user",u)
                Costruisci doc predefinito personalizzato per u
                Send HTTP Response con doc
                Return
        ELSE    Send HTTP Response con doc. "devi autenticarti"
                Return
ELSE    // sessione autenticata
        Costruisci doc richiesto personalizzato per u
        Send HTTP Response con doc
        Return
```

Il valore della **variabile di sessione** *u* è usato per
"estrarre dal database" le informazioni dell'utente

Chi realizza Autenticazione?



Semplificando moltissimo

```
u := getValue-Session("user");
IF      u == ""
THEN    // sessione non autenticata
        Estrai username,password da HTTP Request
        IF      username,password ∈ TabellaCredenziali
        THEN    Insert-Session("user",u)
                 Costruisci doc predefinito personalizzato per u
                 Send HTTP Response con doc
                 Return
        ELSE    Send HTTP Response con doc. "devi autenticarti"
                 Return
ELSE    // sessione autenticata
        Costruisci doc richiesto personalizzato per u
        Send HTTP Response con doc
        Return
```

- ❑ Tutto web server, in base alla configurazione
- ❑ Unica eccezione: costruzione del documento (web app)

Login: Hmmm...

□ Esempi

- Vado su `www.facebook.com` e ricevo contenuto generico con FORM per login
- Mi autentico e vedo **ancora** `www.facebook.com` ma **personalizzato**
- Vado su `amazon.it` e ricevo contenuto generico con FORM per login
- Mi autentico e vedo **ancora** `amazon.it` ma **personalizzato**

- Vado su `netflix.com/login` e ricevo contenuto generico con FORM per login
- Mi autentico e vedo `netflix.com/browse` personalizzato

- Vado su `mail.google.com` e ricevo contenuto generico con FORM per login
- Mi autentico e vedo `mail.google.com/mail/u/0/#inbox` personalizzato

*In molti casi arrivo su un
URL **diverso** da quello iniziale*



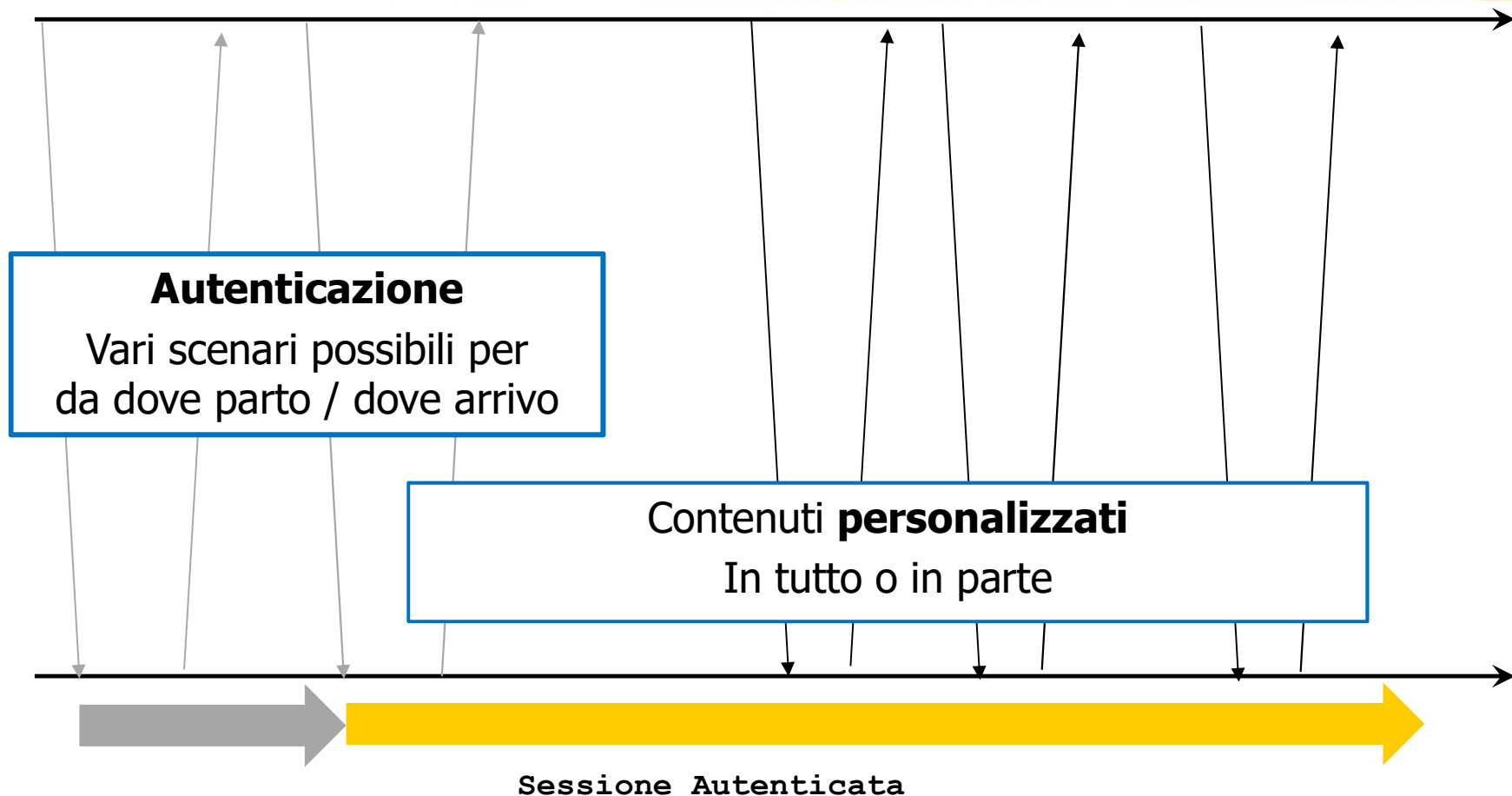
Login con redirection

1. GET URL-P in sessione non autenticata
2. HTTP Response che "sollecita autenticazione" ("pagina login")
3. POST URL-VALIDATION con credenziali
4. HTTP Response con **redirection** verso URL-P1 **predefinito**
5. GET URL-P1
6. HTTP Response con documento dinamico **personalizzato**

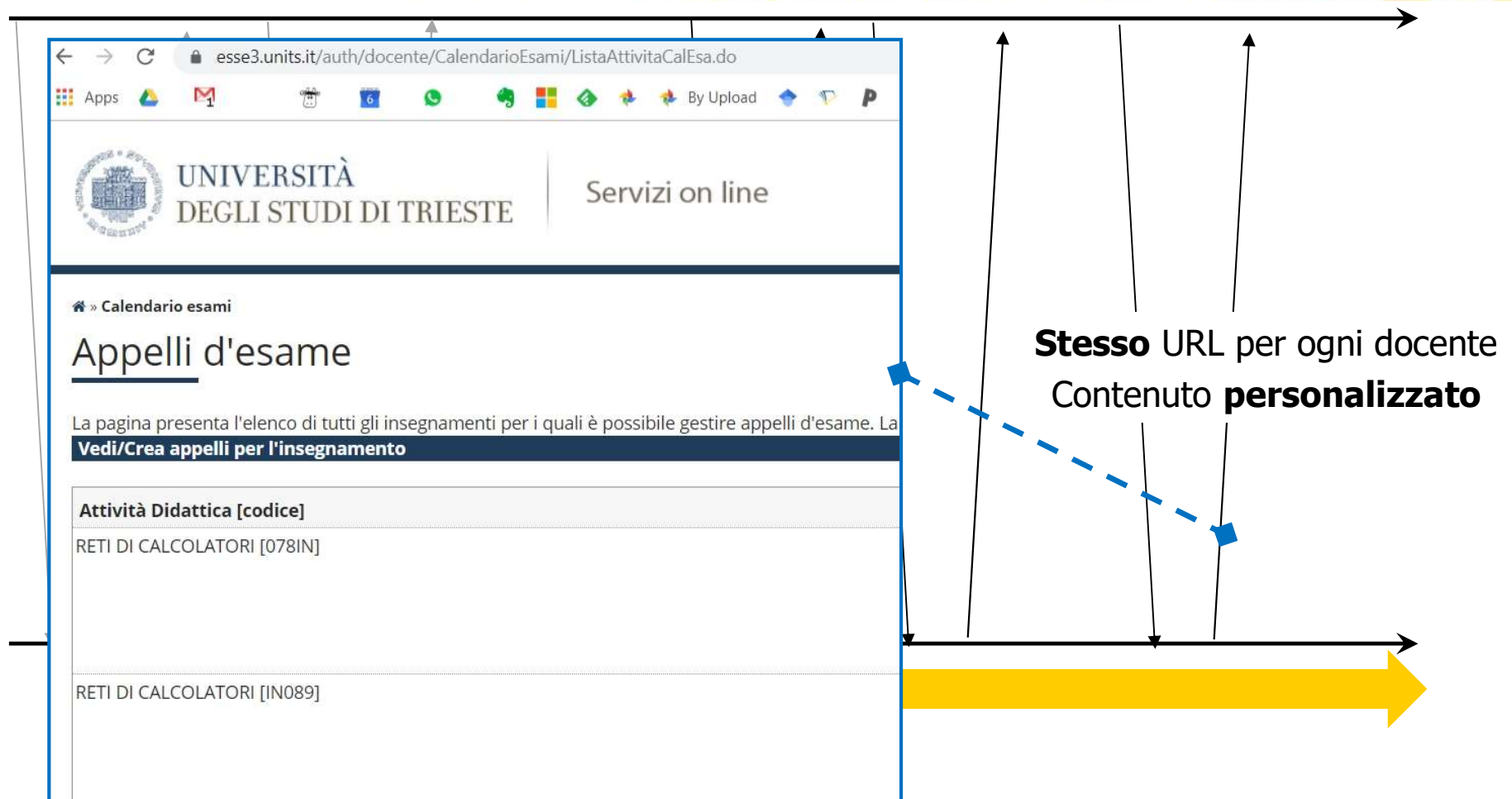
□ Browser mostra URL-P1 nella address bar

□ Omettiamo lo pseudocodice per brevità

Ricapitolando...(I)



Ricapitolando...(II)



Gravissimo Errore Relativamente Comune



Problema banalissimo



1. Scrivere il sorgente HTML di una pagina con *(immagini, link, IFRAME, ...)*
2. Elencare le **modifiche da applicare al sorgente fornito in 1** affinché l'accesso alla pagina possa avvenire **solo con authentication FORM**

Pensiamoci un attimo



- ☐ Aggiunta di un FORM nel documento da proteggere

- ☐ Se dovessi proteggere un file audio?
Metterei un FORM nella canzone?

- ☐ Browser ha ricevuto un file HTML contenente un FORM:
 - ☐ Mi mostra solo il FORM?
 - ☐ Basterebbe modificare il browser per vedere tutto

Voto = $-\infty$

1) Nel html bisogna aggiungere:

```
<FORM ACTION="/validate.asp" Method=POST>  
user: <INPUT TYPE="text" NAME="A">  
password: <INPUT TYPE="password" NAME="B">
```

Modificare alla pagina W=

```
<html>  
:  
<FORM ACTION="/logged-only" METHOD="POST">  
Username:<input type="text" NAME="USERNAME">  
Password:<input type="text" NAME="password">  
</FORM>  
</html>
```

Authentication vs Authorization



Contenuti protetti (per ora) (REMINDE)



- ❑ Configurazione Web Server:

- ❑ Insieme di URL che **richiedono autenticazione**
 - ❑ Insieme di URL che **non** richiedono autenticazione

- ❑ Gli utenti autenticati hanno **tutti** gli **stessi** "diritti di accesso"

- ❑ **Non è sufficiente (ovviamente)**

Hmmm...(I)

[https://esse3.units.it/auth/docente/CalendarioEsami?
AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15](https://esse3.units.it/auth/docente/CalendarioEsami?AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15)

**UNIVERSITÀ
DEGLI STUDI
DI TRIESTE**

Servizi on line

MENU

» Calendario Esami » Lista appelli d'esame

Lista appelli d'esame

Appelli di: RETI DI CALCOLATORI [142IN]
INGEGNERIA ELETTRONICA E INFORMATICA [IN05] (L)...

visualizza dettagli >>

Elenco Appelli d'esame

☐ Nuovo appello d'esame ☐ Nuova prova parziale

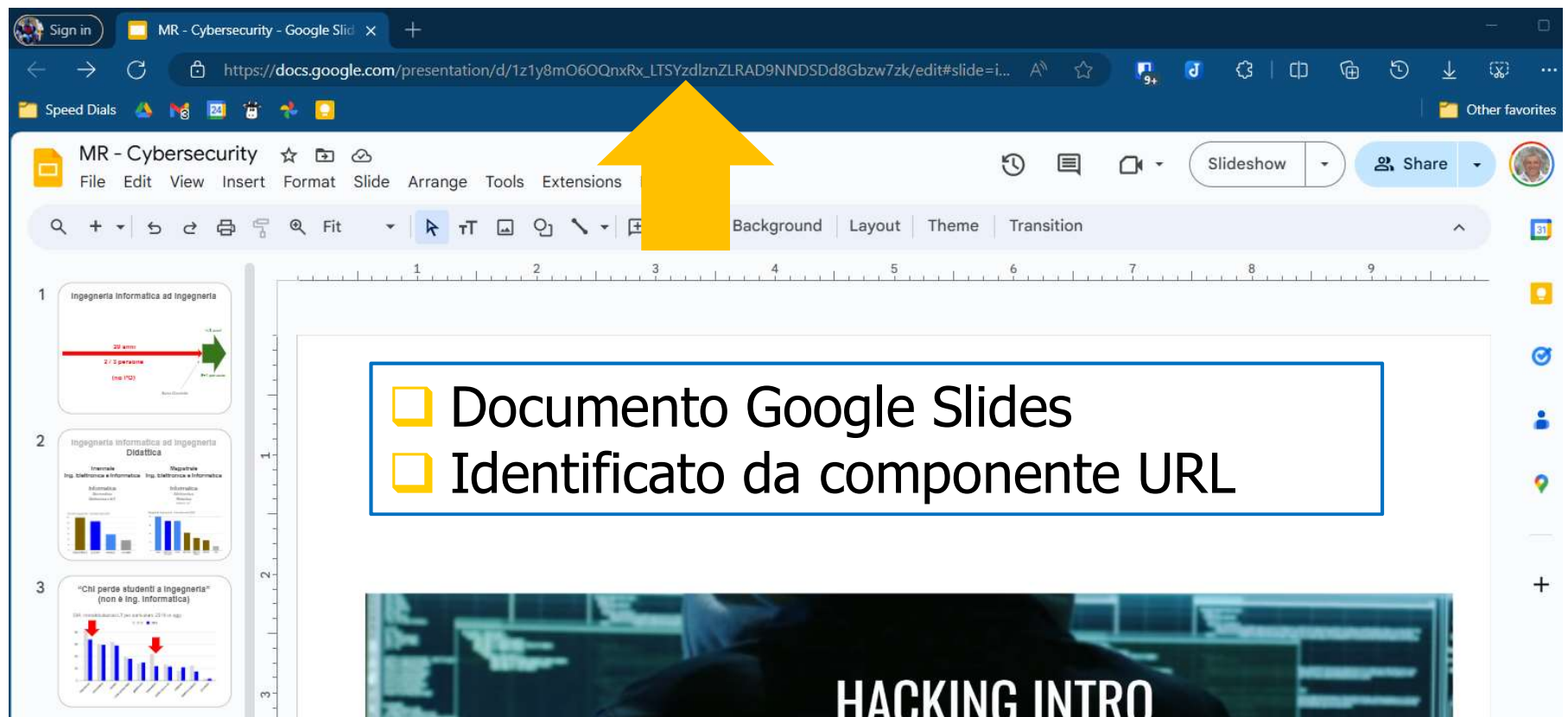
Visualizza recenti

Descrizione Appello	Data ora aula	Studenti iscritti	Esiti inseriti	Verballi caricati	Azioni
Quarto appello estivo - 2023/2024	 19/09/2024 09:30 Aula F				  
Terzo appello estivo - 2023/2024	 04/07/2024 09:30 Aula F	 10	 3	 3	  
Secondo appello estivo - 2023/2024	 20/06/2024 09:30 Aula F	 7	 1	 1	  
Primo appello estivo - 2023/2024	 07/06/2024 09:30 Aula F	 9	 2	 2	  

***Ogni utente autenticato di esse3
che conosce l'URL di questa pagina
può operare su questo esame???***



Hmmm...(II-a)



The screenshot shows a web browser window displaying a Google Slides presentation. The browser's address bar contains the URL: https://docs.google.com/presentation/d/1z1y8mO6OQnxRx_LTSYzdlznZLRAD9NNDSDd8Gbzw7zk/edit#slide=i.... A large yellow arrow points from the URL bar down to the slide content. The slide content includes a list of three items on the left and a main slide area on the right. The main slide area contains a blue-bordered box with two bullet points and a video player at the bottom.

- 1 Ingegneria Informatica ad Ingegneria Didattica
- 2 Ingegneria Informatica ad Ingegneria Didattica
- 3 "Chi perde studenti a Ingegneria" (non è Ing. Informatica)

☐ Documento Google Slides

☐ Identificato da componente URL

HACKING INTRO

Hmmm...(II-b)

**Perché Cybersecurity:
Seminario 3 ore → 85 persone (!)**

Share "MR - Cybersecurity"

Add people, groups, and calendar events

People with access

	Alberto Bartoli (you) bartoli.alberto@gmail.com	Owner
	Eric Medvet eric.medvet@gmail.com	Commenter

General access

 Restricted
Only people with access can open with the link

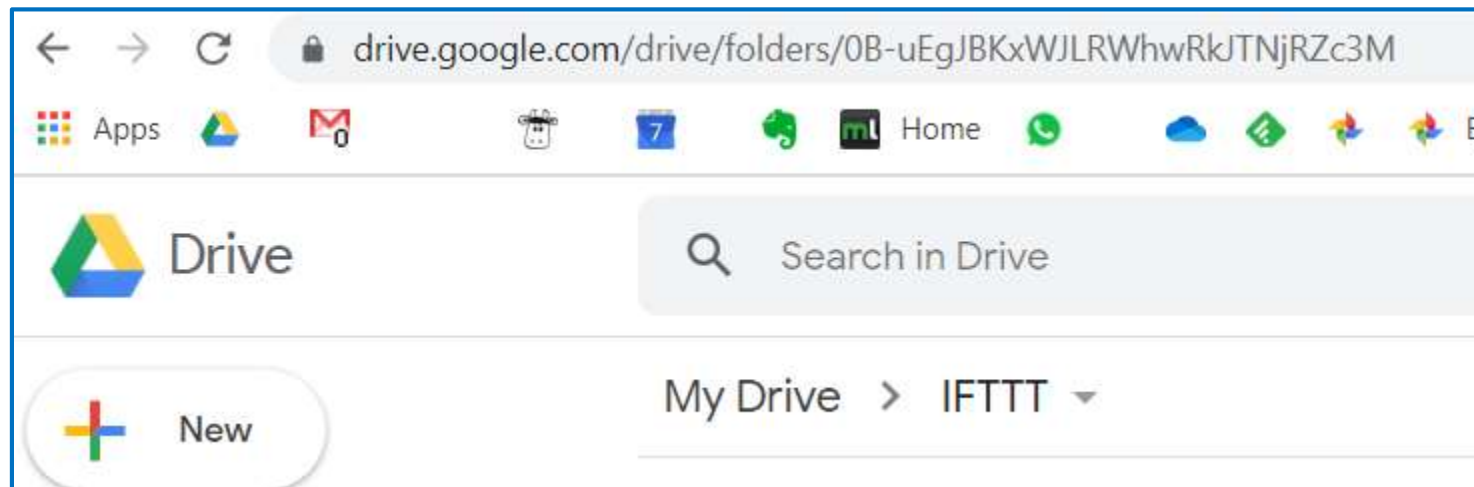
[Copy link](#) [Done](#)

Ho pensato di anticipare l'iscrizione più sotto)
L'introduzione sarà (metasploitable3).
La lezione sarà strutturata in 3 parti:
1. Un'ora e mezza di introduzione al mondo della cybersecurity.
2. Mezz'ora di dimostrazione di attacchi fatta in diretta da me sul mio PC (tra due macchine virtuali). Chi viene con il software già installato sul proprio PC potrà fare le stesse cose sul proprio PC.
3. Nei giorni successivi alla lezione ogni studente dovrebbe eseguire quegli attacchi, ed altri, sul proprio PC (tra macchine virtuali). Per i giorni successivi non spiegherò nulla e lascerò agli studenti il tempo per fare queste attività in classe.

*Come è possibile renderlo
accessibile solo ad **alcuni** utenti
autenticati ma **non a tutti**?*

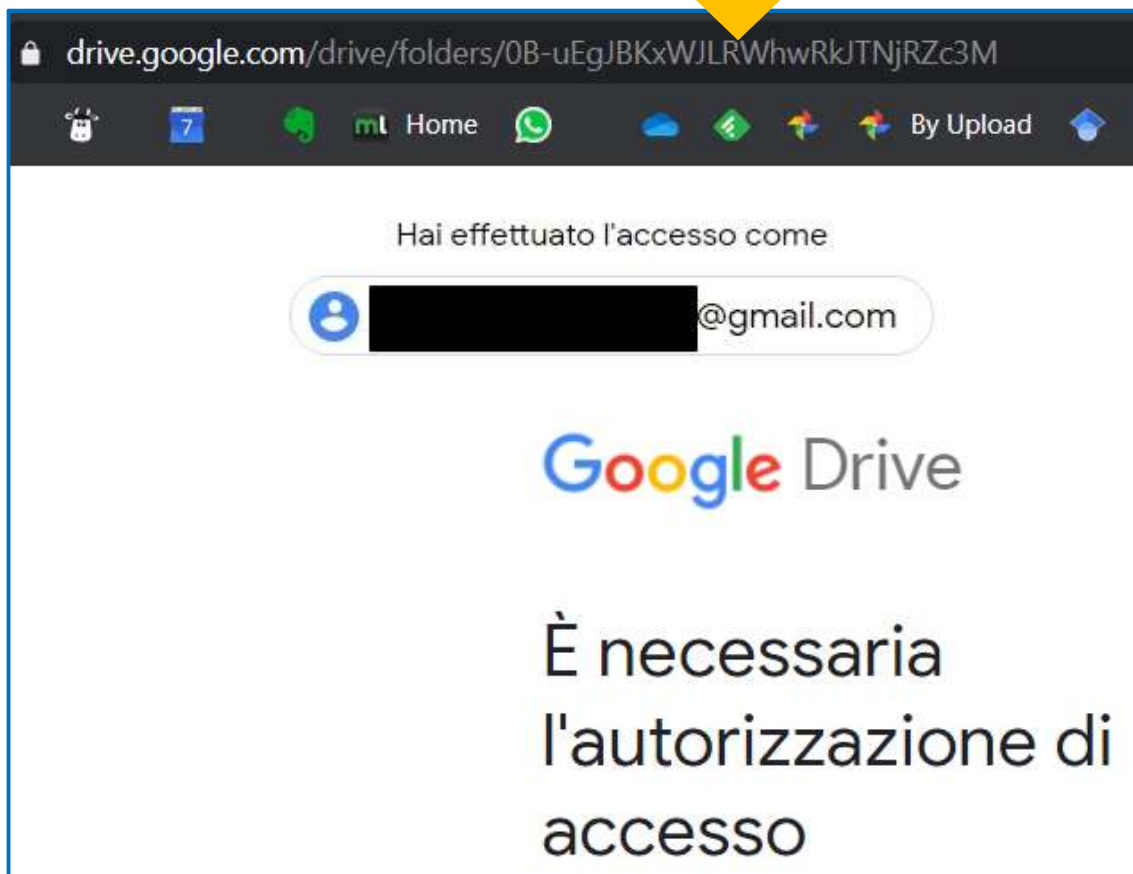


Authentication vs Authorization (I)



- ❑ Folder
- ❑ Identificato da componente URL

Authentication vs Authorization (II)



Utente è **autenticato**

Non è **autorizzato**
ad accedere a questo URL

Contenuti protetti: (~~per ora~~) Authorization



□ Configurazione Web Server:

- Insieme di URL che **richiedono autenticazione**
 - Per ogni URL, insieme di username **autorizzati** all'accesso (Access Control List: **ACL**)
- Insieme di URL che **non** richiedono autenticazione

- $ACL(\text{URL-X}) = \text{username-A, username-B, username-C}$
- $ACL(\text{URL-Y}) = \text{username-A}$
- $ACL(\text{URL-Z}) = \text{"senza autenticazione"}$
- ...

Senza Authorization check

```
u := getValue-Session("user");
IF      u == ""
THEN    // sessione non autenticata
        Estrai username,password da HTTP Request
        IF      username,password ∈ TabellaCredenziali
        THEN    Insert-Session("user",u)
                Costruisci doc predefinito personalizzato per u
                Send HTTP Response con doc
                Return
        ELSE    Send HTTP Response con doc. "devi autenticarti"
                Return
ELSE    // sessione autenticata
        Costruisci doc richiesto personalizzato per u
        Send HTTP Response con doc
        Return
```

Indispensabile verificare che u è **autorizzato**
ad accedere al documento

Authorization check

- Prima di tornare documento `requested-URL`
- **Indispensabile** verificare che $u \in \text{ACL}(\text{requested-URL})$

...
Costruisci documento URL-X (eventualmente personalizzato)
Send HTTP Response con documento
...



```
IF      u ∈ ACL(URL-X)
THEN    Costruisci documento URL-X personalizzato per u
        Send HTTP Response con documento
ELSE    Send HTTP Response "non sei autorizzato per URL-X"
```

Hmmm...

- **Configurazione:** Diritti di accesso agli URL
 - ACL(URL-X) = username-A, username-B, username-C
 - ACL(URL-Y) = username-A
 - ACL(URL-Z) = "senza autenticazione"
 - ...

*Quindi per configurare un web server devo
elencare tutti gli URL su quel web server e poi
descrivere individualmente ognuno di essi?*



Realm (I)

- ❑ **Realm: insieme** di risorse protette **nello stesso modo**
 - ❑ Insieme di URL
 - ❑ Descrizione molto compatta
 - ❑ ACL
 - ❑ Insieme di username
 - ❑ Protocollo di autenticazione
 - ❑ Vari protocolli di autenticazione (abbiamo visto FORM, vedremo BASIC)

Realm Name	Resources	ACL	Protocol
Esami	/esami/*	alberto marco ruud	FORM
Documenti	*.pdf	alberto ricky andry	BASIC
Config	/admin/*	admin	FORM

Realm (II)



❑ Default Realm:

- ❑ Ogni URL **non** appartenente agli altri Realm (non protetto)
- ❑ Accessibile **senza** autenticazione

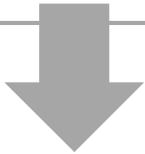
❑ Definito **implicitamente**

Realm Name	Resources	ACL	Protocol
Esami	/esami/*	alberto marco ruud	FORM
Documenti	*.pdf	alberto ricky andry	BASIC
Config	/admin/*	admin	FORM
Default	Any other	-	No Auth.

Realm (III)

□ Configurazione Web Server:

- Insieme di URL che **richiedono autenticazione**
 - Per ogni URL, insieme di username **autorizzati** all'accesso (Access Control List: **ACL**)
- Insieme di URL che **non** richiedono autenticazione



□ Tabella dei Realm

Web Server vs Web App



- ❑ Web app ("Codice che devo scrivere")
 - ❑ Costruisce contenuti dinamici, spesso personalizzati
- ❑ Web Server ("Automatico, devo solo **configurare**")
 - ❑ Autenticazione (Tabella delle Credenziali)
 - ❑ Autorizzazione (Tabella dei Realm)
 - ❑ Contenuti statici

Authorization:

In pratica



Cosa deve succedere?

[https://esse3.units.it/auth/docente/CalendarioEsami?
AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15](https://esse3.units.it/auth/docente/CalendarioEsami?AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15)

**UNIVERSITÀ
DEGLI STUDI
DI TRIESTE**

Servizi on line



[» Calendario Esami](#) » [Lista appelli d'esame](#)

Lista appelli d'esame

Appelli di: RETI DI CALCOLATORI [142IN]
INGEGNERIA ELETTRONICA E INFORMATICA [IN05] (L)...

[visualizza dettagli >>](#)

Elenco Appelli d'esame

☐ Nuovo appello d'esame ☐ Nuova prova parziale Visualizza recenti

Descrizione Appello	Data ora aula	Studenti iscritti	Esiti inseriti	Verballi caricati	Azioni
Quarto appello estivo - 2023/2024	 19/09/2024 09:30 Aula F				  
Terzo appello estivo - 2023/2024	 04/07/2024 09:30 Aula F	 10	 3	 3	 
Secondo appello estivo - 2023/2024	 20/06/2024 09:30 Aula F	 7	 1	 1	 
Primo appello estivo - 2023/2024	 07/06/2024 09:30 Aula F	 9	 2	 2	 

Indietro

Caso molto comune

[https://esse3.units.it/auth/docente/CalendarioEsami?
AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15](https://esse3.units.it/auth/docente/CalendarioEsami?AA_ID=2023&CDS_ID=10424&AD_ID=118851&APP_ID=15)

**UNIVERSITÀ
DEGLI STUDI
DI TRIESTE**

Servizi on line

MENU

» Calendario Esami » Lista appelli d'esame

Lista appelli d'esame

Appelli di: RETI DI CALCOLATORI [142IN]
INGEGNERIA ELETTRONICA E INFORMATICA [IN05] (L)...

visualizza dettagli >>

Elenco Appelli d'esame

☐ Nuovo appello d'esame ☐ Nuova prova parziale

Visualizza recenti

Descrizione Appello	Data ora aula	Studenti iscritti	Esiti inseriti	Verballi caricati	Azioni
Quarto appello estivo - 2023/2024	 19/09/2024 09:30 Aula F				  
Terzo appello estivo - 2023/2024	 04/07/2024 09:30 Aula F	 10	 3	 3	 
Secondo appello estivo - 2023/2024	 20/06/2024 09:30 Aula F	 7	 1	 1	 
Primo appello estivo - 2023/2024	 07/06/2024 09:30 Aula F	 9	 2	 2	 

- ❑ Documento assemblato con query a DB
- ❑ "Impossibile" descrivere in anticipo tutte le combinazioni al web server
- ❑ Check "deve" essere eseguito **dalla web app**

Caso meno comune

MR - Cybersecurity

File Edit View Insert Format Slide Arrange Tools Extensions

Background Layout Theme Transition

- 1 Ingegneria Informatica ad Ingegneria
200 anni
2 / 3 persone
(ing. IGI)
- 2 Ingegneria Informatica ad Ingegneria Didattica
Ingegneria Informatica Ingegneria Informatica
Ingegneria Informatica Ingegneria Informatica
- 3 "Chi perde studenti a Ingegneria" (non è Ing. Informatica)
Ingegneria Informatica Ingegneria Informatica

- ☐ Documento **non** assemblato con query a DB
- ☐ "Facile" descrivere in anticipo al web server chi può accedere
- ☐ Check può essere eseguito **dal web server**

HACKING INTRO

Web Server vs Web App:

In pratica



- ❑ Web app ("Codice che devo scrivere")
 - ❑ Costruisce contenuti dinamici, spesso personalizzati
 - ❑ Autorizzazione

- ❑ Web Server ("Automatico, devo solo **configurare**")
 - ❑ Autenticazione (Tabella delle Credenziali)
 - ❑ Autorizzazione (Tabella dei Realm)
 - ❑ Contenuti statici

- ❑ In moltissimi casi pratici, Authorization deve essere **programmata**

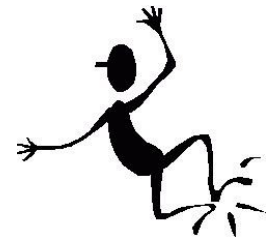
18app: Un bug interessante...

- ❑ Subject con **username-1** si autentica
- ❑ Riceve pagine con link per creare voucher di acquisto

<https://www.18app.italia.it/BONUSWS/rest/secured/18enne/beneficiario/CF-username>

<https://www.18app.italia.it/BONUSWS/rest/secured/18enne/listaVoucherDaSpendere/CF-username>

- ❑ BUG: **manca il controllo di authorization**
- ❑ Per molti mesi, ogni utente **autenticato** poteva accedere alle pagine (e consumare i voucher) di **ogni altro utente**
- ❑ Bastava inviare HTTP Request verso URL contenenti **CF-X diverso dal proprio**



Curiosità (Cybersecurity)...



- ❑ Errore di programmazione che può "creare problemi di sicurezza"
= **Vulnerabilità**
- ❑ Questa particolare tipologia di vulnerabilità:
 - ❑ Appartiene alla "categoria" delle Access Control Vulnerabilities
 - ❑ Spesso indicata con **IDOR** (**I**nsecure **D**irect **O**bject **R**eference)

Login: Ultimo caso



Login (REMINDE)



1. GET URL-P in sessione non autenticata
 2. HTTP Response che "sollecita autenticazione" ("**pagina login**")
 3. POST URL-VALIDATION **con credenziali**
 4. HTTP Response con documento dinamico **personalizzato** (landing su URL-P)
- oppure
4. HTTP Response con **redirection** verso URL-P1 **predefinito**
 5. GET URL-P1
 6. HTTP Response con documento dinamico **personalizzato** (landing su URL-P1)

Login: Ultimo caso (I)

RESEARCH-ARTICLE

A Framework for Large-Scale Detection of Web Site Defacements

Authors: [Alberto Bartoli](#), [Giorgio Davanzo](#), and [Eric Medvet](#) | [Authors Info & Claims](#)

ACM Transactions on Internet Technology (TOIT), Volume 10, Issue 3 • Article No.: 10, Pages 1 - 37
<https://doi.org/10.1145/1852096.1852098>

Published: 01 October 2010 [Publication History](#)

14 916

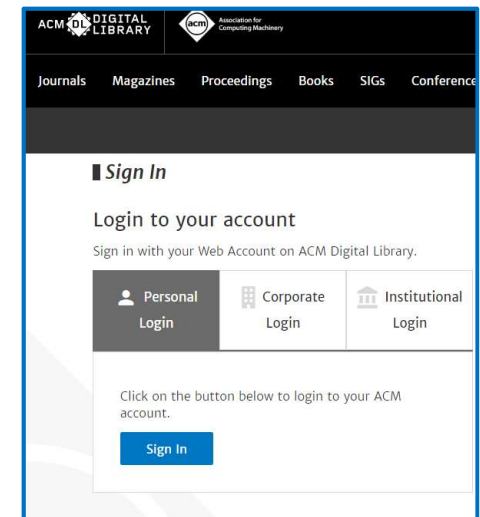
click

GET URL-P in sessione non autenticata

...

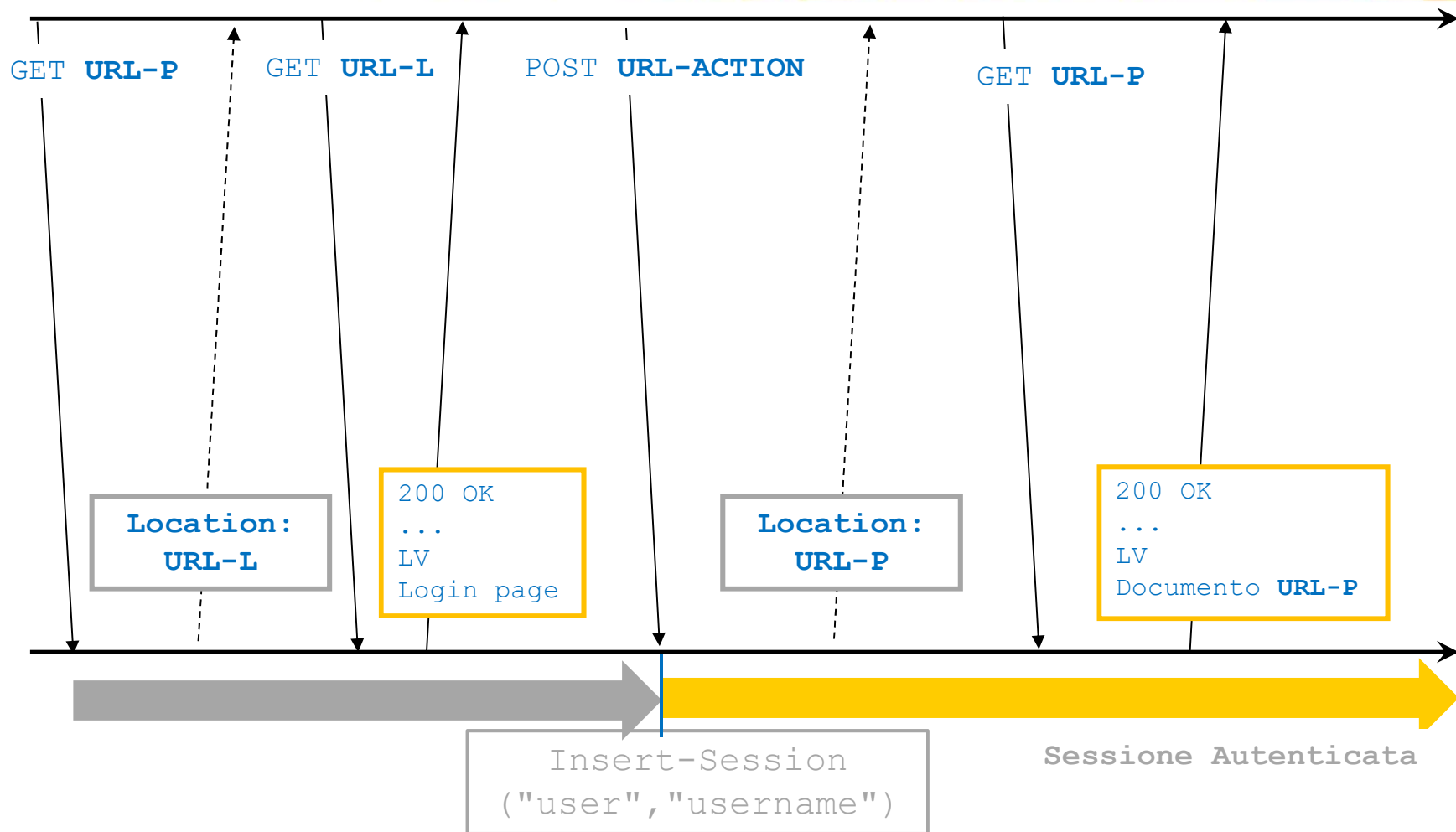
HTTP Response con documento URL-P
(landing su URL-P)

Login: Ultimo caso (II)

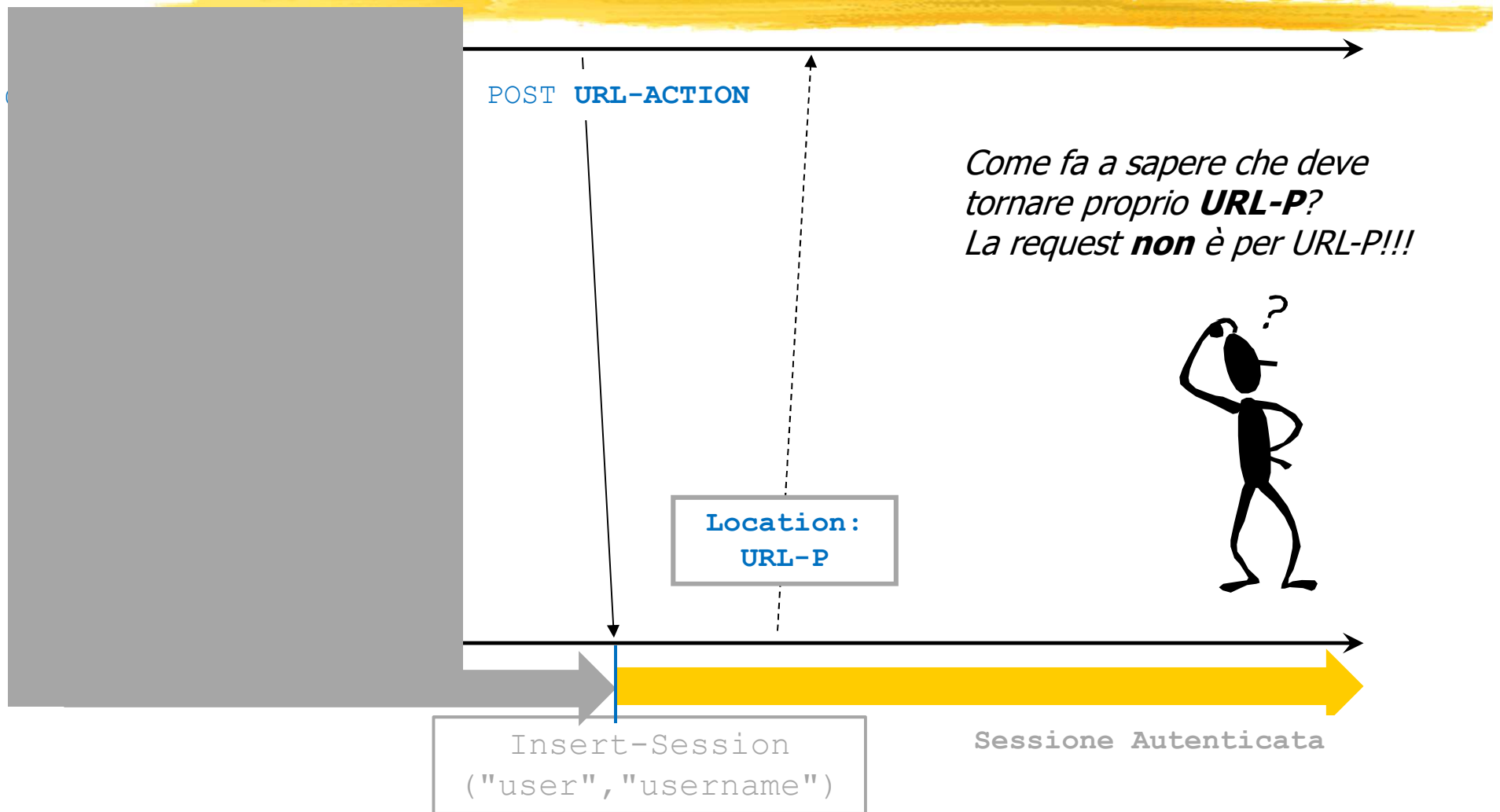


1. **GET URL-P** in sessione non autenticata
2. HTTP Response con **redirection** verso URL-login **predefinito**
3. POST URL-VALIDATION con credenziali
4. HTTP Response con **redirection** verso URL-P
5. **GET URL-P**
6. HTTP Response con documento URL-P
(landing su URL-P)

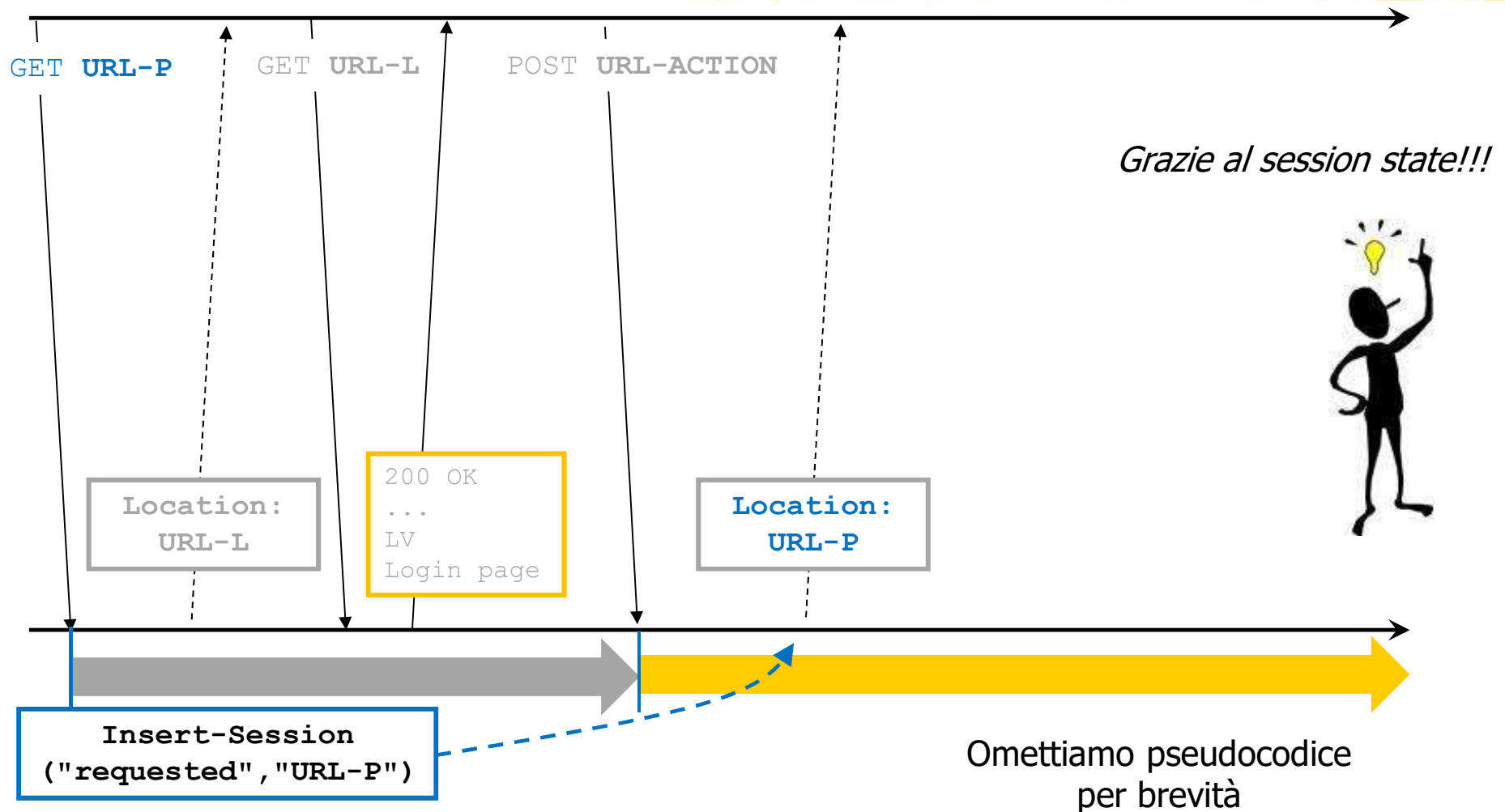
Apparentemente banale



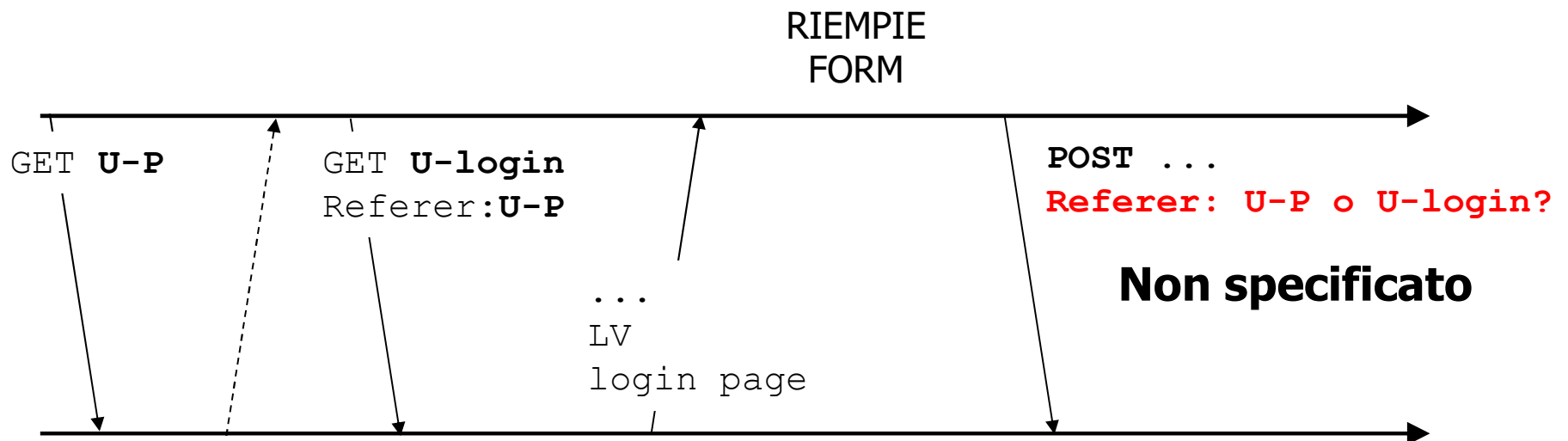
Hmmm...



Non banale



Referrer in POST (dettaglio)



Ricapitolando...

1. URL-P → URL-P
 2. URL-P → URL-P1 predefinito
 3. URL-P → URL-P con redirection su login page
- ❑ Pseudo codice solo per caso 1
(altri due casi concettualmente semplici)

Autenticazione

Vari scenari possibili per
da dove parto / dove arrivo

Contenuti **personalizzati**

In tutto o in parte

Sessione Autenticata

Cookie Identifiers



Scenario sfortunato 1

- ❑ Attacker legge la Tabella dei Cookie di B1@D1
 - ❑ Non chiediamoci "come" può farlo
 - ❑ Riflettiamo solo sulle conseguenze



- ❑ Attacker può generare HTTP Request che appartengono alle sessioni di B1@D1
- ❑ Anche senza conoscere le password

Scenario sfortunato 2

- ❑ **Attacker osserva il traffico HTTP di B1@D1**

- ❑ Non chiediamoci "come" può farlo

- ❑ Riflettiamo solo sulle conseguenze



- ❑ Attacker può generare HTTP Request che appartengono alle sessioni di B1@D1

- ❑ Anche senza conoscere le password

Importantissimo



- ❑ Operazioni con validità legale / economica / finanziaria
- ❑ "Autenticazione" fondata su "**riservatezza**" di **cookie identifier**
 - ❑ Deve essere noto **solo** a B@D e Web Server
 - ❑ **Nessun altro** deve conoscerlo
 - ❑ Riservatezza della password **non** è sufficiente

Ipotesi ottimistiche

- HTTP Request R appartiene a sessione *sid* con web server W
 - ⇔ R contiene parametro *name=sid*
 - *name* dipende dalla configurazione di W
 - *sid* **identificatore di sessione** scelto da W (**univoco** su W)
- Assumiamo che sia impossibile:
 - Attacker legge la Tabella dei Cookie di B1@D1
 - Attacker osserva il traffico HTTP di B1@D1
- E' sufficiente per stare tranquilli o manca qualcosa?



Hmmm...



- HTTP Request R appartiene a sessione *sid* con web server W
 - ⇔ R contiene parametro *name=sid*
 - *name* dipende dalla configurazione di W
 - *sid* **identificatore di sessione** scelto da W (**univoco** su W)
- Set-Cookie: ID=47
 - Soddisfa il requisito "è univoco"
 - Cosa potrebbe fare un attacker?

Esempio



- ❑ Attacker conosce:
 - ❑ URL-X per eseguire operazioni "protette"
 - ❑ Nome e significato parametri da inserire nella Request
(es: source_IBAN, dest-IBAN, amount / insegnamento, studente, voto)
- ❑ Attacker:
 - ❑ Costruisce Request per URL-X con parametri "fraudolenti"
 - ❑ Invia **moltissime copie** della Request:
una per ogni valore possibile dei Cookie
- ❑ IF Esiste sessione con ID usato da Attacker
- ❑ THEN Attacker esegue operazione fraudolenta in quella sessione

Cookie identifier: Requisito

- HTTP Request R appartiene a sessione *sid* con web server W
 - ⇔ R contiene parametro *name=sid*
 - *name* dipende dalla configurazione di W
 - *sid* **identificatore di sessione** scelto da W
(**univoco** su W)
+
non enumerabile
("talmente lungo che è praticamente impossibile provare tutti i valori")
+
non predicibile
- Set-Cookie: ID=4766AAvvGHJ782

HTTP Basic Authentication

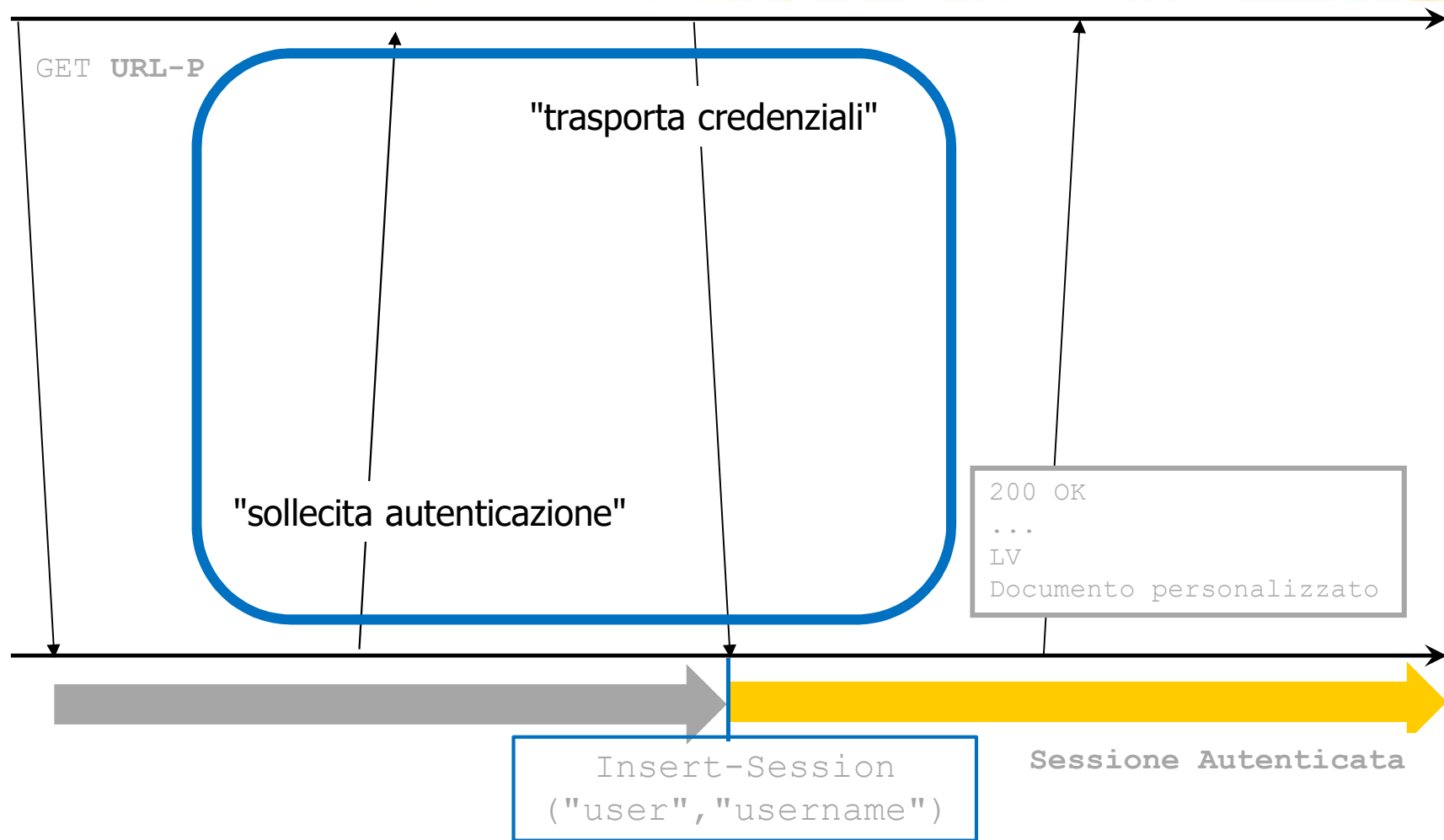


Realm (REMINO)

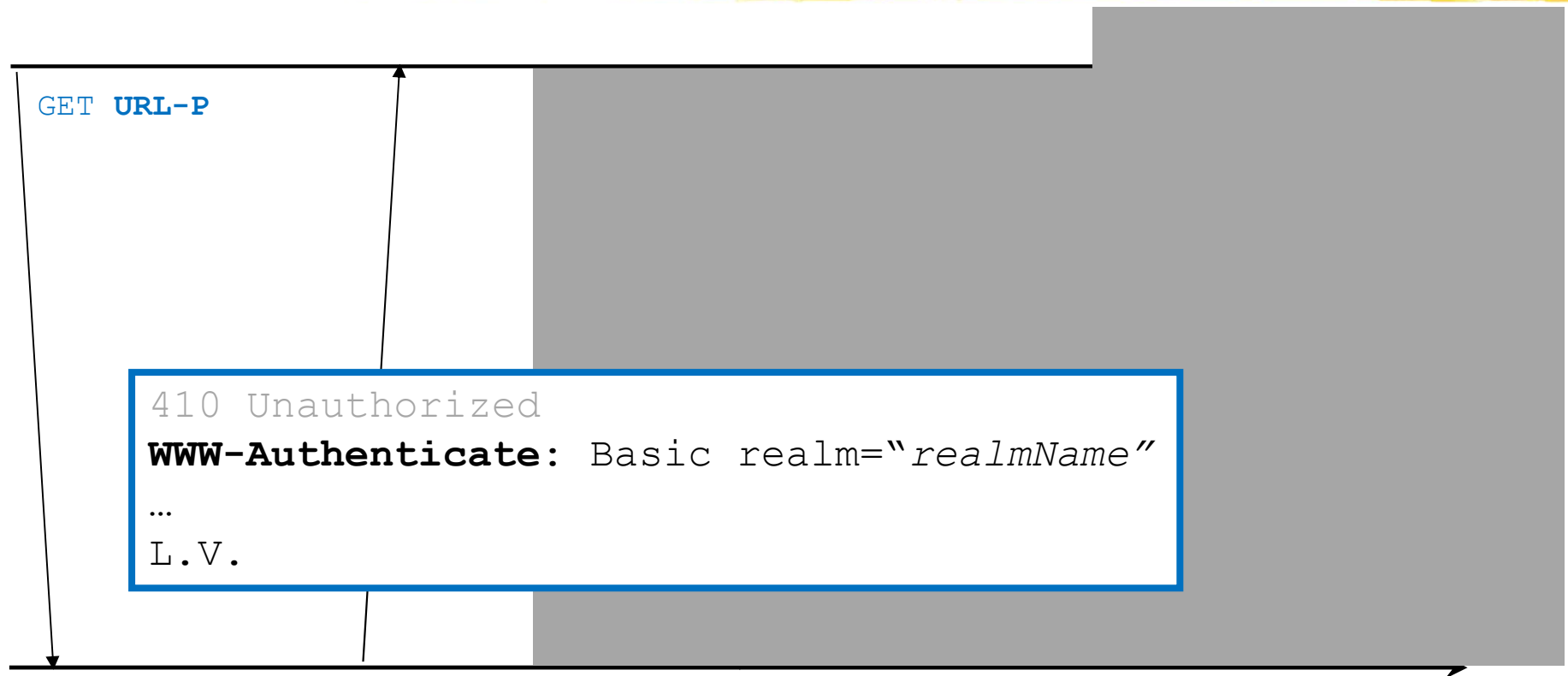
- ❑ **Realm: insieme** di risorse protette **nello stesso modo**
 - ❑ Insieme di URL
 - ❑ Descrizione molto compatta
 - ❑ ACL
 - ❑ Insieme di username
 - ❑ Protocollo di autenticazione
 - ❑ Vari protocolli di autenticazione (abbiamo visto FORM, vedremo BASIC)

Realm Name	Resources	ACL	Protocol
Esami	/esami/*	alberto marco ruud	FORM
Documenti	*.pdf	alberto ricky andry	BASIC
Config	/admin/*	admin	FORM

Cosa dobbiamo vedere



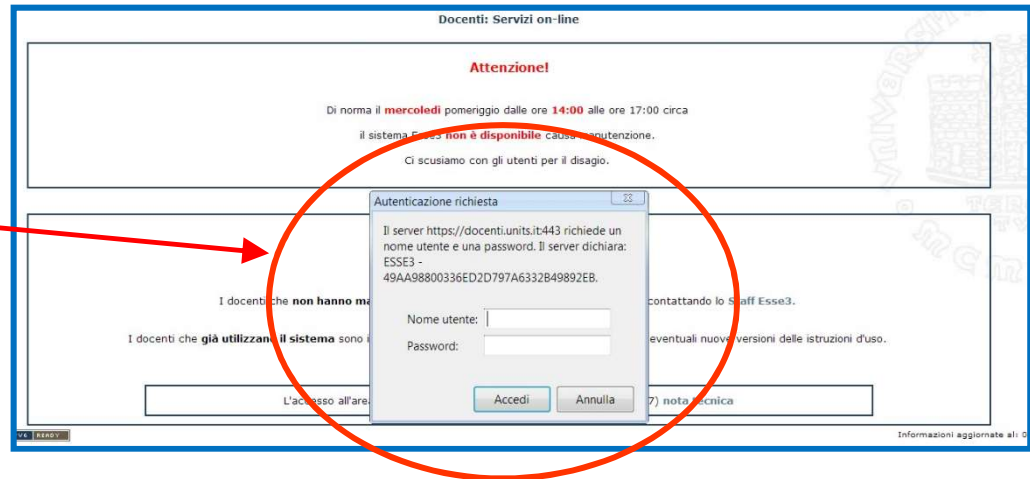
Basic Authentication (I)



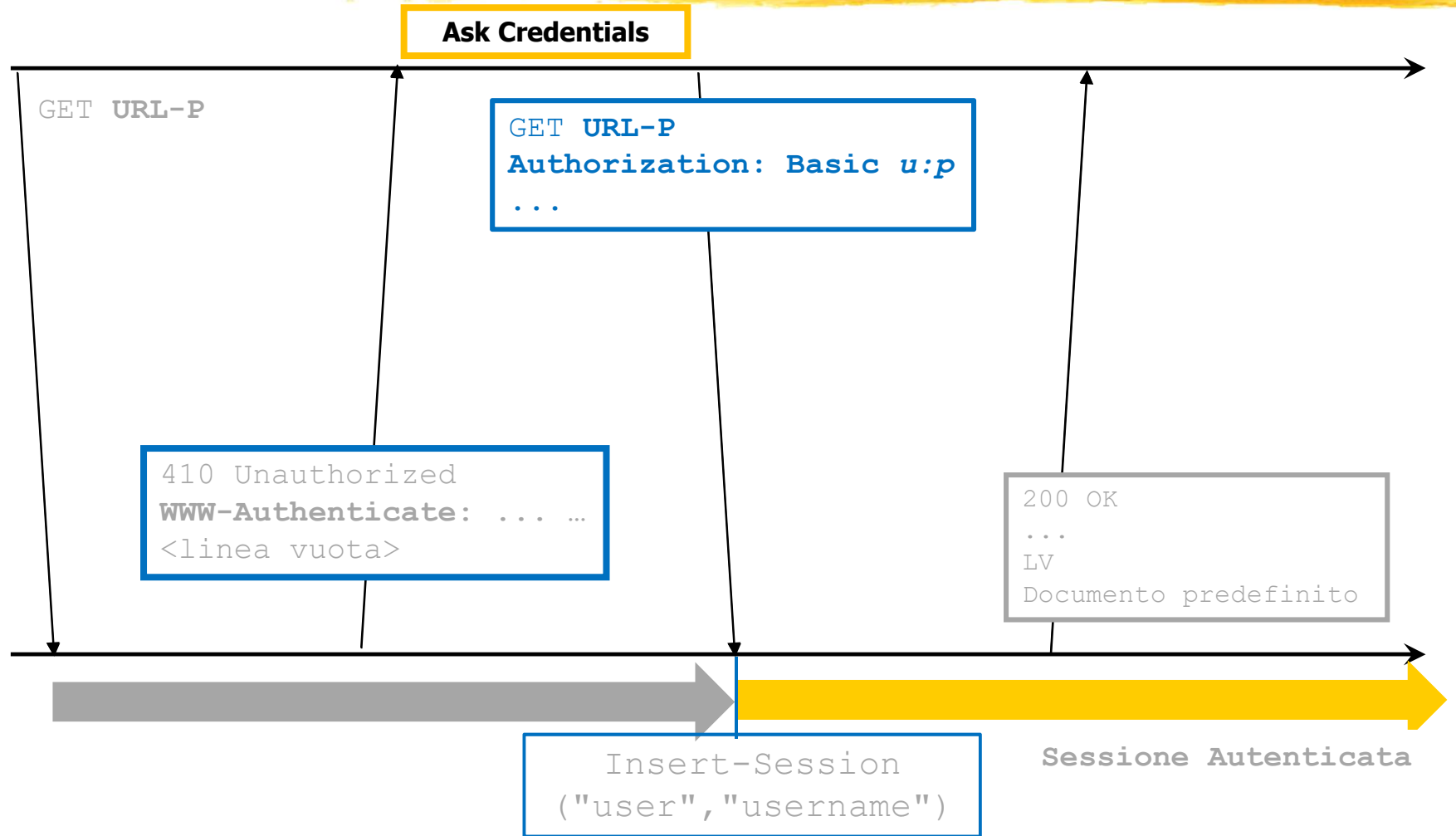
Browser

1. **Apri finestra** per chiedere `< username, password >`
2. Invia nuova HTTP Request **identica** alla precedente ma con header:
Authorization: `Basic username:password`
 - ❑ Credenziali codificate Base64
(Esempi su Cyberchef, Labs nel sito del corso)
 - ❑ "Codifica": **non** è una "protezione"

Finestra generata dal
Browser



Basic Authentication (II)



Esempio (I-a)

request

```
31 captured)
Ethernet II
Internet Protocol, Src Addr: MANOLETE1.ds.units.it (140.105.50.27), Dst Addr: 140.105.48.1
Transmission Control Protocol
Hypertext Transfer Protocol
GET /~bartolia/Mio/index.html HTTP/1.1\r\n
User-Agent: Mozilla/4.0 (compatible; MSIE 5.0; windows NT 5.0) opera 5.02 [en]\r\n
Host: uts.univ.trieste.it\r\n
Accept: text/html, image/png, image/jpeg, image/gif, image/x-xbitmap, */*\r\n
Accept-Language: en\r\n
Accept-Encoding: deflate, gzip, x-gzip, identity, */q=0\r\n
Referer: http://uts.univ.trieste.it/~bartolia/\r\n
Connection: Keep-Alive, TE\r\n
TE: deflate, gzip, chunked, identity, trailers\r\n
\r\n
```

response

```
Frame 9 (845 on wire, 845 captured)
Ethernet II
Internet Protocol, Src Addr: 140.105.48.1 (140.105.48.1), Dst Addr: MANOLETE1.ds.units.it (140.105.50.27)
Transmission Control Protocol
Hypertext Transfer Protocol
HTTP/1.1 401 Authorization Required\r\n
Date: Tue, 12 Mar 2002 13:28:08 GMT\r\n
Server: Apache/1.3.6 (Unix)\r\n
WWW-Authenticate: Basic realm="Area Riservata"\r\n
Keep-Alive: timeout=15, max=100\r\n
Connection: Keep-Alive\r\n
Transfer-Encoding: chunked\r\n
Content-Type: text/html\r\n
\r\n
data (528 bytes)
```

<https://bartoli.inginf.units.it>

17/10/2024

124

Esempio (I-b)

request

```
⊞ Frame 64 (528 on wire, 528 captured)
⊞ Ethernet II
⊞ Internet Protocol, Src Addr: MANOLETE1.ds.units.it (140.105.50.27), Dst Addr: 140.105.48.1 (140.105.48.1)
⊞ Transmission Control Protocol
⊞ Hypertext Transfer Protocol
  GET /~bartolia/Mio/index.html HTTP/1.1\r\n
  User-Agent: Mozilla/4.0 (compatible; MSIE 5.0; windows NT 5.0) opera 5.02 [en]\r\n
  Host: uts.univ.trieste.it\r\n
  Accept: text/html, image/png, image/jpeg, image/gif, image/x-xbitmap, */*\r\n
  Accept-Language: en\r\n
  Accept-Encoding: deflate, gzip, x-gzip, identity, */*\r\n
  Authorization: Basic [REDACTED]\r\n
  Referer: http://uts.univ.trieste.it/~bartolia/\r\n
  Connection: Keep-Alive, TE\r\n
  TE: deflate, gzip, chunked, identity, trailers\r\n
  \r\n
```

- ❑ Credenziali in Base64
- ❑ Quindi sono "in chiaro" (decodificabili da chiunque)

Login: FORM vs BASIC



FORM

1. GET URL-P in sessione non autenticata
2. HTTP Response che "sollecita autenticazione" ("**pagina login**")
3. **POST URL-VALIDATION** con credenziali
4. HTTP Response con documento dinamico **personalizzato**

BASIC

1. GET URL-P in sessione non autenticata
2. HTTP Response che "sollecita autenticazione" ("~~pagina login~~")
3. **GET URL-P** con credenziali
4. HTTP Response con documento dinamico **personalizzato**

Osservazione (I)



❑ Browser ~~non~~ **sa** che si sta autenticando

❑ ~~Non~~ usa funzionalità HTTP “per l’autenticazione”

Osservazione (II-a)

401 Unauthorized

Content-Type: text/html

Content-Length: 2438

...

L.V.

documento HTML di errore

❑ Significato ≈ Non sei **autenticato**

❑ Reason Phrase ≈ Non sei **autorizzato**

❑ Concetti **molto diversi**: può confondere le idee...

Osservazione (II-b)



- ❑ Header Basic Authentication: nomi scelti in modo **molto discutibile**
 - ❑ WWW-Authenticate
 - ❑ Authorization
- ❑ Usati per risolvere il problema della autenticazione
- ❑ Ma fanno pensare **anche** al problema **completamente diverso** della autorizzazione
 - ❑ Authentication: Chi è?
 - ❑ Authorization: Ha il diritto di fare ciò che ha chiesto?

Dettaglio: Se "cambio realm"?



Domanda

- ❑ Browser autenticato per Realm1 FORM
- ❑ Richiede URL di Realm2 BASIC (o viceversa)

Realm Name	Resources	ACL	Protocol
Esami	/esami/*	alberto marco ruud	FORM
Documenti	*.pdf	alberto ricky andry	BASIC
Config	/admin/*	admin	FORM

Deve autenticarsi nuovamente?



Risposta: Nella realtà



- ❑ Protocolli di autenticazione diversi possono richiedere prove di identità più o meno "forti"
 - ❑ Username-Password
 - ❑ Username-Password + Click sul cellulare
 - ❑ Username-Password + Token generato da dispositivo
 - ❑ Username-Password + Smartcard
 - ❑ ...

- ❑ SE Realm2 richiede autenticazione con prova "più forte" di Realm1
- ❑ ALLORA Browser autenticato per Realm1 deve autenticarsi nuovamente per Realm2

Risposta: Per noi

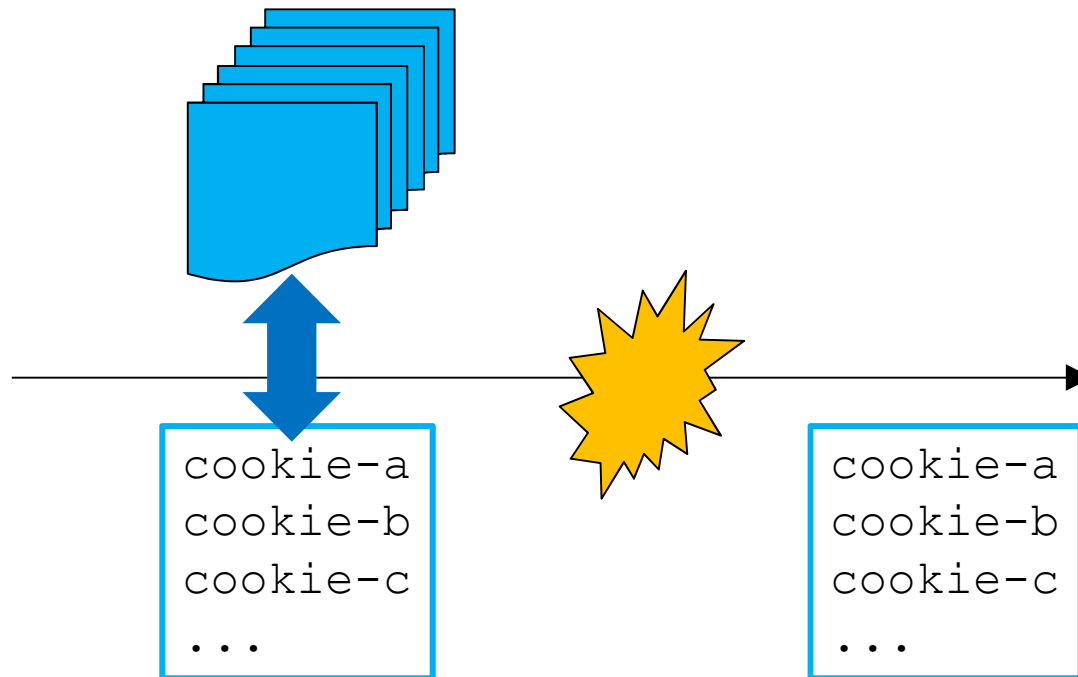


- ❑ I nostri protocolli di autenticazione usano tutti la stessa prova di identità
- ❑ Quindi ci si autentica **solo una volta**

Navigare in "Incognito"



Cookie Table (REMIND)

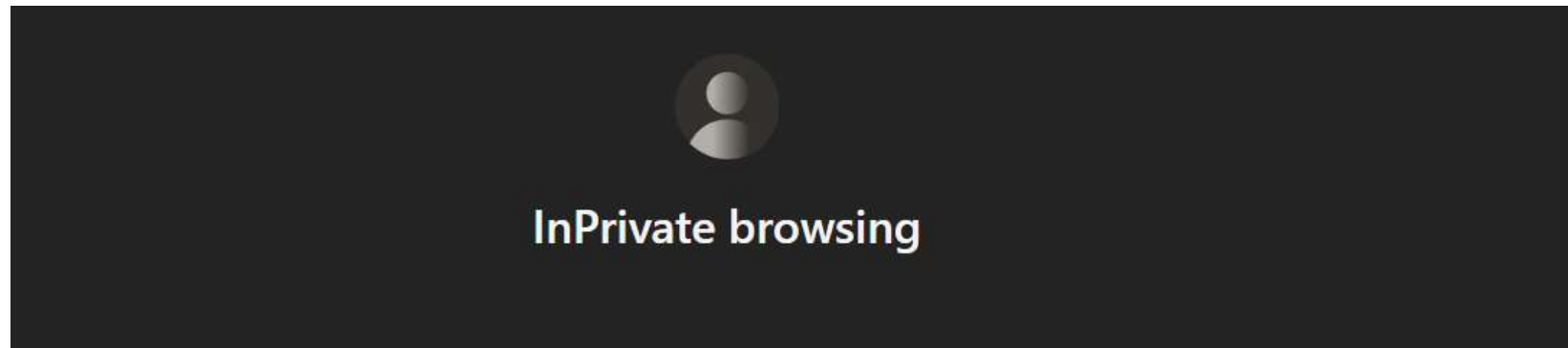


1. **Condivisa** tra tutti i tab
2. **Persistente**
(sopravvive a chiusura del browser / shutdown)

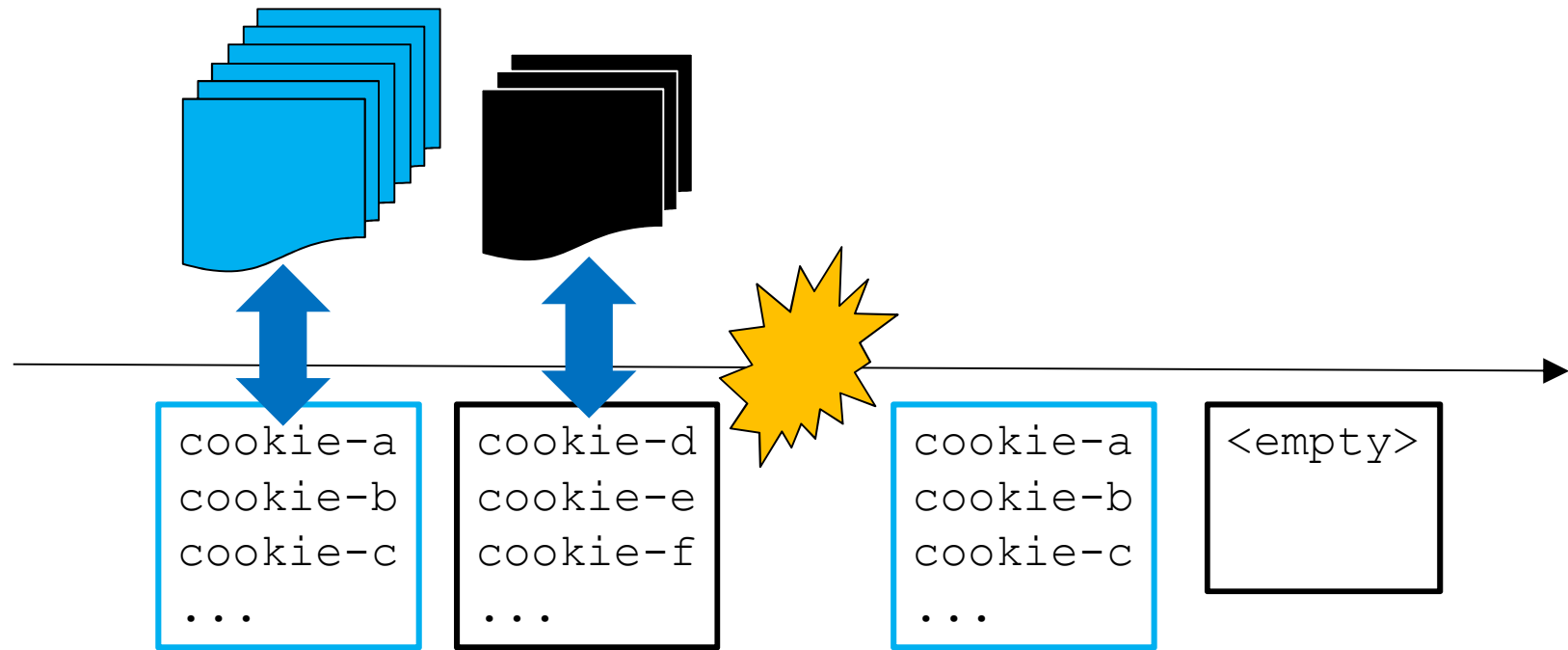
Terminologia

- ❑ Browser diversi usano terminologia diversa
- ❑ Funzionalità identica

- ❑ Finestra
 - ❑ Incognito
 - ❑ Privata
 - ❑ Anonima



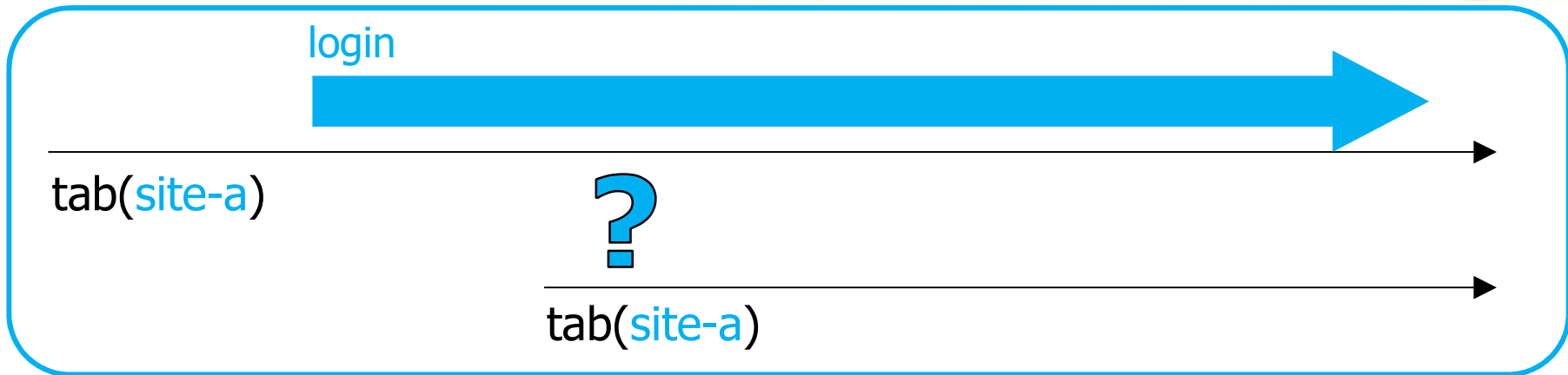
Incognito browsing



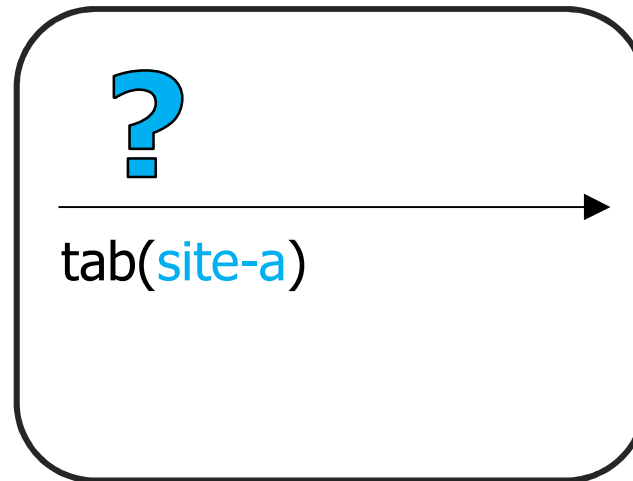
1. **Non condivisa** con i tab della finestra "normale"
2. **Non Persistente**

≈ **"Browser separato, usa e getta"**

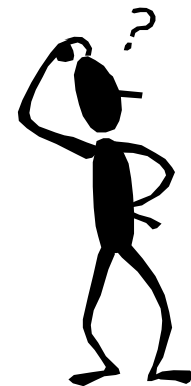
Esempio (I-a)



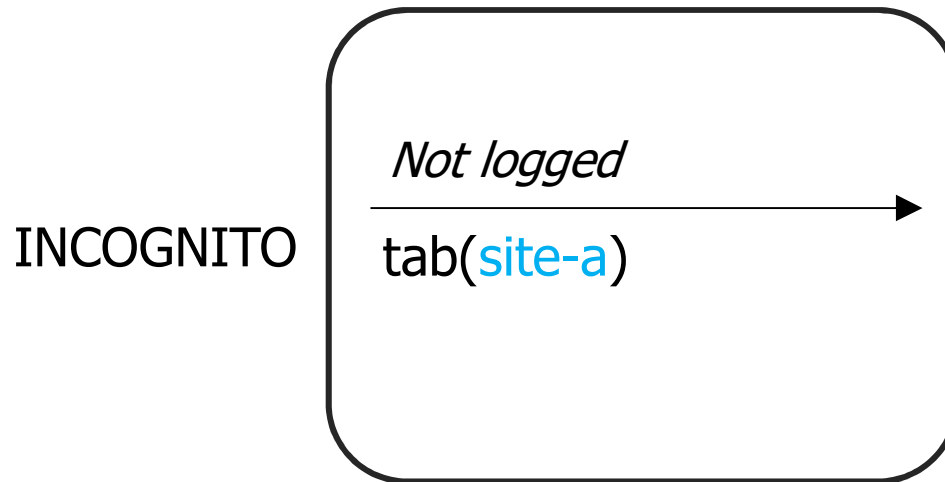
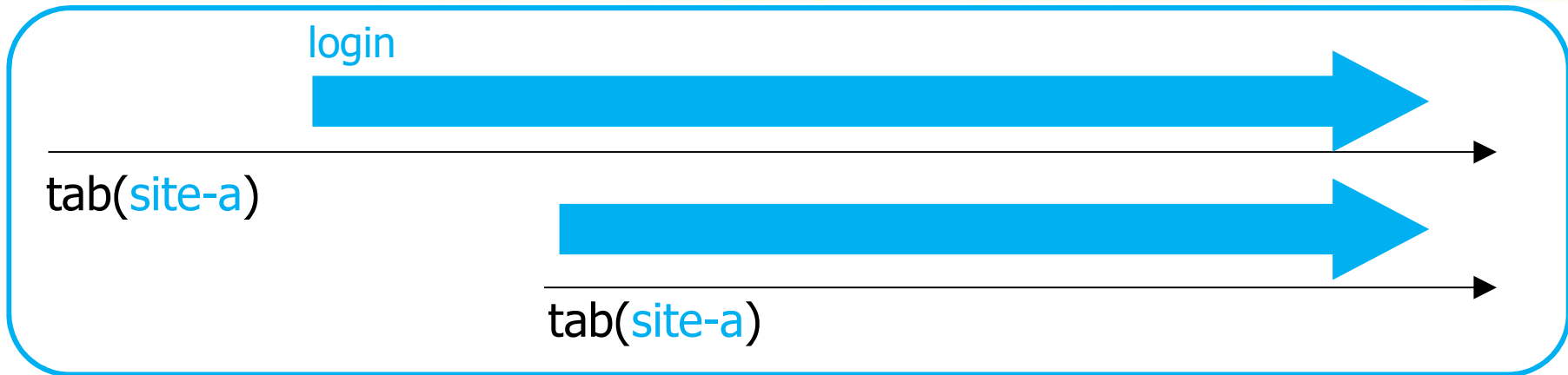
INCOGNITO



Logged on site-a?



Esempio (I-b)



Esempio (II-a)

?

tab(site-b)

INCOGNITO

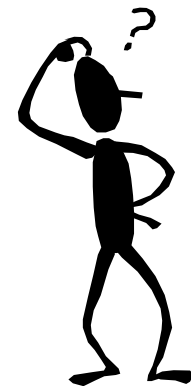
login

tab(site-b)

?

tab(site-b)

Logged on site-b?



Esempio (II-a)

Not logged

tab(site-b)

INCOGNITO

login

tab(site-b)

tab(site-b)

Problema importante

- ❑ Desidero fare operazioni su Internet "senza lasciare tracce"
- ❑ ...uso la navigazione "**in incognito / privata / anonima**"
- ❑ Risolve il mio problema?



Domanda banale 1



1. Apro finestra in incognito / privata / anonima
2. Mi autentico su Google con `username-1`
3. ...
4. Google search "`search term`"
5. ...

□ Google sa che `username-1` ha cercato "`search term`"?

Domanda banale 2



1. Apro finestra in incognito / privata / anonima
2. Mi autentico su Facebook con `username-2`
3. ...
4. Visito pagina P con bottone Facebook like e premo like
5. ...

☐ Facebook sa che `username-2` ha visitato P ed ha premuto like?

Domanda banale 3



1. Apro finestra in incognito / privata / anonima
2. Visito `somesite`
3. ...

☐ Il mio name server sa che mi sono collegato con `somesite`?

Importantissimo



- ❑ "Incognito / privato / anonimo" è fuorviante
- ❑ Significa **solo** "cancella la history della navigazione"

Your activity might still be visible to:

- Websites you visit
- Your employer or school
- Your internet service provider

Curiosità...



- ❑ Desidero fare operazioni su Internet "senza lasciare tracce"
- ❑ Occorrerebbe definire con precisione:
 1. Tipologia di tracce che vogliamo evitare
 2. Capacità di chi desidera ricostruire la nostra attività
 - ❑ Stalker
 - ❑ Polizia
 - ❑ Intelligence Service
 - ❑ ...
- ❑ Tecnologie che **non** vediamo: VPN, Tor

Analytics



Obiettivo



- ❑ Web site W desidera **contare gli accessi**
- ❑ Conteggio con granularità di **pagina** (invece che complessivo)

- ❑ Conteggio realizzato da **un altro** web site A
(A offre un servizio ai web site di altre organizzazioni)

- ❑ Motivazione
 - ❑ Necessità del conteggio è ovvia
 - ❑ Meglio usare un servizio **specializzato**
 - ❑ Raccoglie molte informazioni sugli accessi
 - ❑ Facilita analisi dei dati

Esempio:

A = Google Analytics



Pageviews

2,686



Molte altre informazioni

Analisi di:

- ❑ Header HTTP Request
- ❑ Indirizzo IP lato Client
- ❑ ...

Demographics

Language

Country/Territory

City

System

Browser

Operating System

Service Provider

Mobile

Operating System

Service Provider

Screen Resolution

Language

	Visits	% Visits
1. it	395	48.83%
2. it-it	252	31.15%
3. en-us	111	13.72%
4. en-gb	13	1.61%
5. fr	9	1.11%
6. hr	6	0.74%
7. pt-br	6	0.74%
8. en	5	0.62%
9. nl	2	0.25%
10. (not set)	1	0.12%

[view full](#)

Esempio di Implementazione (I)

- ❑ A assegna un codice univoco **wid** ad ogni web site servito
- ❑ W inserisce in ogni sua pagina un IFRAME microscopico:
`<IFRAME src="http://A/?id=wid" height=1 width=1>`



1. Browser invia HTTP Request a W `http://w.com/p`
2. Browser invia **automaticamente** un'altra HTTP Request ad A:

`GET /?id=wid`

`...`

`Referer: http://w/p`

`...`

⇒ A può contare gli accessi su W (**wid**) con granularità di pagina (**p**)

Esempio di Implementazione (II-a)

W1



```
<IFRAME src="http://A?id=wid1"...>
```

W2



```
<IFRAME src="http://A?id=wid2"...>
```

W3

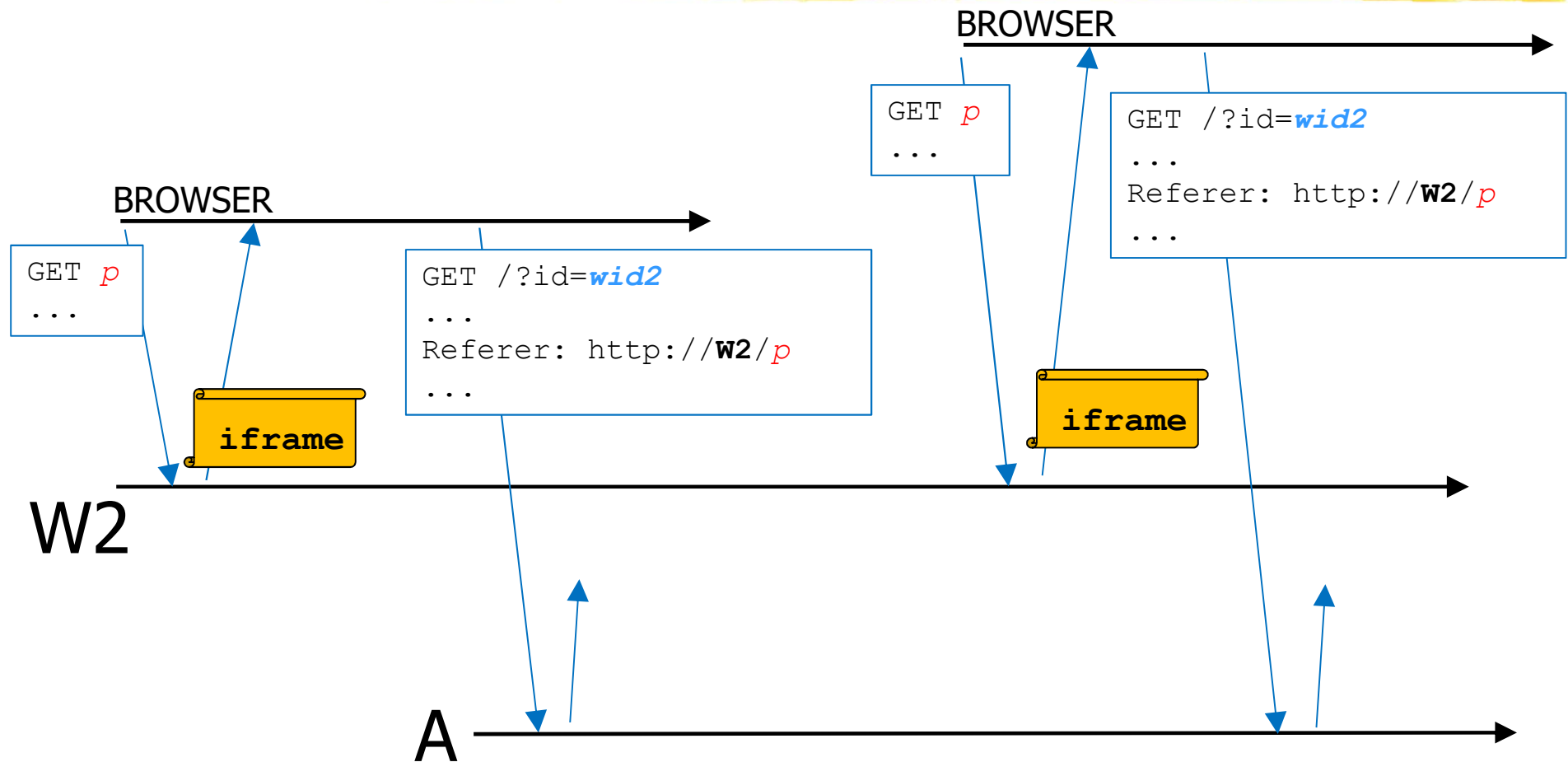


```
<IFRAME src="http://A?id=wid3"...>
```

A



Esempio di Implementazione (II-b)



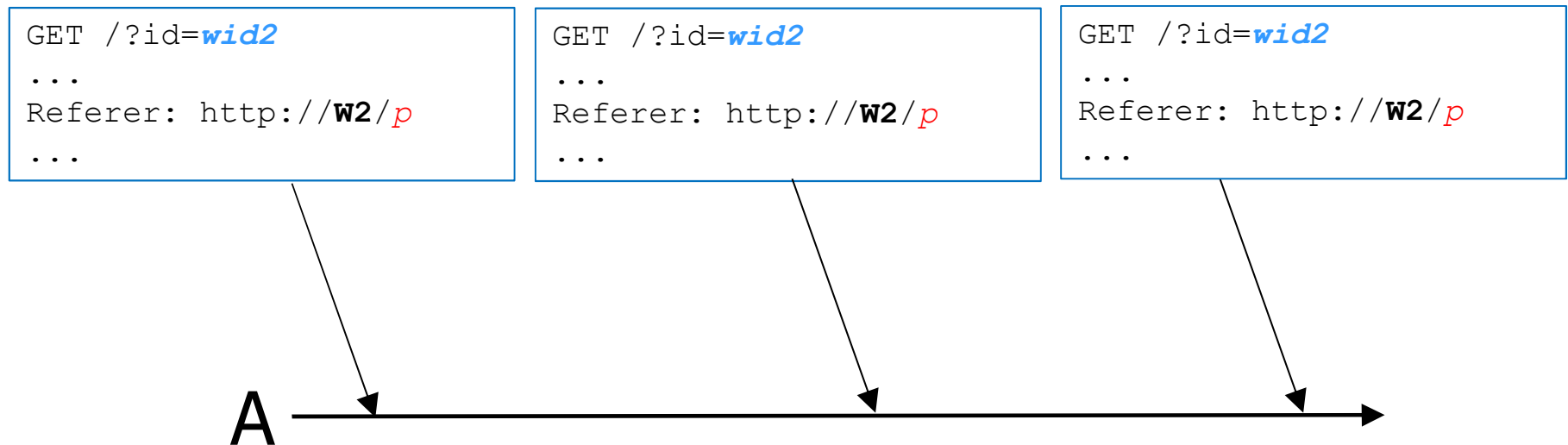
Osservazione 1

- ❑ A assegna un codice univoco **wid** ad ogni web site servito
- ❑ In linea di principio sarebbe **inutile**
(Referer contiene URL **completo**)
- ❑ In pratica è presente perché semplifica implementazione A

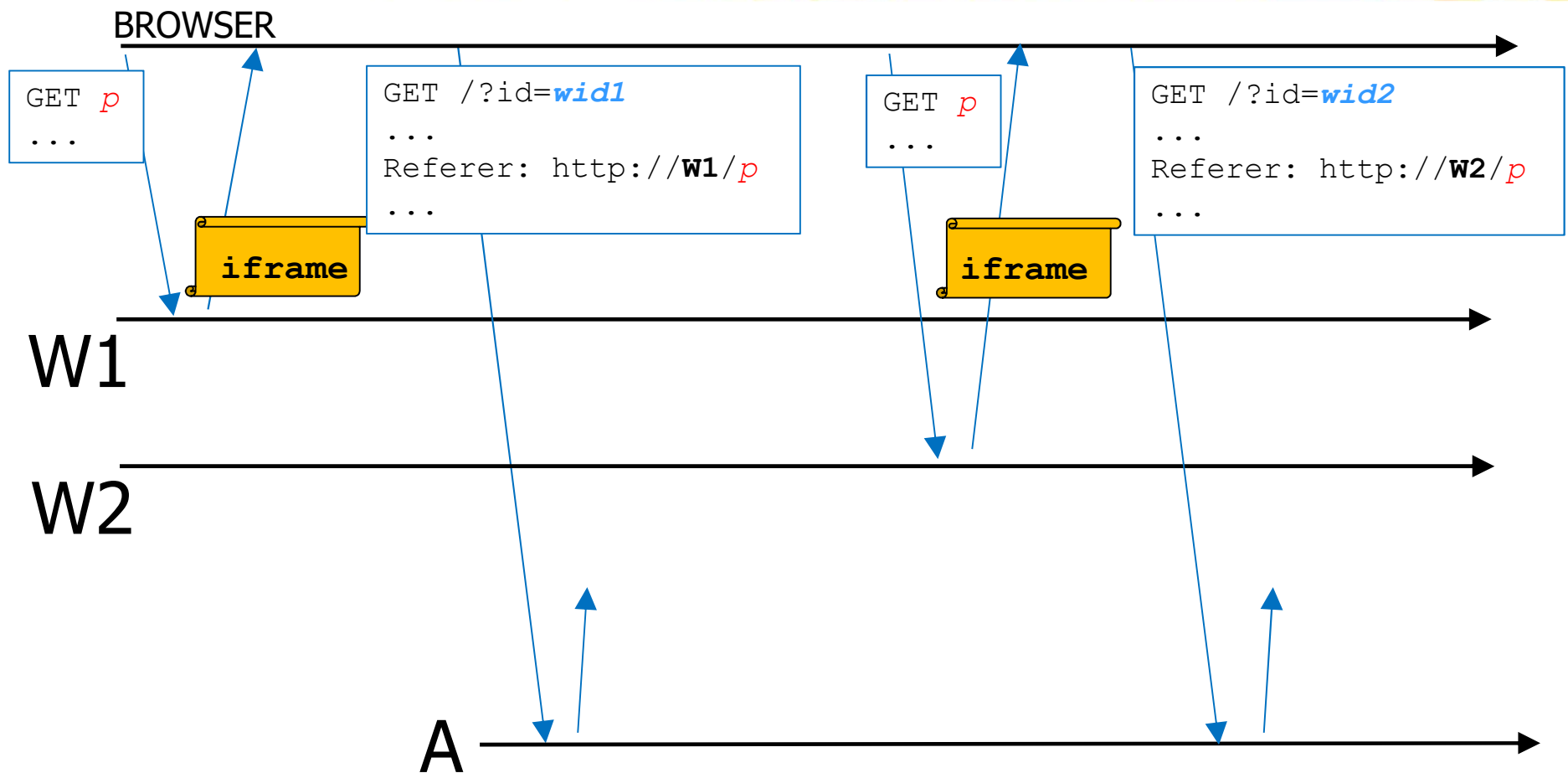


Osservazione 2

- ❑ Conta le **visite**
- ❑ **Non** ha informazioni per contare i **browser**



Esempio di Implementazione (III)



Molte altre possibilità

Requisito:

- ❑ Browser carica pagina P
- ❑ Browser deve inviare **automaticamente** HTTP Request ad A

Implementazione:

- ❑ P forza prelievo di `IFRAME` "molto piccolo" da A
 - ❑ P forza prelievo di `IMG` "molto piccola" da A
 - ❑ P forza prelievo di `IFRAME/IMG` **invisibile** da A (`display:none`)
 - ❑ P contiene **Javascript** che invia HTTP Request ad A
 - ❑ ...
-
- ❑ Sistemi di sviluppo web semplificano inserimento **automatico** in **tutte** le pagine di un sito

Caso (ahimè) frequente

W



```
<IFRAME src="http://A1/?id=a1id-w"...>  
<IFRAME src="http://A2/?id=a2id-w "...>  
<IFRAME src="http://A3/?id=a3id-w "...>
```

A1



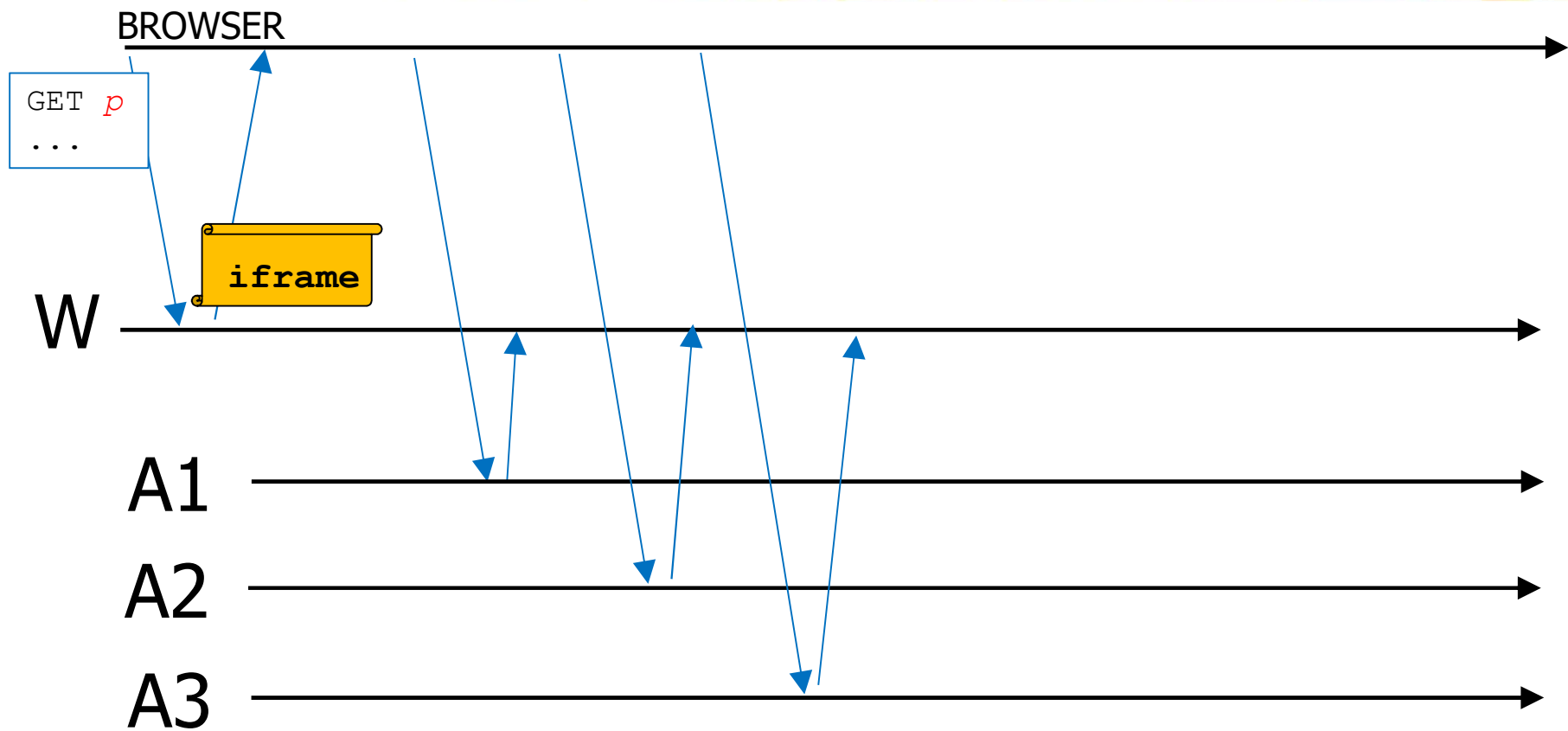
A2



A3

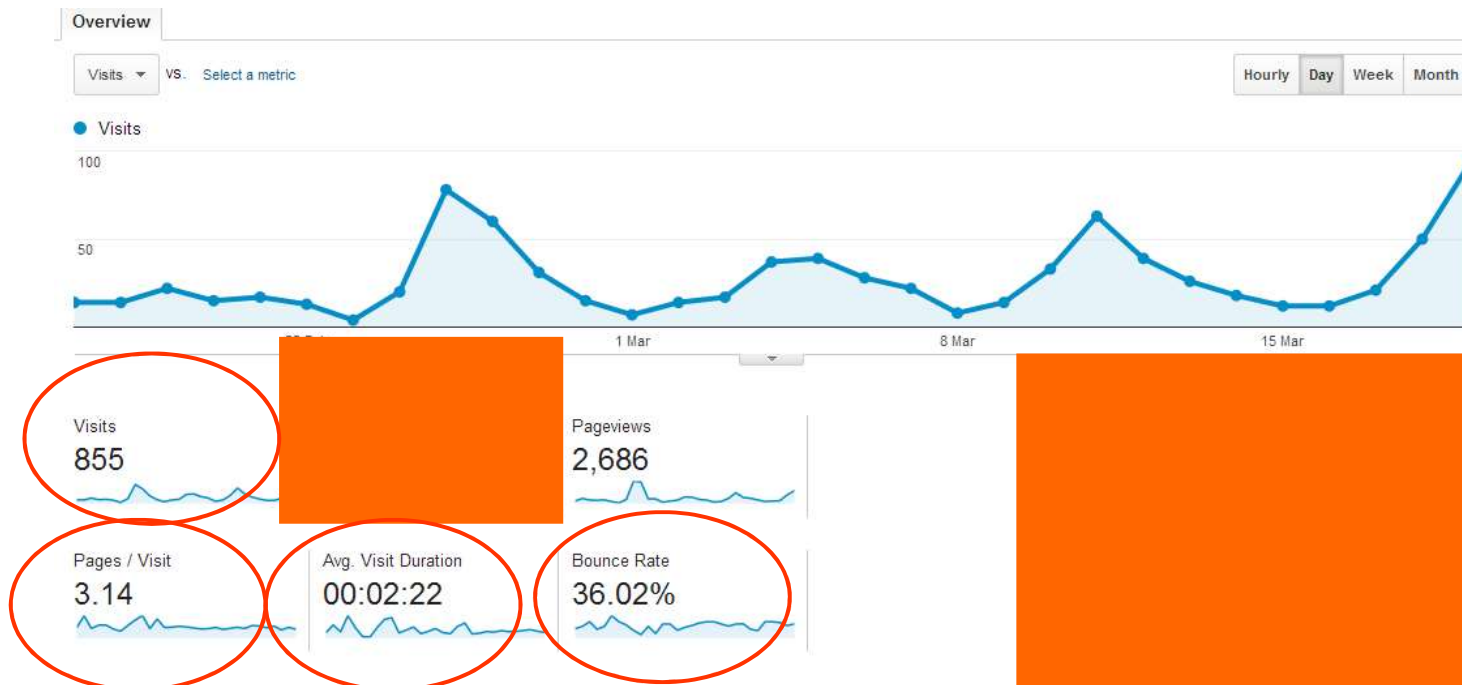


Esempio



Obiettivo aumentato (I)

- ❑ A desidera anche:
 - ❑ Contare il numero di **browser**
 - ❑ Raccogliere la **sequenza di pagine** visitate da ogni browser

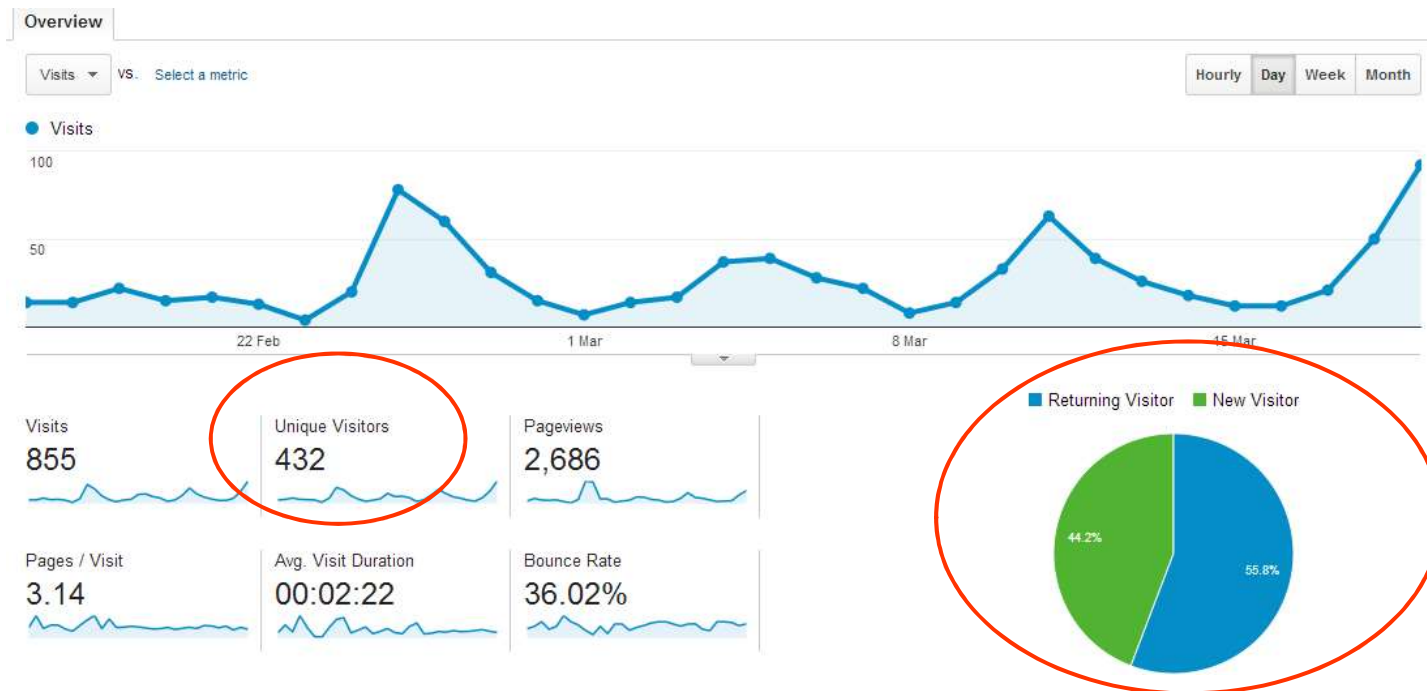


Obiettivo aumentato (II)

☐ A desidera anche:

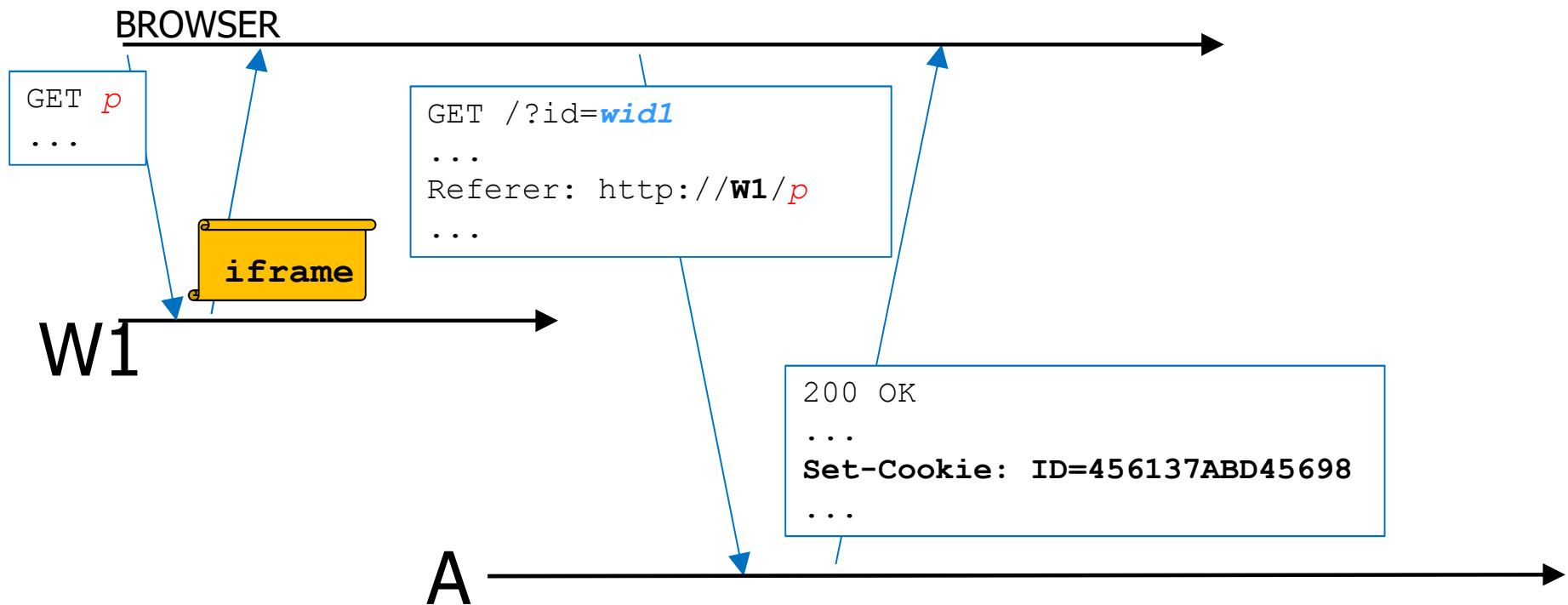
☐ ...

☐ Contare il numero di browser **che tornano più volte**



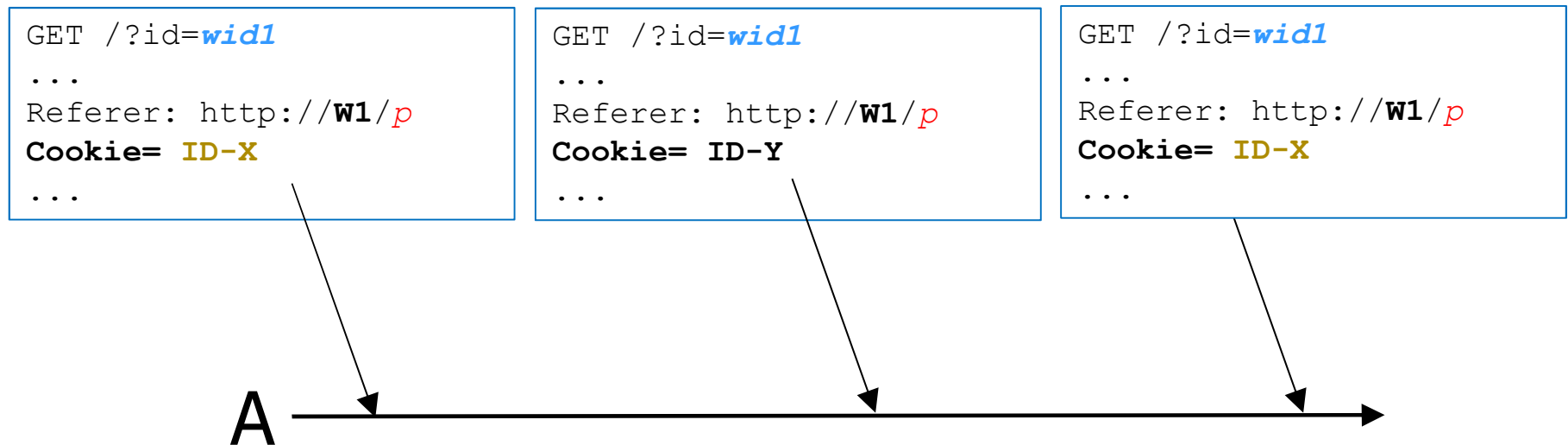
Implementazione (I)

- ❑ A mantiene una **sessione** per ogni accesso ad A
- ❑ Scadenza del Cookie: "lunghissima"



Implementazione (II)

□ Conta anche i **browser**

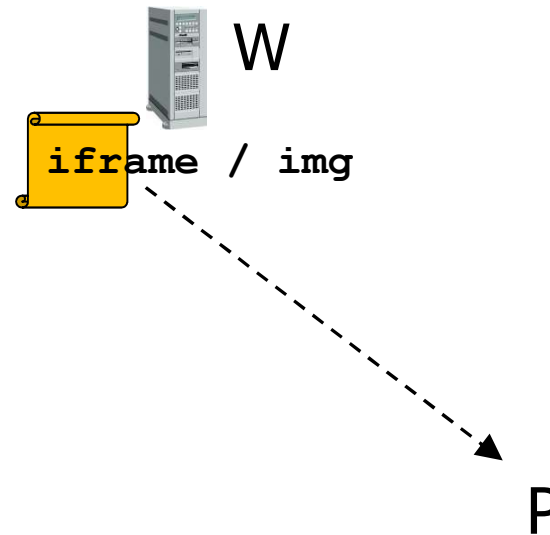


Third-party cookies



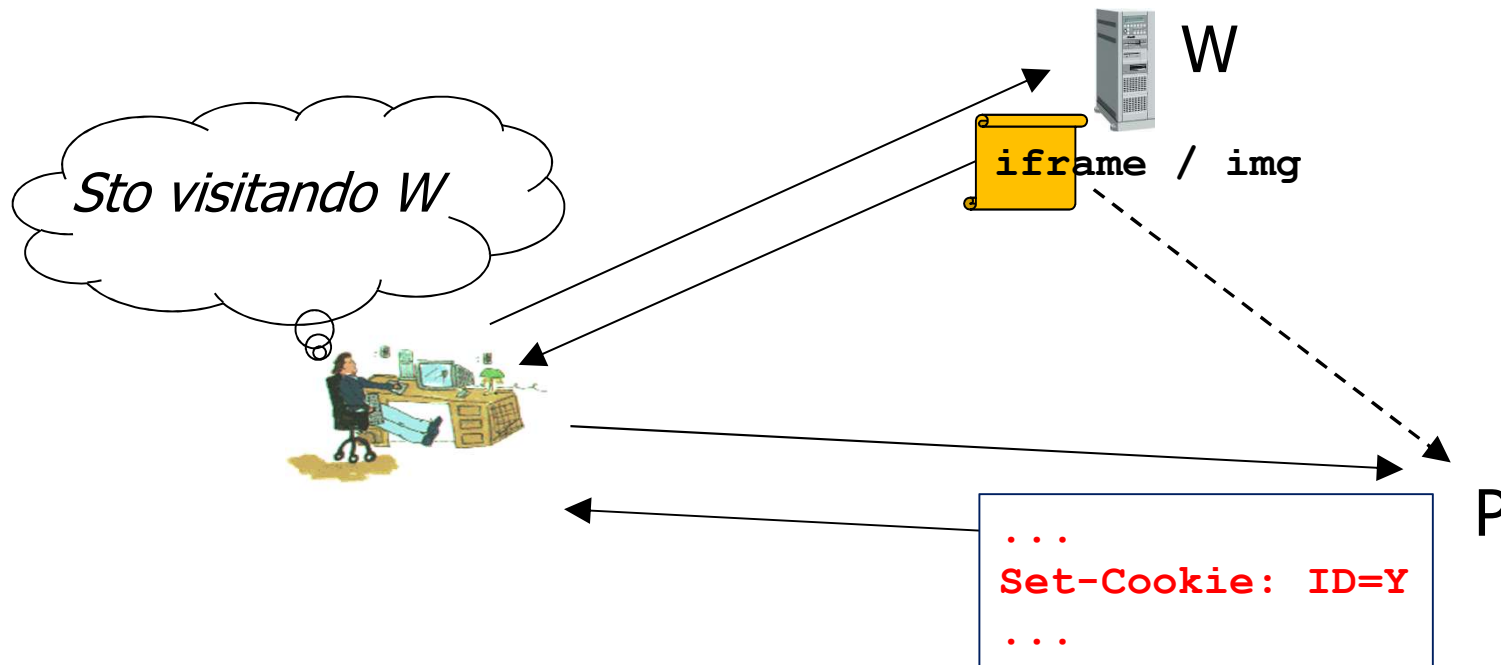
Scenario Comunissimo

- ❑ W ha contenuti su P
- ❑ Definiti in modo da essere prelevati **automaticamente** dal Browser



Third party cookies

- ❑ Utente **crede** di visitare W ma visita **anche** P
- ❑ P può creare un cookie (**third party** cookie)



Motivo



☐ Analytics

- ☐ W delega a P conteggio e categorizzazione degli accessi
- ☐ W utilizzerà queste informazioni internamente

☐ Tracking

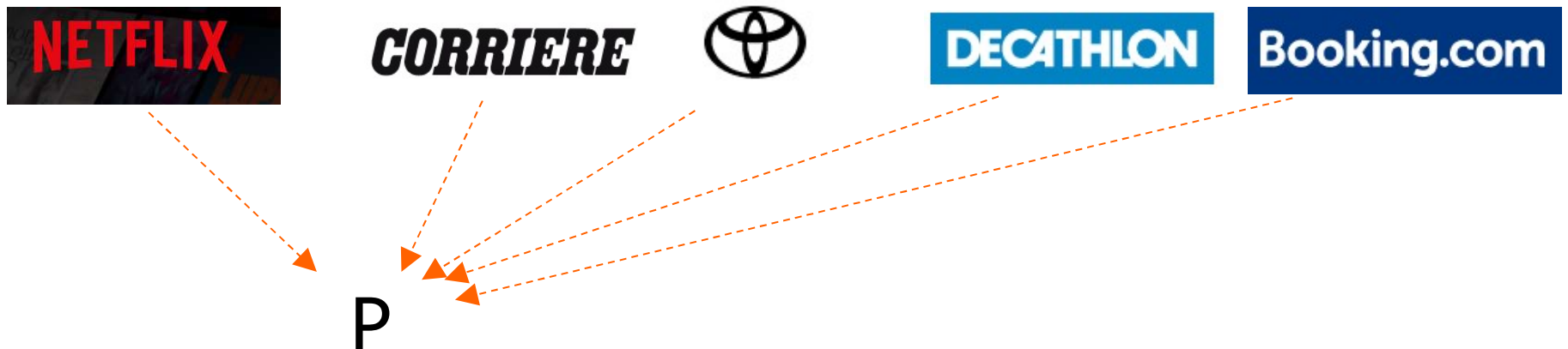
- ☐ W permette a P di **tracciare gli accessi** (in cambio di denaro)
- ☐ P venderà queste informazioni ad altre organizzazioni interessate a creare "profili" di Browser@Device

☐ Tracking **enormemente** diffuso

- ☐ Esistono moltissime organizzazioni P
- ☐ Ogni W ha tipicamente molti P

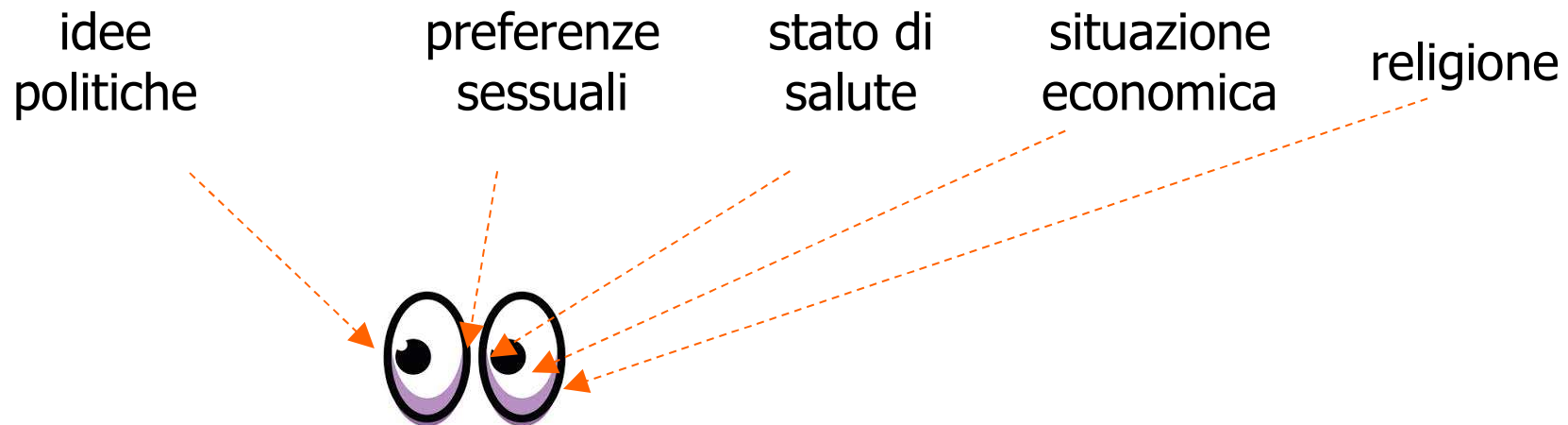
Nota bene (I)

- ❑ **Cookie è associato ad P (non al sito web visitato)**
- ❑ P presente su **molti** web site ⇒
 - ❑ P riconosce "**ogni**" Browser@Device



Nota bene (II)

- P presente su **molti** web site ⇒
 - P riconosce "**ogni**" Browser@Device
 - **P osserva la navigazione** di "**ogni**" Browser@Device



Hmmm...

CDC Centers for Disease Control and Prevention
CDC 24/7: Saving Lives, Protecting People™

HIV/AIDS



Informativa GDPR

- ❑ W europei devono **informare** di ogni third-party cookie a cui forzano i propri utenti
 - ❑ Finalità chiare (?)
 - ❑ Consenso consapevole (?)
 - ❑ ...

Informativa

Noi e terze parti selezionate utilizziamo cookie o tecnologie simili per finalità tecniche e, con il tuo consenso, anche per "interazioni e funzionalità semplici", "miglioramento dell'esperienza", "misurazione" e "targeting e pubblicità" come specificato nella [cookie policy](#). Il rifiuto del consenso può rendere non disponibili le relative funzioni.

Puoi liberamente prestare, rifiutare o revocare il tuo consenso, in qualsiasi momento.

Usa il pulsante "Accetta" per acconsentire all'utilizzo di tali tecnologie. Usa il pulsante "Rifiuta" per continuare senza accettare.

Scopri di più e personalizza

Rifiuta

Accetta

Navigare su web

- ❑ **Ogni** W ospita **molti** third-party
- ❑ **Ogni** volta che visitiamo un **qualsiasi** W, **molti** P registrano la visita
- ❑ **Molti** third parties raccolgono **sistematicamente** navigazione di **"ogni"** Browser@Device
 - ❑ Andate a vedere i cookie nel vostro browser

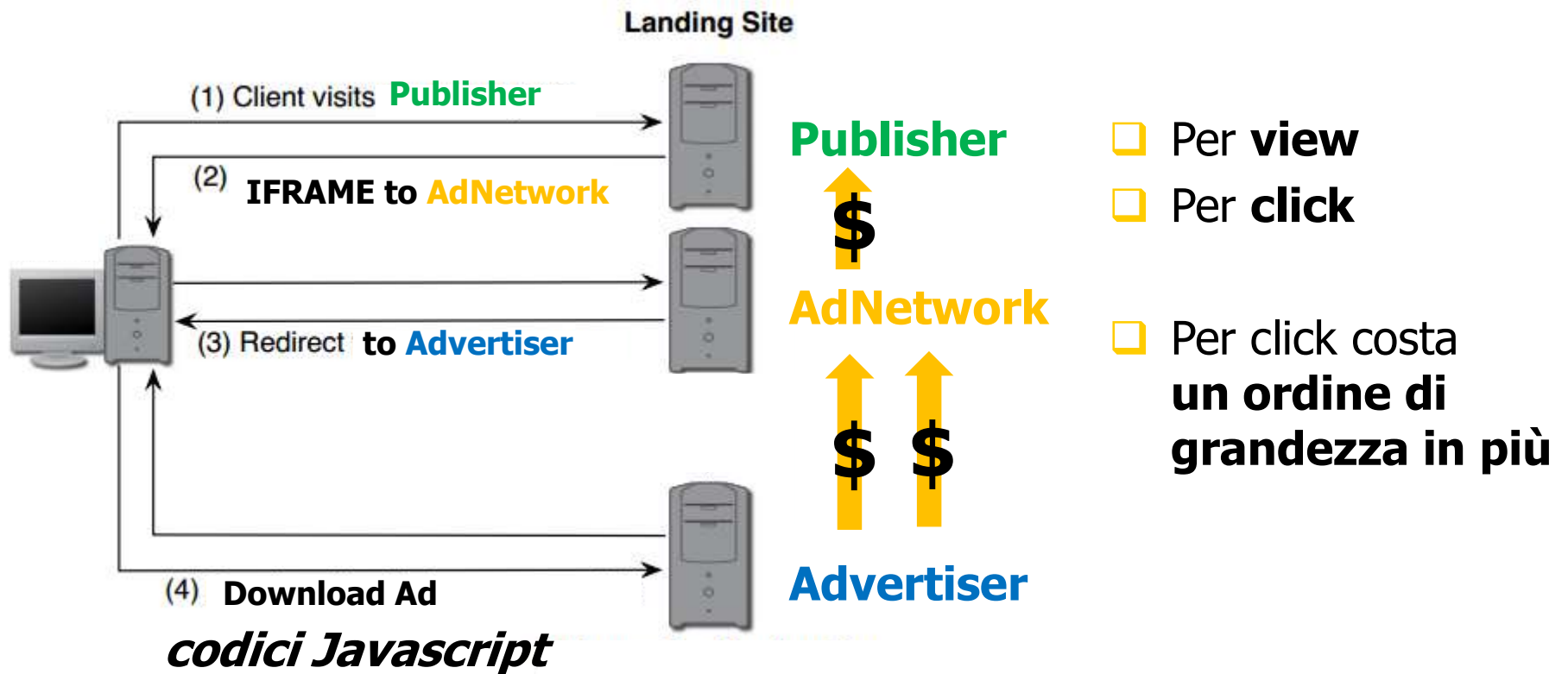


Web Advertisements

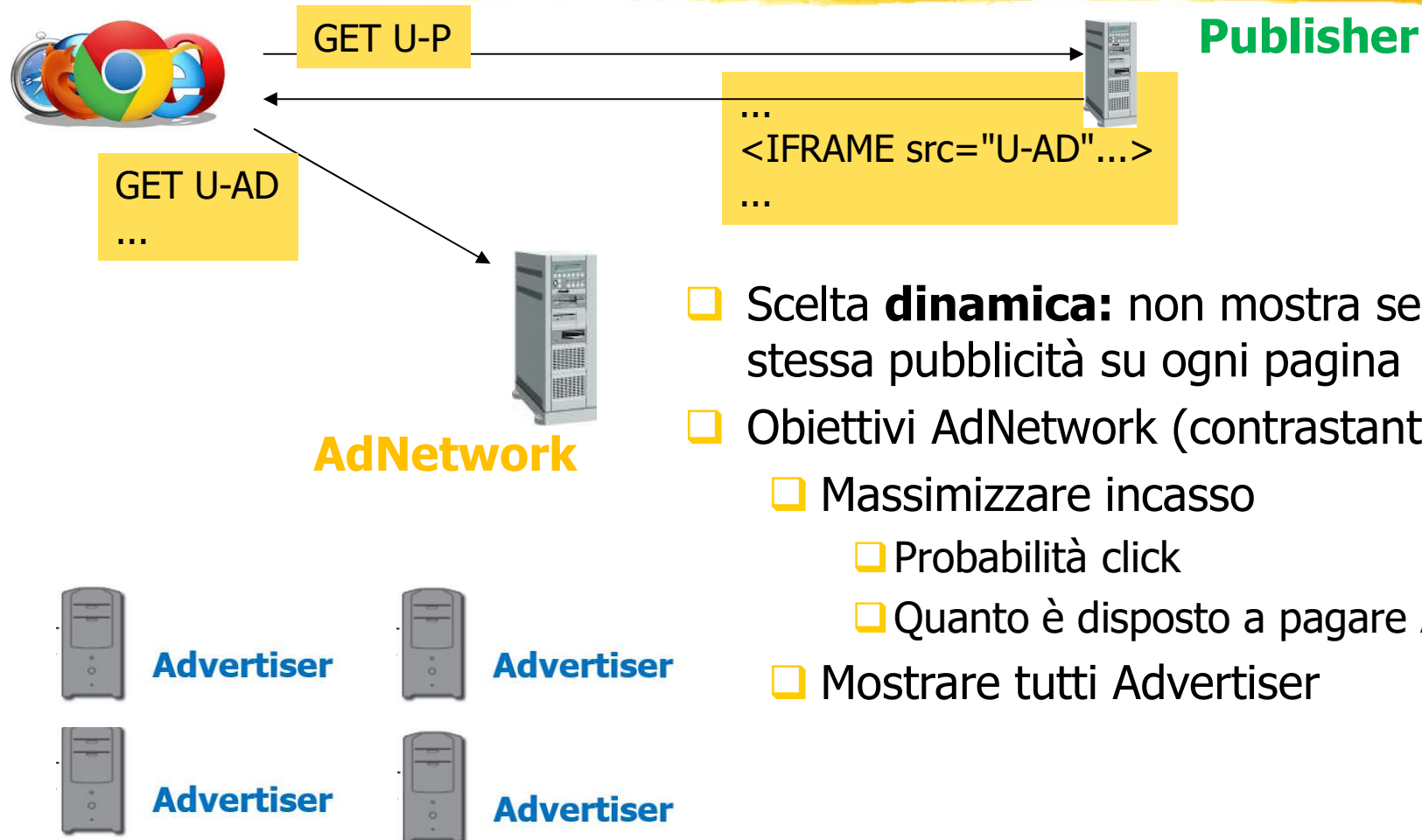
(cenni di cenni di cenni...)



Web Advertisements (I)

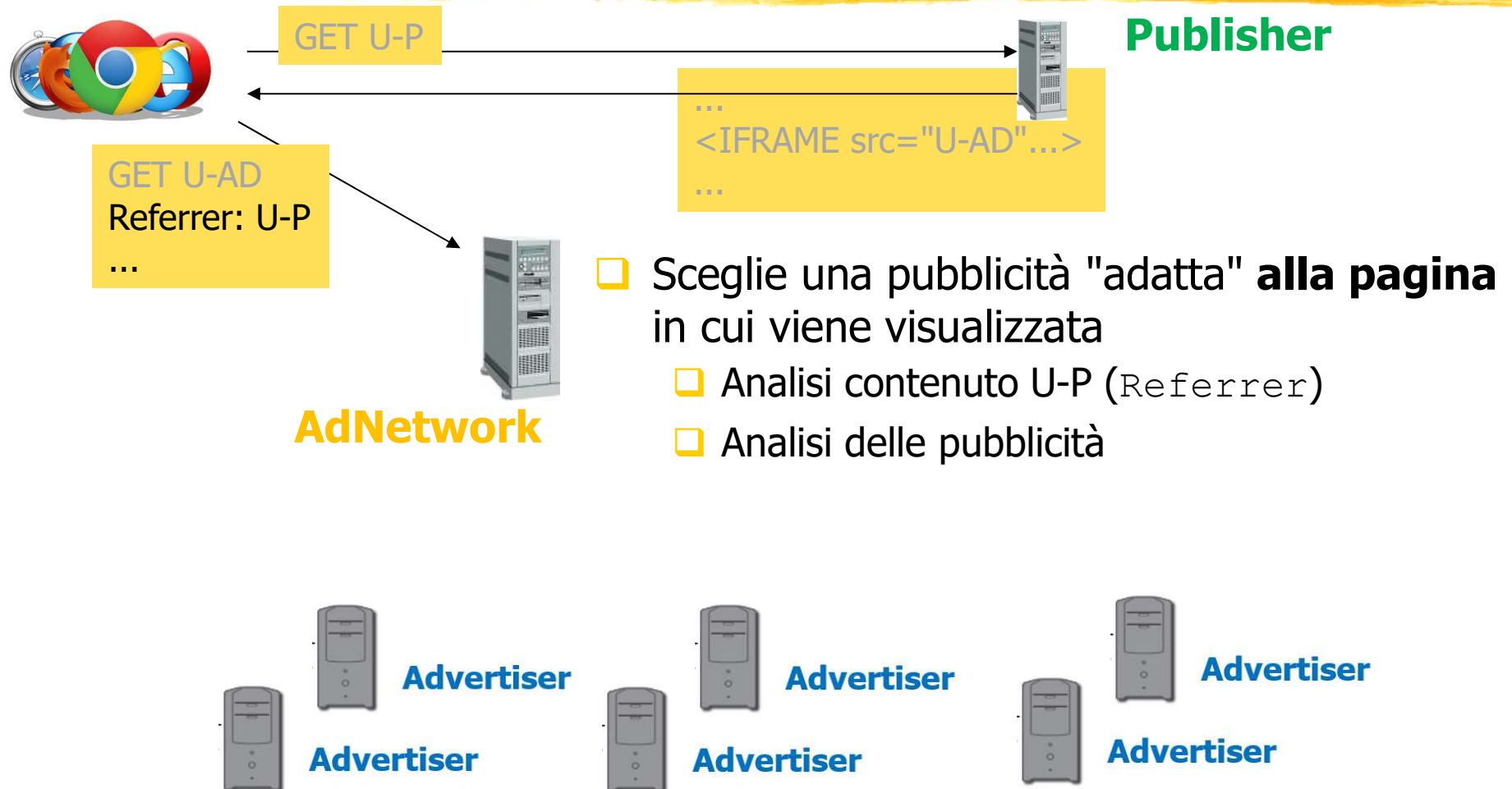


Web Advertisements (II)

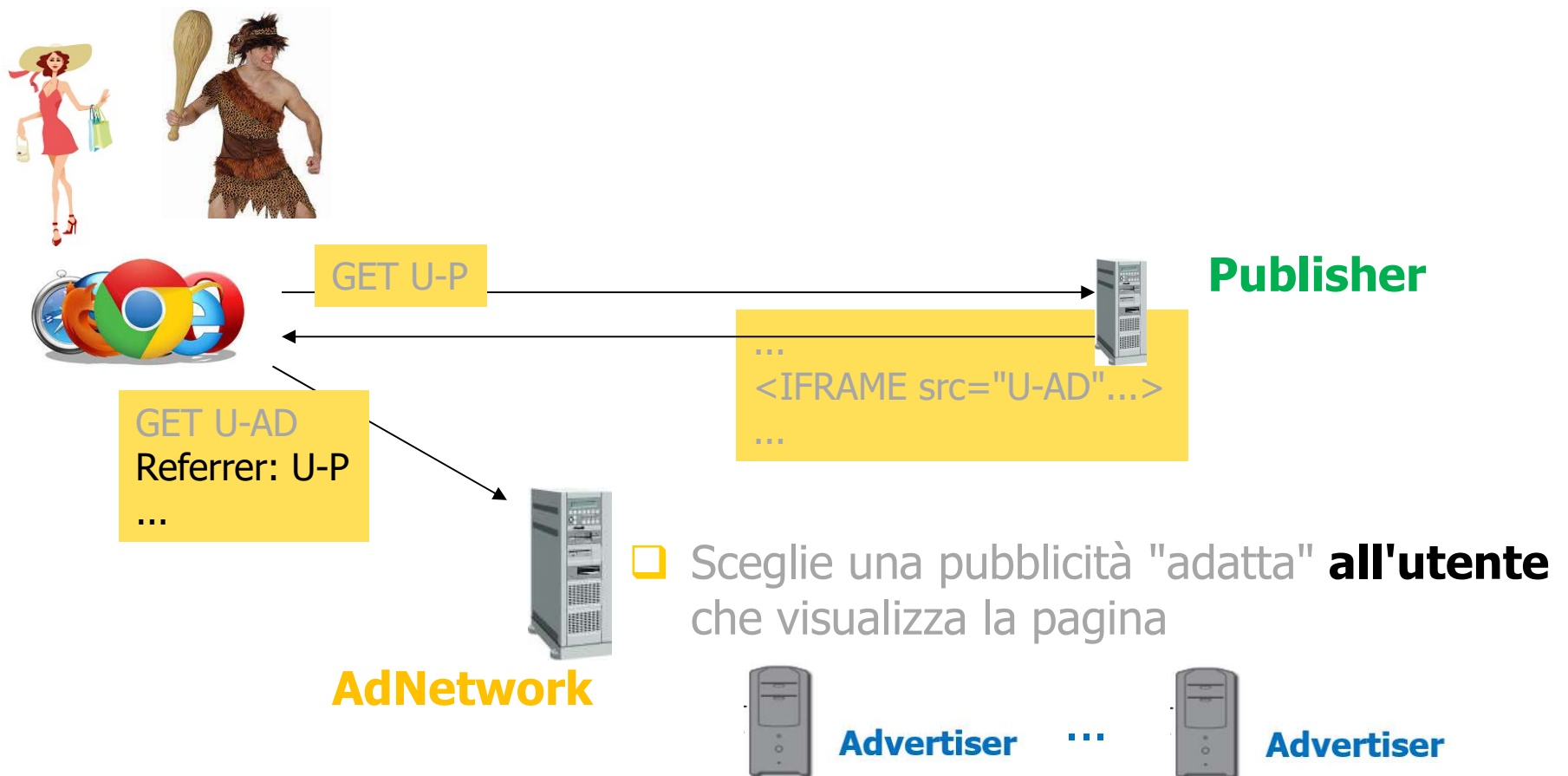


- ☐ Scelta **dinamica**: non mostra sempre la stessa pubblicità su ogni pagina
- ☐ Obiettivi AdNetwork (contrastanti):
 - ☐ Massimizzare incasso
 - ☐ Probabilità click
 - ☐ Quanto è disposto a pagare Advertiser
 - ☐ Mostrare tutti Advertiser

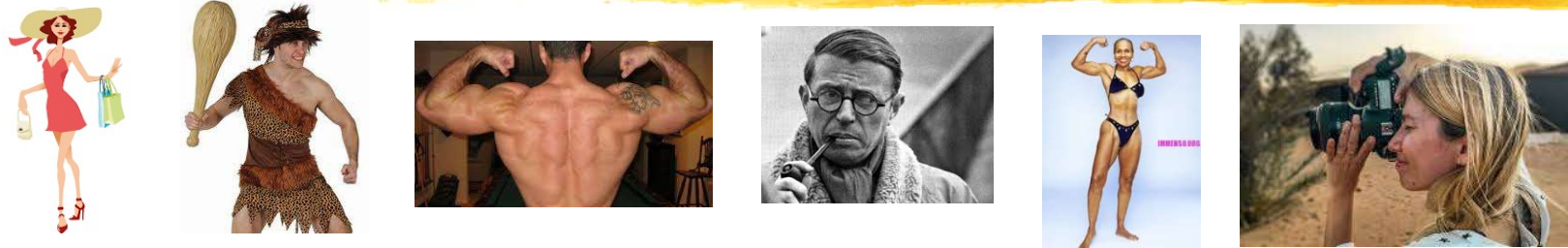
Contextual Advertising



Targeted Advertising (I)



Targeted Advertising (II)



- ❑ Scelta **dinamica** della pubblicità in base al **profilo dell'utente** a cui viene mostrata
- ❑ Sogno storico delle aziende, dei pubblicitari, dei politici...
- ❑ Oggi è realtà
- ❑ Implicazioni economiche, sociali, politiche, strategiche

ENORMI

Osservazione



- ❑ **Contextual** Advertising
- ❑ **Targeted** Advertising

- ❑ Estremamente complesse da realizzare
 - ❑ Algoritmo
 - ❑ Implementazione (deve essere scalabile e rapidissima)

- ❑ ~~Vediamo~~ vedevamo **solo**:
 1. **Quale informazione** si può usare
 2. Come si **raccoglie**
- ❑ **Non** come si **usa**

The Big Brother (I)



- ❑ Navigazione B@D: **Soldi** da pubblicità **targeted** per B@D
- ❑ Estendere insieme di W
⇒ Targeting migliore ⇒ Più soldi
- ❑ Riconoscere navigazioni di stesso B@D raccolti da P diversi (Cookie syncing)
⇒ Targeting migliore ⇒ Più soldi
- ❑ Riconoscere devices di uno stesso Utente (Device linking)
⇒ fusione più profili $B1@D1, \dots, BK@DK$
⇒ Targeting migliore ⇒ Più soldi

The Big Brother (II)



- ❑ Raccogliere informazione su Device owner
aggiuntiva rispetto alla navigazione

- ❑ Domande a motore di ricerca
- ❑ Argomento di post / tweet
- ❑ Like
- ❑ Luoghi visitati
- ❑ Intervallo sonno-veglia
- ❑ ...

⇒ Targeting migliore ⇒ Più soldi

- ❑ Uso di **stesso username** da device/browser diversi permette di fondere facilmente le informazioni raccolte

Keep in mind



- ❑ Servizi **apparentemente gratuiti** hanno **ovviamente** un costo: informazioni su di noi

- ❑ Purtroppo:
 - ❑ Moltissimi non ne sono consapevoli
 - ❑ Implicazioni profondissime, spesso molto negative, non comprese